

CYBER ELIAS ACADEMY

TEACHING MANUAL

Cybersecurity

Session Roadmap · Lesson Notes · Concept Diagrams · Answer Keys

READY TO TEACH

© 2026 Cyber Elias Academy · cea.ng

Table of Contents

Course Roadmap

Session 01 — Threat Landscape

Session 02 — Passwords MFA

Session 03 — Safe Browsing

Session 04 — Email Phishing

Session 05 — Device Hardening

Session 06 — WiFi Mobile Backups

Session 07 — Assessment Method

Session 08 — Improvement Plan Incident

Session 09 — Capstone Report

OVERVIEW

Course Roadmap

What we cover in every session

#	SESSION TOPIC	WEEK / MODULE	DURATION
01	Threat Landscape	Week 1 â€" Module 1: Hygiene (Stopâ€"Thinkâ€"Verify)	105 minutes
02	Passwords MFA	Week 1 â€" Module 1: Hygiene (Stopâ€"Thinkâ€"Verify)	105 minutes
03	Safe Browsing	Week 1 â€" Module 1: Hygiene (Stopâ€"Thinkâ€"Verify)	105 minutes
04	Email Phishing	Week 2 â€" Module 2: Protecting People and Devices (theme: **Harden**)	105 minutes
05	Device Hardening	Week 2 â€" Module 2: Protecting People and Devices (theme: **Harden**)	105 minutes
06	WiFi Mobile Backups	Week 2 â€" Module 2: Protecting People and Devices (theme: **Harden**) â€" final session of Week 2	105 minutes
07	Assessment Method	Week 3 â€" Module 3: Assess and Improve	105 minutes
08	Improvement Plan Incident	Week 3 â€" Module 3: Assess and Improve	105 minutes
09	Capstone Report	Week 3 â€" Module 3: Assess and Improve (capstone build and present)	105 minutes (build, finalise, present, viva)

How to use this book: Each session below is a complete, ready-to-teach lesson note. Section A tells you what to prepare, B lists the outcomes, D–F are the teaching content, G–H are your demos and practicals, and the knowledge check with answer key is at the end. The concept diagram for each session is embedded as a visual aid.

SESSION 01 OF 9

Threat Landscape

CONCEPT DIAGRAM — SESSION 01



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 1 â€" THE THREAT LANDSCAPE AND A SECURITY MINDSET

A. SESSION IDENTIFICATION

Item	Detail
Session number	1 of 9
Session title	The Threat Landscape and a Security Mindset
Week / Module	Week 1 â€" Module 1: Hygiene (Stopâ€"Thinkâ€"Verify)
Recommended duration	105 minutes
Difficulty level	Beginner (first contact with cybersecurity)
Prerequisite knowledge	Basic computer use â€" using a mouse and keyboard, opening a browser, creating and saving a file. No security knowledge assumed. If a learner struggles with the mouse/keyboard, pair

Item	Detail
	them with a confident learner for the first exercise.
Connection to previous work	This is the first session of the course. There is no previous cybersecurity session. It connects to everyday life: nearly every learner has received a scam SMS or a strange WhatsApp message.
Preparation before class	Academy PCs on and logged in; a projector connected; the four fictional scenario cards (Section G) prepared as printed sheets or projected; the "Red-Flag Record Sheet" (Section H) printed per learner; decide how you will show the fake bank SMS (as a printed card or a simple slide â€" **never** send a real message). Confirm the class understands this is a defensive course with an ethics agreement to sign.

Instructor note on tone: This session must feel *empowering*, not frightening. Learners should leave feeling "I can spot these tricks," not "the internet is a terrifying place I cannot survive." Keep the mood calm, practical and confident.

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Define** cybersecurity in their own words and explain why it matters for ordinary people and small businesses.
2. **Explain and apply** the "Stopâ€"Thinkâ€"Verify" habit before clicking, paying, replying or sharing.
3. **Name and describe** the main malware families â€" virus, worm, trojan, spyware and ransomware â€" and give one plain example of each.
4. **Define** social engineering and phishing, and explain how they trick people (psychology, not just technology).
5. **Describe** common Nigerian scam and fraud patterns â€" fake bank SMS, WhatsApp impersonation, fake job offers, fake investment schemes â€" and list their usual red flags.
6. **Distinguish correctly** between the four core terms: **threat, vulnerability, exploit** and **risk**.
7. **Explain** why small businesses are attractive targets, using at least two reasons.
8. **Identify red flags** in five fictional scenarios and recommend the safe response for each, scoring at least 4 out of 5.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops). A shared computer between two learners is fine; pair them so one reads the scenario and one writes the verdict, then swap.
- Instructor computer connected to a projector or large screen.

Software

- A web browser (Chrome). This session uses no special software â€" it is a think-and-discuss session with checking activities.

Accounts

- None required this session. (Gmail accounts are needed for S2 and S4 â€" remind learners now.)

Sample files

- **Five fictional scenario cards** (Section G and Section H), each describing a message or situation. Created by the instructor; no real victim data.
- **Red-Flag Record Sheet** â€" a one-page table for learners to record, for each scenario: *Is it a threat? What type? What are the red flags? What is the safe action?*
- **Ethics & Scope agreement** (Section 15 of the Design Document) â€" printed for signature.

Worksheets

- Worksheet 1.1 â€" "Spot the Red Flag" (the record sheet above).
- Worksheet 1.2 â€" "Threat, Vulnerability, Exploit, Risk" matching exercise (in the learner workbook).

Tools

- None beyond a browser and paper. A simple slide with the four terms is helpful.

Internet

- Not required. If internet is available, the instructor may show a genuine (harmless, informational) example of a scam-warning article, but the session does not depend on it. Do **not** visit live scam sites.

Alternative for learners who lack a facility

- Any computer with a browser works. If a learner has only a phone, pair them with a desktop user and let them participate in the discussion and verdicts.

Safety note for the instructor (read aloud at the start): Every message, email and scenario used today is **fictional and created for teaching**. We will not open, forward or reply to any real scam. We follow the academy's Ethics & Scope rules at all times.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: Put a simple slide or card on the screen showing a **fictional** text message:

> *"Dear Customer, your account has been flagged for suspicious activity. To avoid suspension, confirm your BVN and ATM PIN at this link immediately: bank-secure-verify.example. Thank you â€" First National Bank."*

(This is a made-up message for teaching. The domain `.example` is a reserved name used in teaching, not a real website.)

What the instructor says:

> *"Good morning. Before we begin â€" hands up if you have ever received a message like this one. â€¦ Almost everyone. Now, hands up if you nearly believed one. â€¦ Good. Today you are going to learn exactly why that message is a trap, and how to spot the next one in five seconds.*
>
> *Look at the message again. It says 'Dear Customer' â€" not your name. It creates fear: 'suspension'. It asks for your **BVN and ATM PIN** â€" things a real bank will never ask for. And it pushes you to click immediately. That is not a bank. That is a trap wearing a bank's clothes."*

Expected learner response: Learners will nod, share quick personal stories, or say "I get these all the time" or "My aunty was almost caught." Accept all answers warmly. **Do not** ask anyone to reveal personal financial details. Steer the discussion to *how* the trick works, not to anyone's loss.

Then set the tone: Say clearly:

> *"This course is **defensive**. We learn to protect, not to attack. We will never try to trick anyone or access a system we do not own. By the end of these three weeks, you will be the person your family and your shop calls when something looks suspicious."*

Why this opener works: It uses a message almost every Nigerian has seen, it produces instant recognition ("that happened to me"), and it frames the whole course as protection and competence rather than fear.

E. PREREQUISITE REVIEW (7 minutes)

Run this as a quick oral round-robin. Put the questions on the projector.

Question 1: "What is the difference between a web browser and a search engine? Give one example of each."

- Expected answer: A browser is the program that displays web pages (Chrome, Edge); a search engine is a website you use *inside* a browser to find things (Google, Bing).
- Common gap: learners use the words loosely. Clarify: "Chrome is the car; Google is the road you drive on."

Question 2: "If a website address starts with `https://` and shows a padlock, what does that tell you?"

- Expected answer: The connection is encrypted â€" the information travelling is scrambled so others cannot easily read it. (The full lesson on what a padlock *does not* mean is in S3.)
- Common gap: many believe "padlock = safe website." Say: "Remember that. We will come back in Session 3 and show you why that belief is only half true."

Question 3: "When you save a file on a Windows computer, where does it normally go, and how do you find it again?"

- Expected answer: Usually the Documents or Downloads folder; you find it with File Explorer.
- Common gap: some learners only know the Desktop. Show File Explorer briefly on the projector.

Bridge to today (say this):

> *"You already use the tools â€" the browser, files, the internet. Today we do not add a new tool. We add a new **way of thinking** that keeps you safe while you use the tools you know. It is called a security mindset, and it starts with three words: **Stop. Think. Verify.**"*

If more than a third of the class cannot answer Question 1, spend 5 extra minutes on a short browser tour before continuing.

F. FULL LECTURE NOTES

F.1 What cybersecurity actually is

The idea. Cybersecurity is the practice of protecting computers, phones, accounts, networks and information from being stolen, damaged or misused.

Plain-English definition. Cybersecurity is everything we do to keep our devices and data **safe** â€" and to keep the wrong people **out**.

Why it exists. Money, private information and important records now live on computers and phones. Banks, businesses, churches, schools and families all depend on digital tools. Wherever there is something valuable, someone will try to take it. Cybersecurity is the lock on the door.

What it protects. Three things again and again:

- **Confidentiality** â€" keeping private things private (your PIN, your customers' records).
- **Integrity** â€" keeping information correct and unaltered (your account balance, your sales records).
- **Availability** â€" keeping your systems working when you need them (your shop can still take orders).

Real-life comparison. Think of a house. You have a **door lock** (passwords), a **window grill** (firewall), a **security light** (updates), and neighbours who know you (good habits). No single one of these makes a house perfectly safe â€" but together, they make it *hard* for a thief, who then moves to the easier house next door. Cybersecurity is the same: we are not trying to be perfect; we are trying to be **too difficult to bother with**.

Important limitation / misconception. Many people think cybersecurity is only for big companies or "computer people." This is false. A market trader's WhatsApp, a church's bank app, a student's Gmail â€" all need the same basic protection. **Small and ordinary can still be a target.**

F.2 The security mindset: Stop â€" Think â€" Verify

The idea. The single most powerful defence is not software. It is a habit of mind.

Plain-English definition. Before you click a link, open an attachment, send money, share a code, or reply to a message, you **stop**, you **think**, and you **verify**.

- **STOP** â€" Do not rush. Scammers depend on speed and urgency. Buying five seconds of calm defeats most attacks.
- **THINK** â€" Ask: *Who sent this? Why are they asking? What are they asking for? Is this normal?*
- **VERIFY** â€" Check through a **different, trusted channel**. Call the bank using the number on your card. Call your "uncle" on a number you already have. Open the official app yourself instead of clicking the link.

Why it works. Almost every scam relies on you acting *fast* and *without checking*. The moment you slow down and verify, the trap falls apart.

Real-life comparison. It is exactly what a careful person does at the market. If a stranger rushes up to you saying "quick, quick, give me â‚¦20,000, your brother sent me," you would stop, think, and call your brother. Do the same online.

Misconception to correct. "I am too clever to be tricked." Everyone can be tricked when they are tired, busy, scared or tempted. The mindset protects the intelligent as much as anyone, because it does not rely on being clever â€" it relies on a habit.

F.3 The malware family

The idea. Malware is short for "malicious software" â€" any program written to harm, spy on, or take control of a device. It is a **family** with several members.

Plain-English definition. Malware is software that does something bad on purpose. Like a family, the members have different behaviours but the same surname.

Type	What it is	Plain example	Familiar analogy
Virus	A piece of bad code that attaches to a file or program and spreads when that file is opened and shared.	An infected USB drive passed around a cyber cafÃ©.	A **cold**: it travels with you and infects others you meet.
Worm	Malware that spreads **by itself** across a network without needing a file to be opened.	A worm that copies itself to every computer on the office Wi-Fi.	A **contagious disease** that spreads by itself with no handshake.
Trojan	Malware disguised as something useful; you install it willingly, thinking it is harmless.	A "free movie player" installer that also steals passwords.	A **Trojan horse** â€" a gift that hides an enemy inside.
Spyware	Secretly watches what you do â€" keystrokes, screens, messages â€" and sends it to the attacker.	A phone app that secretly records your typing.	A **hidden camera** in your room.
Ransomware	Locks or encrypts your files and demands payment to unlock them.	A message saying "Pay â‚¦200,000 or lose all your files."	A **kidnapper** who holds your files and asks for ransom.

Why it exists. For money (ransomware and spyware), for control (turning your PC into part of a criminal network), or simply for vandalism and showing off.

What it does. Steals data, locks files, spies on you, spreads to others, damages the device, or gives the attacker remote control.

Important limitations and misconceptions:

- "Antivirus catches everything." No â€" new malware appears every day, and antivirus is only one layer. Good habits matter just as much.
- "Only Windows gets malware." Windows is the most common target, but phones, Macs and tablets can all be attacked. Nobody is immune.
- "I will see it if I am infected." Malware often hides. That is the whole point. This is why backups and updates matter.

F.4 Social engineering â€" hacking the person, not the computer

The idea. Social engineering is tricking a *person* into giving away information or access. Instead of breaking the computer, the attacker breaks the human.

Plain-English definition. Social engineering is a lie told with confidence, aimed at making you do something against your own interest.

Why it works â€" the five buttons attackers press:

Button	What it means	Scam example
Urgency	"Act now or lose it."	"Your account will be blocked today."

Button	What it means	Scam example
Authority	"I am the bank / the government / the boss."	"This is your bank's security department."
Fear	Scares you into reacting.	"You are in trouble with the police."
Greed	Tempts you with easy money.	"You have won â,¦500,000!"
Helpfulness	Exploits your kindness.	"Please send me your code, I am stranded."

Phishing. Phishing is the most common form of social engineering: a fake message (email, SMS or WhatsApp) that pretends to be from someone you trust â€" your bank, a delivery company, a friend â€" in order to steal a password, a code, or money. It "fishes" for your secrets with tempting bait.

Real-life comparison. Social engineering is like a burglar who dresses as a uniformed delivery man and says, "You have a parcel â€" just let me in to sign it." The door was locked; the burglar simply asked you to open it.

Misconception to correct. "Phishing is only by email." No â€" phishing arrives by SMS ("smishing"), by phone call ("vishing"), and by WhatsApp. The channel changes; the trick stays the same.

F.5 Common Nigerian attack patterns

These are everyday patterns learners will recognise. **All names and details here are illustrative and fictional.**

1. **Fake bank SMS / email.** "Your account has been suspended. Click here to verify." The link goes to a fake login page that steals your details.
   - *Red flags:* generic greeting, a link, urgency, asking for PIN/BVN/OTP.
2. **WhatsApp impersonation.** Someone copies a relative's or friend's profile picture and name, then messages: "I am in trouble, send â,¦50,000 fast."
   - *Red flags:* a new number, rush, an unusual request for money, refusal to talk on a call.
3. **Fake job offers.** "You have been offered a job. Pay â,¦10,000 for your uniform/registration." The real job does not exist.
   - *Red flags:* a real job never asks *you* to pay first.
4. **Fake investment schemes.** "Double your money in one week â€" guaranteed." Early payers are paid with later payers' money, then it collapses.
   - *Red flags:* "guaranteed" high returns, pressure to recruit friends, no registered company.

Why small businesses are targeted. Small businesses are attractive because:

- They often handle **real money and customer data** but have **little protection**.
- They **trust people easily** (regular customers, "new suppliers").
- They may have **one shared account or device**, so one mistake affects everything.
- Their owner is usually **too busy** to stop and check â€" perfect for urgency tricks.

Say this to the class:

> *"The scammer is not smarter than you. The scammer is patient. They send the same message to thousands of people and wait for one tired person to click. Your job is simply not to be that tired person â€" and Stopâ€"Thinkâ€"Verify makes sure of it."*

F.6 Four words that professionals use correctly: threat, vulnerability, exploit, risk

Learners must not confuse these. Use the **locked-house** analogy.

Term	Plain-English meaning	House analogy
Threat	Anything that could cause harm.	A **burglar** who might come.
Vulnerability	A weakness that lets harm happen.	The **open window** the burglar could use.

Term	Plain-English meaning	House analogy
Exploit	The method used to take advantage of the weakness.	The **ladder** the burglar uses to reach the open window.
Risk	The chance and size of harm if threat meets vulnerability.	The **likelihood** the burglar finds the open window and takes something valuable.

The relationship (say it slowly):

> *"A **threat** reaches a **vulnerability** through an **exploit**, and that produces **risk**."*

Example in one sentence: "A scam message (threat) can trick an untrained employee (vulnerability) by pretending to be the boss (the exploit method), and the risk is that the shop loses â‚¦300,000."

Misconception to correct. "Risk" is not the same as "threat." A threat with no vulnerability creates little risk. We reduce **risk** by removing **vulnerabilities** â€" that is exactly what this course teaches.

F.7 Summary of the lecture

- **Cybersecurity** protects the confidentiality, integrity and availability of our data and devices.
- The core habit is **Stop â€" Think â€" Verify**.
- **Malware** is a family: virus, worm, trojan, spyware, ransomware.
- **Social engineering** attacks the person; **phishing** is its most common form.
- Common Nigerian patterns: fake bank messages, WhatsApp impersonation, fake jobs, fake investments.
- **Threat / vulnerability / exploit / risk** are different words with different jobs.
- Small businesses are targeted because they hold value with little protection and are often too busy to check.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

Goal: Walk the class through **five fictional scenarios** on the projector, thinking aloud so learners see *how* a trained eye scans a message. All scenarios are invented for teaching. No real messages are opened.

Setup: Display each scenario card one at a time (printed or on a slide). For each, ask the class to call out what they notice *before* you explain. Write their observations on the board, then reveal the analysis.

Scenario 1 â€" The fake bank SMS

> *"GTB CUSTOMER: Urgent! Your account will be blocked in 2 hours. Re-activate now by confirming your card PIN and OTP at gtb-reactivate.example."*

- **Think aloud:** "Bank name spelled as the bank might shorten it, but the domain is `gtb-reactivate.example` â€" not the bank's real address. It asks for my **PIN and OTP** â€" no real bank ever does this. It uses a 2-hour deadline."
- **Type of threat:** Phishing (smishing) / social engineering.
- **Safe action:** Delete; never click; if worried, open the bank's official app or call the number on your card.

Scenario 2 â€" WhatsApp impersonation

> *A message from a number you do not recognise, using your cousin's photo and name: "Bro, I lost my phone and this is my new number. I need â‚¦80,000 urgently for an emergency. Please send to this account."*

- **Think aloud:** "The name and photo can be copied by anyone. A 'new number' plus an urgent money request plus a different bank account are classic red flags. If it were really my cousin, I could call the old number or our family to confirm."
- **Type:** Social engineering / impersonation / fraud.
- **Safe action:** Do not send money. Call the person on a number you already trust. Warn relatives.

Scenario 3 â€” Fake job offer

> *"Congratulations! You have been selected for a work-from-home job paying â¦150,000 monthly. To secure your position, pay a â¦10,000 registration fee today."*

- **Think aloud:** "Real employers pay you; they do not ask you to pay them. 'Secure your position' creates urgency and greed. No company details, no interview."
- **Type:** Scam / fraud.
- **Safe action:** Do not pay. Verify the company independently. Report to the platform.

Scenario 4 â€” The USB drive found in a car park

> *You find a USB flash drive labelled "SALARY 2026" near the office gate. A colleague says, "Let's check whose it is â€" plug it in."*

- **Think aloud:** "This is a classic trojan delivery. A strange USB could auto-run harmful software or contain a hidden malicious file. The label is bait."
- **Type:** Malware delivery (trojan/virus).
- **Safe action:** Do not plug unknown drives into any computer. Hand it to security or IT.

Scenario 5 â€” The "your PC is infected" pop-up

> *While browsing, a full-screen page appears with a loud alarm: "WARNING! Your computer is infected with 5 viruses! Call this number or click to clean now."*

- **Think aloud:** "A real security tool does not lock your whole screen and shout. This is 'scareware' â€" a fake alert designed to make you call a fake 'support' line or download more malware."
- **Type:** Scam / scareware / malware trap.
- **Safe action:** Do not call, do not click. Close the tab (or restart the browser). Run a real scan with Windows Defender.

Questions to ask during the demo:

- "Which of the five buttons (urgency, authority, fear, greed, helpfulness) is being pressed here?"
- "What is the *one action* that would keep you safe in each case?"
- "Which of these could reach your shop or your church WhatsApp group?"

Expected result: Learners begin calling out red flags on their own by Scenario 3 or 4. Praise that â€" it is the whole point of the session.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: With the instructor guiding step by step, each learner completes a **Red-Flag Record Sheet** for five scenarios, naming the threat type, listing red flags, and choosing the safe action.

Starting materials: A printed Red-Flag Record Sheet per learner, and the five scenarios (reuse the Section G scenarios, or give slightly different ones so learners must think). A pen. No computer needed â€" this is an analysis exercise (a deliberate choice: the brain is the tool).

Procedure (instructor calls out each numbered step; learners work; instructor walks the room):

1. Write your name at the top of the sheet. Remember: everything here is **fictional**. Do not write any real password, PIN or personal number anywhere on this sheet.
2. Look at **Scenario 1**. Read it twice.
3. Fill in Column A â€" **Threat type** (malware family, phishing, social engineering, scam, etc.).
4. Fill in Column B â€" **Red flags** (list at least two things that look wrong).
5. Fill in Column C â€" **Safe action** (the one thing you would do).

6. **Pause and predict:** Before moving on, cover Column C with your hand and ask yourself: "If I did nothing, what would go wrong?" Then write the safe action.
7. Repeat steps 2â€“6 for all five scenarios.
8. When finished, compare with the person beside you. If you disagree on a threat type, explain your reason.

Expected result (model answers â€” instructor key):

#	Threat type	Red flags	Safe action
1	Phishing / smishing	Generic greeting; false urgency; asks for PIN/OTP; strange domain	Do not click; verify via official app/number; delete
2	Impersonation fraud	New number; copied photo; urgent money request; different account	Do not send; call the real person on a known number
3	Job scam	Asks *you* to pay; urgency; no interview or company details	Do not pay; verify employer independently
4	Malware via USB	Unknown drive; tempting label; someone wants to plug it in	Do not plug in; hand to security/IT
5	Scareware / scam	Full-screen panic; asks you to call or download; a real tool would not behave so	Close/restart browser; run a real Defender scan

Points to pause on and predict:

- After Scenario 2: "Could the photo and name be fake?" â†' Yes, easily copied.
- After Scenario 4: "Why is a found USB dangerous even if it is empty-looking?" â†' It can carry hidden malware.

Troubleshooting while walking the room:

- Learner writes "it is bad" â†' Prompt: "Name the *type* and give at least two red flags."
- Learner confuses phishing with malware â†' Remind: phishing *tricks a person*; malware is *harmful software*. They can combine, but they are different.
- Learner wants to "test" a link â†' **Stop immediately.** Remind the Ethics rule: we never open real suspicious links.

Completion checklist (learner ticks each):

- ☐ All five scenarios completed
- ☐ Each has a named threat type
- ☐ Each has at least two red flags
- ☐ Each has one clear safe action
- ☐ No real personal data written on the sheet

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: Create a short **"Family Safety Advice Card"** â€" a mini leaflet that explains one common Nigerian scam and how to avoid it, written for a family member who is not in this class. You choose the audience (e.g., your grandmother, a younger sibling, a shop owner).

Scenario: CEA has asked you to help teach your own family. You must explain, in your own simple words, one threat â€" for example, fake bank SMS or WhatsApp impersonation â€" and give three clear safety steps.

Requirements:

1. Choose **one** threat from today's session.
2. In 3â€"5 sentences, explain in plain language how the scam works (do **not** copy the lecture wording).
3. Give **three** clear safety steps a person can follow.
4. Add a strong one-line motto (you may borrow "Stop â€" Think â€" Verify" or write your own).
5. Keep it on one page, readable by a non-expert.

Constraints:

- Do **not** include any real phone number, account number, link or person's name.
- Do **not** write instructions that could help anyone scam others.
- Use simple English; a real family member should be able to follow it.

Time allowance: 15 minutes.

Success criteria:

- Names one threat clearly.
- Explains how the scam tricks people (mentions at least one "button" â€" urgency, fear, greed, etc.).
- Gives three practical, safe steps.
- Reads clearly to a non-expert and contains no real personal data.

Hints available if stuck:

- Hint 1: Start with "Have you ever seen a message that saysâ€¦?" and describe it.
- Hint 2: The three steps can be: *Stop and do not click; Check with the real bank/person; Report and delete.*
- Hint 3: End with your motto so it is memorable.

Instructor answer key / model (do not show learners until after):

> ***Family Safety Card â€" Beware Fake Bank Messages***
>
> *Sometimes you get a text saying your bank account will be closed unless you click a link and type your card PIN. It is a lie. The sender is a scammer who copies the bank's name to frighten you and make you hurry.*
>
> ***Do these three things:***
>
> 1. *Do not click the link. Your real bank will not ask for your PIN, OTP or BVN in a text.*
> 2. *If you are worried, open your bank's own app or call the number printed on your bank card.*
> 3. *Delete the message and tell your family so they do not fall for it too.*
>
> *Stop â€" Think â€" Verify.*

Marking guidance (out of 10):

- Correctly names one real threat (2)
- Explains the trick clearly and in own words (3)
- Three practical safety steps (3)
- Clear, non-expert-friendly language (1)
- No real personal data; nothing harmful (1)

J. REAL-WORLD CASE STUDY

Situation. *(This is a realistic but non-identifying account, typical of small-business incidents. Names and details are illustrative; no real victim or organisation is described.)*

A small tailoring shop in Port Harcourt â€" let us call it *a family tailoring business* â€" handled orders by WhatsApp and did its accounts on one shared laptop. The owner, "Mama C," received an SMS that appeared to come from her bank: *"Your account is about to be deactivated. Confirm your details to keep receiving payments."* It was late in the evening, she was tired, and the shop's POS payments were her livelihood.

Relevant facts.

- The message used the bank's real name and colours and a fake but convincing web page.
- It asked her to type her card details and the OTP that arrived seconds later.
- The shop used the same password for the laptop, the email and the business Facebook page.

Decision point. She had seconds to decide: click and "secure" her account, or stop and check.

Possible approaches.

1. **Click immediately** to avoid deactivation â€" the scammer's goal.

2. **Ignore it** completely and hope for the best â€” safer, but does not confirm the account.
3. **Stop, Think, Verify** â€” do not click; open the bank's official app; call the number on her card; ask a family member.

Recommended solution. Approach 3. Verifying through a trusted, separate channel is the professional response. Had she already clicked, the right immediate steps would be: call the bank to freeze the card, change the reused password everywhere it was used, and report the incident.

Trade-offs.

- Approach 1: fast, but hands the scammer everything â€” catastrophic.
- Approach 2: avoids this scam but leaves her unsure; she may still panic later and click a similar one.
- Approach 3: takes a few extra minutes, but resolves both the fear and the risk, and teaches the whole family.

Professional connection. This is exactly what security-aware staff do every day: **verify through a second channel before acting on any urgent request.** It is the single most transferable habit in the whole course.

K. COMMON MISTAKES AND TROUBLESHOOTING

Use this table as the session's live troubleshooting guide.

K.1 Confusing phishing with malware

Symptoms: Learner calls a fake bank SMS "malware." **Likely cause:** The learner has not separated *tricking a person* from *harmful software*. **How to investigate:** Ask: "Was the attacker attacking a computer, or tricking a person?" **Safe corrective steps:** Re-explain: phishing/social engineering attacks the **person**; malware is **software** that harms the device. They can be combined but are different categories. **How to confirm resolved:** Learner classifies a message and a file correctly and gives a reason. **How to prevent recurrence:** Always ask "person or program?" first.

K.2 Thinking "I will never be tricked"

Symptoms: Learner dismisses the scenarios as "obvious." **Likely cause:** Overconfidence; they have not yet felt the urgency/temptation. **How to investigate:** Ask them to read a scenario as if it arrived *at 11 p.m. after a long day*. **Safe corrective steps:** Explain that scams target tiredness and emotion, not intelligence. **How to confirm resolved:** Learner gives a reason for the mindset ("because anyone can be rushed"). **How to prevent recurrence:** Repeat the "anyone can be tricked" message every week.

K.3 Wanting to "test" or open a suspicious link

Symptoms: Learner says "let me just click it and see." **Likely cause:** Curiosity; lack of awareness of the ethics and the risk. **How to investigate:** This is a **stop-and-correct** moment, not an investigation. **Safe corrective steps:** Firmly remind the class: we never open real suspicious links, and never test systems we do not own. Use only fictional samples. **How to confirm resolved:** Learner restates the Ethics rule correctly. **How to prevent recurrence:** Re-read the Ethics & Scope statement at the start of any hands-on session.

K.4 Mixing up threat, vulnerability, exploit and risk

Symptoms: "The threat is that the window is open." **Likely cause:** The four words sound interchangeable to a beginner. **How to investigate:** Ask the learner to match each word to the house analogy. **Safe corrective steps:** Re-draw the burglar / open window / ladder / chance table. **How to confirm resolved:** Learner can place all four words correctly on one example. **How to prevent recurrence:** Use the four words in every later session.

Distinguish likely vs confirmed: A "likely cause" becomes "confirmed" only after you check it (e.g., the learner can point to the exact word in the message that is the red flag). Teach learners to confirm before concluding.

L. SESSION ASSIGNMENT

Assignment title: "Scam Watch Diary â€” Three Messages I Noticed"

Purpose: Practise recognising real-world threats safely, and build the habit of observing and reasoning rather than reacting.

Realistic scenario: Over the next few days, you will almost certainly see a suspicious message, pop-up, call or post (many people do). Instead of reacting, you will simply **observe and record** â€" safely, without clicking anything.

Detailed instructions:

1. Over the next few days, notice **three** suspicious things (a text, a WhatsApp message, an email, a pop-up, or a phone call). **Do not interact with them** â€" do not click, reply, or call back.
2. For each one, write in your workbook:
   - **What it was** (e.g., "SMS pretending to be a bank") â€" describe it; do **not** copy any real link or anyone's personal data.
   - **Threat type** (malware / phishing / social engineering / scam).
   - **At least two red flags** you spotted.
   - **The safe action** you took (usually: do not click; verify; delete; report).
3. Write one sentence at the end: "*The mindset I used was Stop â€" Think â€" Verify.*" (or describe your own reasoning).
4. If you cannot find three real examples, you may use the five class scenarios, but write your analysis in **your own words**.

Required deliverables:

- A written Scam Watch Diary with three entries (workbook or handwritten sheet).
- No links, no real phone numbers, no personal data.

Submission format: Handwritten or typed, submitted at the start of Session 2.

Deadline: Before Session 2.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Three entries completed	3	Three distinct, clearly described items
Correct threat types	4	Each correctly classified with reasoning
Red flags identified	5	At least two specific red flags per entry
Safe actions	4	Practical, correct, non-harmful responses
Own words / observation	2	Analysis written in the learner's own words
Safety and ethics	2	No real data or links; no attempted interaction

Common mistakes to avoid: writing "it looked bad" without specific red flags; clicking the link "just to check"; copying real links or numbers; confusing phishing with malware.

Instructor reference solution (one entry, as a model):

> *Entry: I received an SMS saying a courier company was holding my parcel and I should pay â‚¦2,500 via a link. Threat type: scam/phishing (smishing). Red flags: (1) I was not expecting any parcel; (2) it asked for payment through a strange link with urgency. Safe action: I did not click; I deleted the message and warned my roommate.*

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key.)

Q1. Short answer. In your own words, what is cybersecurity, and why does it matter to a small shop owner?

Q2. Multiple choice. Which type of malware locks your files and demands payment to unlock them? a) Virus b) Spyware c) Ransomware d) Trojan

Q3. Explain in your own words. What does "Stop â€" Think â€" Verify" mean? Give one example of *verifying*.

Q4. Practical identification. Is this safe or unsafe, and why?

> *"Dear Customer, your BVN is required to update your account. Click here and enter your PIN."*

Q5. Matching. Match each word to its meaning: **threat, vulnerability, exploit, risk.** a) A weakness that lets harm happen b) Anything that could cause harm c) The method used to take advantage of a weakness d) The chance and size of harm

Q6. Scenario. Your "uncle" messages from a new number asking you to send â‚¦100,000 urgently. Write the three things you would do, in order.

INSTRUCTOR ANSWER KEY (Q1â€“Q6)

A1. Cybersecurity is the practice of protecting our devices, accounts, networks and data from being stolen, damaged or misused. For a shop owner it matters because the business holds money, customer records and trust â€” one trick can cost real naira and reputation. (Accept any answer covering protection of data/devices and real-world value.)

A2. (c) Ransomware.

A3. Stop = do not rush; Think = who/what/why and is it normal; Verify = check through a different trusted channel. Example of verifying: calling the bank on the number printed on your card, or calling your uncle on his old, known number. (Accept any correct verification example.)

A4. Unsafe. It is phishing. Red flags: generic greeting, requests BVN/PIN (a real bank never asks for a PIN), urgency to click a link. Safe action: do not click; verify via the official app/known number; delete.

A5. threat = (b); vulnerability = (a); exploit = (c); risk = (d).

A6. 1) Do **not** send money. 2) **Verify** by calling your uncle on his number you already have (or check with family). 3) If confirmed a scam, warn relatives and report/block the number. (Accept any correct ordering that includes not paying and verifying through a trusted channel.)

N. REFLECTION AND RECAP

Plain-English summary. Today you learned that cybersecurity is about protecting our money, data and devices, and that the strongest defence starts with a habit: **Stop â€“ Think â€“ Verify.** You met the malware family â€” virus, worm, trojan, spyware, ransomware â€” and learned that social engineering tricks *people*, with phishing as its most common form. You studied familiar Nigerian patterns: fake bank messages, WhatsApp impersonation, fake jobs and fake investments, and you learned why small businesses are targets. Finally, you learned to tell apart a **threat**, a **vulnerability**, an **exploit** and a **risk**, and you practised spotting red flags in five scenarios.

Five important takeaways:

1. Cybersecurity protects confidentiality, integrity and availability â€” and ordinary people need it, not just big companies.
2. **Stop â€“ Think â€“ Verify** before you click, pay, reply or share.
3. Malware is a family: virus, worm, trojan, spyware, ransomware.
4. Social engineering attacks the person; phishing is its most common form, and it comes by email, SMS and WhatsApp.
5. **Threat, vulnerability, exploit and risk** are different words â€” learn them properly.

Questions to help you recognise what you can now do:

- Can I explain "Stop â€“ Think â€“ Verify" to a family member?
- Can I name the five malware family members?
- Can I spot two red flags in a fake bank SMS?
- Can I tell the difference between a threat and a vulnerability?

Connection to the next session: You now know the threats. But the number one way attackers get in is still the simplest: they guess or steal a **password**. Next session we make your accounts almost impossible to break â€” strong passwords, multi-factor authentication, and a free password manager.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- Learner names threat types correctly and gives a *reason*, not just a word.
- Learner applies Stopâ€"Thinkâ€"Verify spontaneously in discussion ("I would call the bank first").
- Learner distinguishes phishing (person) from malware (software).
- Learner uses the four risk words correctly and points to the exact red flag in a message.
- Learner warns others and stays calm rather than panicking.

Common misconceptions to watch for and correct:

- "Cybersecurity is only for big companies / tech people." â†' Ordinary users and small shops are common targets.
- "A padlock means the site is safe." â†' Only that the connection is encrypted; the site can still be dishonest (full lesson in S3).
- "I am too clever to be tricked." â†' Scams target tiredness and emotion, not intelligence.
- "Phishing only comes by email." â†' It also arrives by SMS, WhatsApp and phone call.
- "Antivirus solves everything." â†' It is one layer; habits, updates and backups matter too.

Suggested remedial exercises for learners who struggle:

1. **Matching drill:** give cards with the four risk words and their meanings; learner matches and explains one.
2. **Red-flag hunt:** give a short fake message and ask the learner to underline every red flag and count them.
3. **Button identification:** show three scams and ask which "button" (urgency, fear, greed, authority, helpfulness) each presses.

Differentiation:

- **Level 1 (supported):** provide a partially completed Red-Flag Record Sheet (threat type already given for scenarios 1 and 2) and word-bank hints.
- **Level 2 (standard):** the exercise as written.
- **Level 3 (challenge):** ask the learner to write an *original* fictional scam scenario of their own, label its threat type, list red flags, and add the safe action â€" then swap it with a partner to solve. (Still fictional; never real.)

Timing guidance: If the room is slow, shorten the lecture's Section F.5 examples and protect the guided practical (Section H) â€" the ability to *spot red flags* is the priority. If the room is fast, extend the case study discussion and let learners present their Family Safety Cards.

END OF SESSION 1

Next: Session 2 â€" Passwords, MFA and Password Managers.

SESSION 02 OF 9

Passwords MFA

CONCEPT DIAGRAM — SESSION 02



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 2 â€" PASSWORDS, MFA AND PASSWORD MANAGERS

A. SESSION IDENTIFICATION

Item	Detail
Session number	2 of 9
Session title	Passwords, MFA and Password Managers
Week / Module	Week 1 â€" Module 1: Hygiene (Stopâ€"Thinkâ€"Verify)
Recommended duration	105 minutes
Difficulty level	Beginner
Prerequisite knowledge	Session 1 (threat vocabulary and the Stopâ€"Thinkâ€"Verify mindset). Basic ability to log in to an account and open a web browser.

Item	Detail
Connection to previous work	In Session 1 you learned *who* the attackers are and *how* they trick people. Today we block the number-one way they get in: a weak or reused password. Every threat from S1 becomes much harder to exploit once your accounts are strong and protected with MFA.
Preparation before class	Academy PCs on and logged in; Chrome open; **Gmail accounts ready** (create in the first 10 minutes if needed, or ask learners to bring their own); internet available for HaveIBeenPwned (own email only) and Bitwarden demo. Print Worksheet 2.1 (Password Upgrade) and Worksheet 2.2 (MFA Steps). **Confirm the ethics and privacy reminders** before any learner types their email anywhere. Test the projector so learners can follow screenshots live.

Instructor safety note: Learners will handle their **own** email on a public breach-checking site today. Before that activity, read the privacy reminder aloud (Section G) and tell learners they may opt out and watch the demonstration instead. Never check anyone else's email.

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Explain** why passwords fail â€" guessing, reuse, breaches and weak patterns â€" in plain language.
2. **Create** a strong passphrase (length, uniqueness, no personal information) that is easy to remember and hard to guess.
3. **Explain** why reusing one password everywhere turns a single breach into many compromises.
4. **Describe** what a data breach is and **check** whether their **own** email appears in a known breach, using a public breach-checking service.
5. **Set up** multi-factor authentication (MFA) on their **own** account and explain the difference between authenticator-app MFA and SMS-code MFA.
6. **Use** a free password manager (Bitwarden) to generate and store a unique password, and explain how it protects them.
7. **Describe** account-recovery best practice (recovery email, recovery codes, honest security questions) and why it matters.
8. **Produce** a personal account-safety action list: one upgraded password, one MFA-enabled account, one password-manager entry.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops). A shared computer is acceptable; pair learners so one types and one reads the on-screen prompts aloud, then swap.
- Instructor computer connected to a projector.
- Learners may bring their own phone for the authenticator-app demonstration (optional but recommended).

Software

- Google Chrome (any recent version).
- A free password manager: **Bitwarden** â€" either the web vault at a browser, the browser extension, or the desktop app. The instructor demonstrates; learners create a free account or watch.
- A free authenticator app for MFA demonstration (e.g., Google Authenticator or any reputable TOTP app). Mentioning one is enough; the academy does not endorse a single product â€" all TOTP apps follow the same standard.

Accounts

- **Learner's own Gmail account** (required). If a learner does not have one, help them create it at the start, or pair them with a learner who does for demonstration purposes. Learners never log into someone else's account.
- **Free Bitwarden account** (optional for learners; created for the demonstration).

Sample files

- **Worksheet 2.1 â€" Password Upgrade** (printed, 1 page).

- **Worksheet 2.2 â€" Turn On MFA Step Tracker** (printed, 1 page).
- A slide with **three sample weak passwords** and **three sample passphrases** (fictional, e.g., `Password123`, `Adaeze2010`, `Correct-Horse-Battery-Staple`) for class discussion.

Tools

- Chrome with the Bitwarden extension (instructor machine).
- A TOTP authenticator app (instructor machine and learner phones where available).
- HaveIBeenPwned website (own email only, with consent).

Internet

- Required for HaveIBeenPwned and Bitwarden. If internet fails, the instructor demonstrates on the projector with a demo account and learners complete the offline worksheets.

Alternative for learners who lack a facility

- Any device with Chrome works. Phone-only learners can follow along for the MFA and Bitwarden parts, and use the offline worksheets if they cannot sign in on a desktop.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: Write three passwords on the board:

> `password123` Â· `Adaeze2010` Â· `Chinedu4real`

What the instructor says:

> *"Look at these three. Which is the strongest? â€¦ Many of you said the third, or the second, because it has a name and a number. Let me tell you a secret: to a computer, all three fall in the same few seconds.*
>
> `password123` *is on every 'most-used passwords' list in the world.* `Adaeze2010` *uses a name and a year â€" a computer can guess names and years almost instantly. And* `Chinedu4real` *â€" a name, a number, and a common word.*
>
> *Here is the truth: passwords are not protected by cleverness. They are protected by* ***length and uniqueness****. Today you will learn to build passwords that a computer cannot guess, protect them with a second lock called MFA, and store them safely in a free password manager."*

Expected learner response: Learners usually believe a name-plus-year is strong. Some will say "I use my birthday." Accept answers without judgement and use the moment to reset the belief.

Then hook with this question: "How many of you use the same password â€" or a small set â€" for your Gmail, your bank app, and your Facebook?" Many hands go up. Say:

> *"By the end of today, that will change. One reused password is like using the same key for your house, your car, your shop and your safe. If a thief copies that one key, everything opens."*

Why this opener works: It directly challenges a widespread misconception, uses familiar Nigerian names, and lands on the concept (length + uniqueness) that the whole session rests on.

E. PREREQUISITE REVIEW (7 minutes)

Run this as a quick oral round-robin. Put the questions on the projector.

Question 1: "What are the three words of our security mindset from last session?"

- Expected answer: **Stop â€" Think â€" Verify.**

- Common gap: learners remember "look and check" but not the exact habit. Re-state it and ask for one example of "verify."

Question 2: "Which type of malware locks your files and demands money?"

- Expected answer: ransomware.
- Common gap: confusing ransomware with spyware. Re-state: ransomware kidnaps files; spyware watches secretly.

Question 3: "What is phishing, in one sentence?"

- Expected answer: a fake message pretending to be from someone trusted, to steal a password, code or money.
- Common gap: saying phishing is a virus. Clarify again: phishing tricks the *person*; malware is *software*.

Question 4: "Why do scammers love 'urgency'?"

- Expected answer: because it stops people pausing and checking.
- Common gap: learners think they personally are too careful. Remind: urgency beats carefulness when you are tired.

Bridge to today (say this):

> *"Last time we learned to spot the trick. Today we make the prize **worthless to the thief**. Even if a scammer tricks you into giving away your password, we are going to add a second lock that stops them â€" and we make sure no single stolen password ruins all your accounts."*

If more than a third cannot answer Question 1, spend 3 extra minutes re-reading the S1 recap before continuing.

F. FULL LECTURE NOTES

F.1 Why passwords fail

The idea. Passwords are the front door to your digital life. When they are weak, it does not matter how good the rest of your security is.

Plain-English definition. A **password** is a secret word or phrase that proves you are you. A password "fails" when someone else can guess it, discover it, or use it.

Passwords fail in **four** common ways:

Way it fails	What it means	Familiar example
Guessing	The password is short or predictable.	`123456`, `password`, `qwerty`
Weak patterns	Names, birthdays, phone numbers, "add a 1 at the end."	`Adaeze2010`, `0803xxxx`, `blessing123`
Reuse	The same password used on many accounts.	One password for Gmail, bank and Facebook
Breaches	A website you used was hacked and your password leaked.	A shopping site leaks all user passwords

Why computers make guessing deadly. A human guesses slowly. A computer tries **millions of guesses per second**. So short passwords (or homepage patterns) are not "hard to guess" â€" they are *easy* for a machine.

Real-life comparison. A password is like the combination lock on a safe. `1234` takes seconds. A long, random combination takes centuries. The lock is only as strong as how many possibilities someone must try.

Important limitation / misconception: "It is hard for a human to guess, so it is safe." Wrong. Attackers use machines. Judge your password by how a *computer* would see it, not by how clever it feels.

F.2 What makes a strong password â€" and the magic of length

The idea. Two things make a password strong: **length** and **uniqueness**. Anything else is secondary.

Plain-English definition. A strong password is **long enough** that guessing is hopeless, and **unique** to one account, so a breach elsewhere cannot hurt other accounts.

Length wins. Every extra character multiplies the number of possible combinations. This is why security professionals say: **length beats complexity.** A long, ordinary-looking phrase is often stronger and easier to remember than a short, messy jumble.

Passwords versus passphrases.

- A **password** is usually short and often hard to remember â€" so people write it down or reuse it.
- A **passphrase** is a **sentence-like string of several words**. Example: `Purple-Market-Goat-Sunday-72`. It is long, has no personal meaning, and is far easier to remember.

Real-life comparison. A 3-letter padlock code has 1,000 possibilities. A 12-character passphrase has so many that a machine would spend an absurdly long time. You have effectively turned a bicycle lock into a bank vault.

The rules of thumb for this course (memorise these four):

1. **Make it long** â€" at least **12â€"16 characters**, longer is better.
2. **Make it unique** â€" a different password for **every** important account.
3. **Avoid personal information** â€" no names of family, birthdays, phone numbers, or state/city names.
4. **Let a tool remember it** â€" a human should not have to memorise twenty passwords. That is what the password manager (F.5) is for.

Worked example â€" weak versus strong:

Example	Why
`chinedu123`	Short, name + sequence â€" weak
`Ch1nedu@2026!`	Long-ish and mixed, but based on a name and year â€" still risky
`Market-Goat-Purple-Sunday-72`	Long, random words, no personal info â€" **strong passphrase**
`v8K#2pL!q9Xw`	Random-looking, good if generated by a manager â€" **strong password**

Misconception to correct: "Adding a symbol makes it strong." Symbols help a little, but a short password with symbols is still short. **Length does the heavy lifting.**

F.3 Password reuse â€" the domino effect

The idea. Using one password across many sites means one breach topples all your accounts.

Plain-English definition. Password reuse is using the same password (or a tiny variation) on more than one account.

Why it is so dangerous. Attackers do not need to break into your bank directly. They break into the *weakest* site you used (a small forum, an old shopping site), steal the password list, then try the same email-and-password on Gmail, Facebook, bank apps and more. This automated trick is called **credential stuffing** â€" using stolen username/password pairs on other services.

Real-life comparison. It is like using **one key for your house, your car, your shop safe and your church store**. If that single key is copied once, every door opens. Unique passwords mean each door has its own lock, so one stolen key opens only one door.

Say this to the class:

> *"A reused password is a **single point of failure**. When one site is breached, you do not lose one account â€" you lose everything that shares that password. Uniqueness is what stops the dominoes from falling."*

Misconception to correct: "I change one letter, so it is unique." `Adaeze2010` and `Adaeze2011` are almost the same to a computer. True uniqueness means genuinely different passwords, which is why we use a manager to generate and store them.

F.4 What a data breach is â€" and checking your own email safely

The idea. A **data breach** is when a company's data â€" including user emails and passwords â€" is stolen or leaked.

Plain-English definition. A breach is a break-in at a company where your information was stored. You did nothing wrong; the company's security failed.

Why it matters to you. If your email and password appear in a breach, attackers will try them elsewhere (credential stuffing). Knowing your email has been breached is a warning to **change that password everywhere you used it** and turn on MFA.

HaveIBeenPwned (own email only). There is a free public website that lets you check whether an email address has appeared in known breaches. It **does not ask for your password** â€" only the email address. The result tells you *which breaches* included that address.

How to use it safely: type **only your own** email; remember that entering your email is your own choice; you may opt out and just watch the demonstration instead. The service tells you your email was in a breach â€" it does **not** mean your account is now broken into, and it does **not** reveal your current password.

Privacy reminder (read aloud before the activity): "*You will check your **own** email only. Never check a friend's, a family member's, or a customer's email. If you prefer not to, watch the projector. This is your choice.*"

Misconception to correct: "If my email shows up, my account is hacked." Not necessarily â€" it means the *address* appeared in a breach. Treat it as a strong nudge to change passwords and enable MFA.

F.5 Multi-factor authentication (MFA) â€" the second lock

The idea. Multi-factor authentication (MFA) means logging in needs **more than just a password**. It is the single biggest improvement most people can make to their account safety.

Plain-English definition. MFA asks for something you **know** (password) **plus** something you **have** (your phone or a code) or something you **are** (fingerprint/face). Two different kinds of proof are far stronger than one.

Why it works. Even if a scammer steals your password, they usually still cannot log in, because they do not have your second factor. MFA breaks the "stolen password = stolen account" chain.

Common second factors:

Type	What it is	Strength	Notes
Authenticator app (TOTP)	An app that generates a new 6-digit code every 30 seconds	**Strong**	Codes work even without network; not tied to your phone number
SMS code	A code sent by text message	**Weaker but still useful**	Can be intercepted or SIM-swapped; better than nothing
Security key / passkey	A physical USB key or device biometric	**Very strong**	Advanced; mention only
Email code	A code sent to your email	Weakest factor type	Useful as a fallback

Authenticator app versus SMS â€" why app-based MFA is stronger. A text-message code travels over the mobile network and can be intercepted or stolen through SIM-swap fraud, where a criminal convinces your network to move your number to their SIM. An **authenticator app** on your own device generates codes locally and is not tied to your phone number, so it is not vulnerable to SIM swap. Use app-based MFA whenever a service offers it.

Real-life comparison. MFA is like needing **both a key and a PIN** to enter a strongroom. Even if someone copies your key, they still cannot get in without the PIN.

Misconception to correct: "MFA means I can use weak passwords." No â€" MFA is a **second** layer. Strong passwords **and** MFA together are best. Also, do not approve an MFA prompt you did not start â€" if your phone suddenly asks "Approve sign-in?", someone may have your password; press **deny** and change it.

F.6 Password managers â€" the honest way to be secure

The idea. A **password manager** is a secure app that **generates** strong, unique passwords and **remembers** them for you, protected by one master password.

Plain-English definition. Instead of memorising many passwords, you memorise **one** strong master passphrase, and the manager stores the rest in an encrypted vault.

Why it exists. The advice "use a different strong password for every account" is impossible to follow by memory. The manager makes good security practical.

What it does:

- Generates long, random, unique passwords.

- Fills them in automatically on websites.
- Stores them in an encrypted vault protected by your master password.
- Syncs across your devices (in the paid/optional tiers; the free tier also syncs across devices).

Bitwarden. We use **Bitwarden** as a free, reputable example. It is one option among several; the lesson is the *behaviour*, not the brand. You create a free account, choose a strong **master passphrase**, and it keeps the vault. The master passphrase is the one thing you must remember well.

Real-life comparison. A password manager is like a **locked filing cabinet with a single strong key**. All your account keys are inside, organised; you carry only the master key.

Important limitations and honest caveats:

- The **master passphrase must be strong and unique** â€" it is the key to everything.
- Enable **MFA on the password manager itself.**
- **If you lose the master passphrase and have no recovery**, you can lose the vault. Keep recovery codes safe (F.7).
- A password manager is **not invincible** but it is far safer than reusing one password. Reputable managers use strong encryption.

Misconception to correct: "Writing any password down is always wrong." Writing passwords on paper **anywhere others can find them is risky**, and typing them into an untrusted file or your notebook is also risky. But a reputable password manager storing them in an encrypted vault is **safer** than reuse. The old advice was to never write anything down; the modern, honest advice is: *use a manager, and protect the master passphrase.*

F.7 Account recovery â€" plan for the "I forgot" day

The idea. Account recovery is how you regain access if you forget a password or lose your phone. Attackers use it too, so it must be protected.

Best practice:

- **Set a recovery email and phone** you control and can access.
- **Save recovery codes** (one-time backup codes services give you) somewhere safe and offline â€" not in the same place as the account.
- **Choose security questions honestly.** Do not use answers anyone can find on social media (your mother's maiden name, your school, your pet). Better: treat them like passwords â€" a made-up but consistent answer stored in your password manager.
- **Turn on MFA** so a stolen recovery email alone is not enough to take over the account.
- **Revoke old sessions/devices** from the account settings if you suspect anything is wrong.

Real-life comparison. Recovery is the spare key you leave with a trusted neighbour. If the wrong person finds it, they can walk in â€" so you must protect the spare key too.

Say this to the class:

> *"Attackers do not only guess passwords. They attack the **recovery** path. Your recovery codes and recovery email are as valuable as your password. Protect them."*

F.8 Summary of the lecture

- Passwords fail by **guessing, weak patterns, reuse and breaches**.
- Strength comes from **length and uniqueness**; a long passphrase beats a short clever password.
- **Reuse** is a domino effect â€" use a unique password for every important account.
- A **breach** means a company leaked data; check your **own** email on HaveIBeenPwned as a warning, not a diagnosis.
- **MFA** adds a second lock; an **authenticator app** is stronger than SMS.
- A **password manager** (e.g., Bitwarden) generates and stores unique passwords behind one strong master passphrase.
- Protect your **account recovery** path â€" recovery codes and recovery email are keys too.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

Goal: Show, on the projector, the whole safety upgrade in action: (1) improving a weak password, (2) checking an email on HaveIBeenPwned, (3) enabling MFA, (4) using Bitwarden to generate and store a password. All on **your own** accounts, with fictional examples where possible. Learners then do the same on **their own** accounts in Section H.

Setup: Chrome open. Bitwarden extension installed on the instructor machine. A TOTP authenticator app ready. A demo Gmail account owned by the academy (not a learner's). Read the privacy reminder aloud before the breach check.

G.1 Demonstration 1 â€" Weak password to strong passphrase (4 minutes)

Say: "Watch how I turn a weak password into something a computer cannot guess â€" while keeping it easy to remember."

On screen, transform:

- Weak: `adaeze123`
- Step 1 (longer): `adaeze-123-fashion` â€" still has a name and number; not good enough.
- Step 2 (random words, no personal info): `Market-Goat-Purple-Sunday-72`

Type it into a password-strength checker (or the Bitwarden generator preview) and show the strength bar jump. Ask the class: "Why is the last one stronger even though it looks like nonsense?" Expected: because it is long and has no personal information.

G.2 Demonstration 2 â€" Checking an email on HaveIBeenPwned (4 minutes)

Read the privacy reminder:

> *"I am using the academy's **own** demo email, not your personal one and not anyone else's. Later, you may check your **own** email, or simply watch. You decide."*

Steps on the projector:

1. Open the HaveIBeenPwned site.
2. Type the academy demo email (or, deliberately, a well-known example address so no real person is exposed).
3. Show the results page: which breaches the address appeared in.
4. Read the guidance: "*The email was present in a breach. This means a site you used was compromised. Your first action is to change that password on the affected site and anywhere you reused it, then enable MFA.*"
5. **Point out clearly:** "Notice it never asked for my password. A legitimate breach checker only needs the email address."

Questions to ask during the demo:

- "Does finding my email here mean my account is hacked right now?" (No â€" it means my address appeared in a breach; treat it as a warning to change passwords and enable MFA.)
- "Whose email may you check?" (Your own only.)

G.3 Demonstration 3 â€" Turning on MFA (4 minutes)

On the projector, using the demo account:

1. Open **Account settings â†' Security â†' Two-step verification / 2-Step Verification**.
2. Choose **Authenticator app** (not SMS, if offered).
3. Show the QR code appearing. **Do not show any real secret if the projector is public** â€" for a demo account it is acceptable, but say aloud: "In real life, never show this QR code to anyone."
4. Scan with the authenticator app (show on your phone or a screen capture), enter the 6-digit code, confirm.
5. Show the account now asking for the code at login.
6. **Show the recovery codes screen** and say: "These are backup keys. I would save these somewhere safe, offline, away from the account." Store them in the password manager or print them.

Point out: "The scammer can have my password and still be locked out â€" because they do not have my phone's app."

G.4 Demonstration 4 â€" Bitwarden generates and stores a password (3 minutes)

On the projector:

1. Open Bitwarden (browser extension or web vault).
2. Create/show the demo account with a **strong master passphrase**.
3. Click **Add item â†' Add a login**.
4. Use **Generate password** to produce a long random password.
5. Save the item with the account name (e.g., "Demo shop account").
6. Show how Bitwarden **fills the login automatically** on the demo site.
7. Demonstrate enabling **MFA on Bitwarden itself** (briefly).

Say: "Now I only remember one strong master passphrase. Every other password is long, random, unique and safely stored. This is the honest way to be secure."

Common errors to show and mention:

- Weak master passphrase â†' the whole vault is only as strong as that one phrase.
- Not saving recovery codes â†' risk of being locked out.
- Approving an unexpected MFA prompt â†' always press deny.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: With the instructor guiding step by step, each learner completes three safe tasks on their **own** machine/accounts: (1) upgrade a weak password to a strong passphrase on paper and in a real (or practice) account, (2) check their **own** email on HaveIBeenPwned (optional) and interpret the result, and (3) set up MFA on one **own** account, plus store a password in Bitwarden.

Starting materials: Worksheet 2.1 (Password Upgrade) and Worksheet 2.2 (MFA Steps) per learner; Chrome; internet; own Gmail account; a phone (optional, for the authenticator app).

Safety and privacy first â€" say aloud:

> *"You will work only on **your own** accounts. Never type another person's email or password into anything. Anything you find on the breach checker is private â€" do not share it or shout it out."*

Procedure (instructor calls out each numbered step; learners follow; instructor walks the room):

Part 1 â€" Build a strong passphrase (5 min)

1. On Worksheet 2.1, write one weak password you have used before. **Do not write any real current password for a real account anywhere.**
2. List the red flags in it (name? year? short? reused? that is the analysis).
3. Now build a passphrase: choose **3â€"4 random, unrelated words** plus a number or symbol. Example pattern: `Word-Word-Word-Number`.
4. **Pause and predict:** "Could someone who knows me guess these words? Does it contain my name, birthday or phone number?" If yes, change the words.
5. Write your new passphrase on the worksheet. This is a *learning* passphrase; keep the sheet private or destroy it after class â€" never leave a list of passwords lying around.

Part 2 â€" Check your own email (4 min, optional/consent) 6. If you consent, open HaveIBeenPwned and type your **own** email only. 7. Read your result. On Worksheet 2.1 write down: *Was my email found? Yes/No. If yes, what will I do?* (Usually: change that password and enable MFA.) 8. If you do not consent, watch the projector and write "Watched demonstration."

Part 3 â€" Turn on MFA on one own account (6 min) 9. Open your **own** Gmail (or another own account you choose). 10. Go to **Security â†' 2-Step Verification**. 11. Choose **Authenticator app** if available (phone), or SMS if that is all you have. 12. Follow the on-screen QR/steps. If you do not have a phone, watch the instructor and write the steps on Worksheet 2.2. **Do not proceed if you cannot complete it now â€" you may finish at home, and that is fine.** 13. **Save your recovery codes** somewhere safe. Write on the worksheet *where* you saved them (not the codes themselves).

Part 4 â€" Store a password in Bitwarden (3 min) 14. Open Bitwarden. Create a free account with a **strong master passphrase** (reuse your Part 1 pattern if you like â€" but a **different** phrase). 15. Add one login: account name + username + a **generated**

password. 16. **Pause and predict:** "What is the one password I must now remember well?" â†' the master passphrase.

Expected result: Each learner has a model passphrase on paper, an interpreted breach result (or "watched"), MFA enabled on one own account (or the steps recorded), and one stored login in Bitwarden.

Points to pause on and predict:

- After step 5: "Why is this passphrase strong?" â†' long, unrelated words, no personal info.
- After step 7: "Does 'no result' mean I am totally safe?" â†' No; it means this service has no record; still use unique passwords and MFA.
- After step 12: "Why app over SMS?" â†' app codes are not tied to your phone number, so SIM swap cannot steal them.

Troubleshooting while walking the room:

- Learner cannot create MFA because the account already has it â†' Good; help them verify it works, then choose a *different* own account, or record the steps.
- Learner has no phone â†' Use a desktop authenticator option if offered, or record the steps; never handle their account for them.
- Learner worries about typing their email â†' Reassure; on-site result; optional; they may watch.
- Learner locks themselves out â†' This is why we save recovery codes. Walk them through the recovery flow calmly.

Completion checklist (learner ticks each):

- ☐ I identified why a weak password is weak
- ☐ I created a strong passphrase (long, unique, no personal info)
- ☐ I checked my own email (or watched) and interpreted the result
- ☐ I enabled MFA on one own account, or recorded the exact steps
- ☐ I saved my recovery codes safely (I know where)
- ☐ I stored at least one generated password in Bitwarden

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: You are the **volunteer "security helper"** for a small church in Port Harcourt. The church uses one shared Gmail account for announcements, a WhatsApp account, and a laptop that many people touch. You must write a **one-page Password & Account Safety Plan** for them.

Scenario: The church's shared Gmail account has the password `church2020`. Several members know it. The pastor is worried. You must advise, using only what you learned today.

Requirements:

1. Explain in 2â€"3 sentences **why** `church2020` is unsafe (name + year + shared + likely reused).
2. Recommend a plan covering:
   - A stronger way to share the account safely (e.g., a strong unique passphrase stored in a password manager, not written on a wall).
   - **MFA** on the account (app-based, not SMS, and why).
   - What to do about the laptop (who logs in, lock screen, do not save passwords in the browser on a shared PC).
   - Recovery: set a recovery email/phone and save recovery codes.
3. Keep it to one page, in plain language the pastor can act on.
4. Do **not** invent facts about real products or statistics.

Constraints:

- No real passwords of any real account â€" use placeholders like `[strong-passphrase]`.
- Do not recommend sharing passwords over WhatsApp or writing them publicly.
- Must be honest about limitations (e.g., MFA still needs care against SMS interception).

Time allowance: 15 minutes.

Success criteria:

- Correctly explains the weaknesses of `church2020`.
- Gives a practical, safe sharing method.
- Recommends app-based MFA with a reason.
- Includes recovery protection.
- Readable by a non-expert; no real data.

Hints available if stuck:

- Hint 1: Start with the four failure modes: guessing, weak patterns, reuse, breach.
- Hint 2: For sharing, a **single vault entry** in a password manager is safer than a poster on the wall â€" and each trusted user has their own manager access only if the manager supports it.
- Hint 3: Recovery codes belong offline, away from the account.

Instructor answer key / model (do not show learners until after):

> ***Password & Account Safety Plan â€" [Church Name]***
>
> ***Why `church2020` is unsafe:*** *It uses the word "church" plus a year â€" both easy for a computer to guess. It is shared by many people, so it cannot be truly secret, and it may be reused on other accounts, meaning one breach could open everything.*
>
> ***The plan:***
>
> 1. ***Change to a strong unique passphrase****, e.g. a set of random words the pastor chooses and no one can guess. Store it in a free password manager, not on a wall or in a WhatsApp message.*
> 2. ***Turn on MFA (authenticator app, not SMS).*** *App codes are not tied to a phone number, so SIM-swap fraud cannot steal them. Even if someone learns the passphrase, they cannot log in without the phone's code.*
> 3. ***The laptop:*** *set a lock screen and a short auto-lock time. On a shared PC, never let the browser "remember" the password. Each user logs out after use.*
> 4. ***Recovery:*** *set a recovery email and phone you control, and save the recovery codes offline. Protect the recovery path as carefully as the password.*
>
> *Remember: Stop â€" Think â€" Verify.*

Marking guidance (out of 10):

- Correct critique of `church2020` (2)
- Safe sharing method (2)
- App-based MFA with reason (2)
- Laptop/shared-device advice (2)
- Recovery protection (1)
- Plain language, no real data, honest limits (1)

J. REAL-WORLD CASE STUDY

Situation. *(A realistic, non-identifying account typical of small-business password problems. Names and details are illustrative.)*

A small boutique in Port Harcourt ran its online sales through a Facebook page, an Instagram account and a Gmail address. To make life easy, the two owners and one staff member all used the **same password** â€" the shop's name plus the year â€" across all three accounts. One weekend, an old shopping site the staff member had used years ago was breached and its password list leaked.

Relevant facts.

- The leaked password matched the shop's account password exactly.
- Attackers used it to log into the Gmail and then reset the Instagram and Facebook passwords.
- Because MFA was **not** enabled, the stolen password was enough.

Decision point. After the theft, what should the owner do first â€" and what should have prevented it?

Possible approaches.

1. **Pay the attacker** who now demanded money to return the accounts.
2. **Do nothing** and create new accounts, losing followers and history.
3. **Recover and secure:** use the provider's account recovery, change passwords to unique strong ones, enable app-based MFA, remove unknown sessions, and warn customers.

Recommended solution. Approach 3, plus the **prevention** that should have been in place from day one: unique passwords per account, stored in a password manager, with app-based MFA. Paying an attacker (Approach 1) funds crime and rarely returns the account; abandoning the accounts (Approach 2) loses the business's audience and trust.

Trade-offs.

- Approach 1: fast hope, but no guarantee, and it rewards crime â€" never recommended.
- Approach 2: safe from this attacker but costly to the business; recovery is almost always better.
- Approach 3: takes effort in the moment, but restores control and prevents a repeat.

Professional connection. This is a textbook **credential-stuffing** incident caused by **password reuse**. Real support and security staff see it constantly, and the fix is exactly what learners practised today: unique passwords, a manager, and MFA.

K. COMMON MISTAKES AND TROUBLESHOOTING

Use this table as the session's live troubleshooting guide.

K.1 "My password has a symbol and a capital, so it is strong"

Symptoms: Learner keeps a short password with a capital and `!`. **Likely cause:** Believing complexity beats length. **How to investigate:** Compare a 7-character mixed-case password with a 16-character passphrase using a strength checker. **Safe corrective steps:** Explain length is the main driver; help them build a longer passphrase. **How to confirm resolved:** Learner explains why length matters and produces a long passphrase. **How to prevent recurrence:** Repeat "length wins" every time passwords come up.

K.2 Learner still reuses one password across accounts

Symptoms: Learner says "it is easier to remember one." **Likely cause:** Convenience; not yet using a manager. **How to investigate:** Ask how many accounts would fall if that one site were breached. **Safe corrective steps:** Show the password manager storing unique passwords so memory is not the problem. **How to confirm resolved:** Learner stores at least two unique passwords in the manager. **How to prevent recurrence:** Assign the manager setup as homework.

K.3 MFA prompt arrives unexpectedly

Symptoms: Learner's phone asks "Approve sign-in?" when they did not try to log in. **Likely cause:** Someone has the password and is trying to log in â€" an MFA "fatigue" attack. **How to investigate:** Do **not** approve. Ask: "Did you start this login?" **Safe corrective steps: Deny** the request, immediately change the password, review active sessions/devices, and keep MFA on. **How to confirm resolved:** Password changed; unknown sessions removed; no more prompts. **How to prevent recurrence:** Never approve an unexpected prompt; use app-based MFA and a unique password.

K.4 Locked out after enabling MFA (lost or changed phone)

Symptoms: Learner cannot log in because the authenticator is on a device they no longer have. **Likely cause:** Recovery codes were not saved. **How to investigate:** Look for the recovery-codes screen or account recovery flow. **Safe corrective steps:** Use saved recovery codes; if none, follow the provider's account recovery; then re-enrol MFA and **save the codes this time**. **How to confirm resolved:** Learner logs in and has new recovery codes stored safely. **How to prevent recurrence:** Always save recovery codes offline at setup.

K.5 Fear of using a password manager

Symptoms: Learner distrusts "putting all my passwords in one place." **Likely cause:** Reasonable worry; lack of understanding of encryption. **How to investigate:** Compare the **alternative** (reuse or a plaintext note). **Safe corrective steps:** Explain a reputable manager encrypts the vault; the master passphrase plus MFA protects it. This is safer than reuse. **How to confirm resolved:**

Learner sets up the manager with a strong master passphrase and MFA. **How to prevent recurrence:** Reinforce honest trade-offs â€" a manager is strong, not magic.

Distinguish likely vs confirmed: A learner's "weak password" is a *likely* weakness; it becomes *confirmed* only when checked (e.g., it appears in a breach list, or the strength checker shows it is weak). Teach learners to verify before concluding.

L. SESSION ASSIGNMENT

Assignment title: "My Account Safety Audit"

Purpose: Turn today's lesson into real change across the learner's **own** accounts, safely and honestly.

Realistic scenario: You are auditing your own digital life the way a professional would â€" improving the weakest points first.

Detailed instructions:

1. Choose **three** of your **own** accounts (e.g., Gmail, a social media account, a shopping account). **Do not include your bank's internet-banking password in this assignment.**
2. For each, do a **private** review (do not write the actual passwords):
   - Was the password short, personal, or reused? (Yes/No)
   - Did you change it to a **unique strong passphrase**? (Yes/No)
   - Is **MFA** now on? (Yes/No, or "in progress")
   - Do you have **recovery** set (email/phone and codes saved)? (Yes/No)
3. Install or open a password manager and store at least **two** generated passwords.
4. Write a short reflection (4â€"6 sentences): What was your weakest habit? What did you change? What will you still do?
5. **Never write actual passwords** anywhere in this assignment. Use placeholders and Yes/No answers.

Required deliverables:

- A completed audit table for three accounts (Yes/No format) â€" no real passwords.
- Evidence that a manager is set up (a screenshot of an empty/new vault is fine; **do not** screenshot real passwords).
- A reflection paragraph.

Submission format: Workbook or typed sheet, submitted at the start of Session 3.

Deadline: Before Session 3.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Three accounts reviewed	3	Clear, honest self-review
Weakness analysis	4	Correctly identifies weak/reused/short passwords
Corrective action	4	Real upgrades; MFA considered with reason
Password manager used	4	At least two generated passwords stored
Recovery addressed	2	Recovery email/phone/codes considered
Reflection quality	2	Thoughtful, honest, in own words
Safety and privacy	1	No real passwords or personal data exposed

Common mistakes to avoid: writing real passwords; including banking details; claiming MFA when it is not set; reusing a "new" password that is just the old one plus a symbol.

Instructor reference solution (fictional/model reflection):

> *"My weakest habit was using my name and birth year on almost everything â€" I had three accounts with nearly the same password. I changed all three to different long passphrases and stored them in a password manager. I turned on app-*

based MFA for my Gmail, which was the most important one. I saved my recovery codes in a safe offline place. What I will still do: enable MFA on my other two accounts and stop using my name in any password."

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key.)

Q1. Short answer. Why is a **long passphrase** usually stronger than a short password with symbols?

Q2. Multiple choice. Which is the safest way to handle passwords for many accounts? a) Use one strong password everywhere b) Write them all in a clearly labelled notebook you carry c) Use a password manager with a strong master passphrase and MFA d) Add a `1` to the end of the same password each time

Q3. Explain in your own words. What is a data breach, and what should you do if your email appears in one?

Q4. Practical identification. Your phone shows "Approve sign-in?" for an account you did not try to log into. What does this suggest, and what should you do?

Q5. Short answer. Give one reason an **authenticator app** is stronger than an **SMS code**.

Q6. Scenario. A friend says, "I use `Blessing2015` for everything because it is easy to remember and has a year in it." Give two specific reasons this is unsafe and one concrete improvement.

INSTRUCTOR ANSWER KEY (Q1â€"Q6)

A1. Because strength grows with the number of possible combinations, and length adds far more combinations than a couple of symbols do. A long passphrase is both hard for a computer to guess and easy for a human to remember. (Accept any answer emphasising length and uniqueness.)

A2. (c).

A3. A data breach is when a company's stored data â€" including user emails and passwords â€" is stolen or leaked. If your email appears, change that password on the affected site and anywhere you reused it, and enable MFA. It does not necessarily mean you are hacked now.

A4. It suggests someone may already have your password and is trying to log in (an MFA push/fatigue attack). Do **not** approve. **Deny** the request, immediately change your password, review active sessions/devices, and keep MFA on.

A5. An authenticator app generates codes on your own device and is not tied to your phone number, so it is not vulnerable to SIM-swap fraud or SMS interception. (Accept any one correct reason.)

A6. Reasons: (1) It has a name and a year â€" both easy for a computer to guess; (2) using it for everything means one breach exposes all accounts (reuse). Improvement: create a long unique passphrase per account and store them in a password manager with MFA enabled. (Accept any two reasons plus a concrete improvement.)

N. REFLECTION AND RECAP

Plain-English summary. Today you learned why passwords fail â€" guessing, weak patterns, reuse and breaches â€" and that **length and uniqueness** are what make a password strong. You built a stronger passphrase, learned how password reuse creates a domino effect, and checked your **own** email on a breach-checking service. You learned what multi-factor authentication is and why an **authenticator app** beats SMS. You set up (or recorded the steps for) MFA on your own account, stored generated passwords in a free password manager (Bitwarden), and learned to protect your account recovery path.

Five important takeaways:

1. Passwords fail by guessing, weak patterns, reuse and breaches.
2. **Length wins** â€" a long, unique passphrase beats a short clever password.
3. **Never reuse** an important password; a breach on one site must not open the others.
4. **MFA** is the biggest single upgrade; prefer **app-based** MFA over SMS.
5. A **password manager** plus a strong master passphrase makes good security practical â€" and protect your **recovery** codes.

Questions to help you recognise what you can now do:

- Can I build a strong passphrase without using my name or birthday?
- Can I explain why reusing a password is dangerous?
- Can I check my own email on a breach checker and interpret the result?
- Can I enable MFA on my own account, and do I know where my recovery codes are?

Connection to the next session: Your accounts are now much stronger. But most attacks do not happen at your keyboard â€" they arrive as a **link**. Next session we learn to look at a web address and tell within seconds whether it is safe to click, what the padlock really means, and how to download software without letting in malware.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- Learner builds a passphrase that is long and genuinely free of personal information, and can justify it.
- Learner can explain reuse as a "domino/one-key" risk.
- Learner interprets a breach result correctly (warning, not a diagnosis) and knows the next action.
- Learner enables MFA and knows why app beats SMS.
- Learner stores generated passwords in the manager and knows the master passphrase is the key.
- Learner handles recovery codes sensibly.

Common misconceptions to watch for and correct:

- "Symbols alone make it strong." â†' Length and uniqueness matter most.
- "Adding `1` at the end makes it a new password." â†' Not unique meaningfully; use a manager.
- "If my email shows in a breach, I am hacked." â†' It is a warning; change and enable MFA.
- "MFA means I can keep a weak password." â†' MFA is a *second* layer, not a replacement.
- "Password managers are unsafe." â†' Reputable managers encrypt the vault; they are safer than reuse.

Suggested remedial exercises for learners who struggle:

1. **Length drill:** give five passwords and ask the learner to rank them by likely strength, then explain each.
2. **Reuse map:** have the learner list which accounts share a password and mark the "dominoes."
3. **MFA walkthrough:** step-by-step, on a non-critical account, with the learner doing each click themselves.

Differentiation:

- **Level 1 (supported):** provide a fill-in-the-blank passphrase builder (choose from a word list; add a number) and a printed MFA click-path.
- **Level 2 (standard):** the exercise as written.
- **Level 3 (challenge):** ask the learner to design a family password policy for a household of five devices â€" shared vs personal accounts, MFA everywhere, recovery, and how to onboard a new member safely.

Timing guidance: The MFA setup can overrun for learners without phones or with slow internet. Protect the **guided practical Part 1 (passphrase) and Part 3 (MFA steps)**; the breach check and Bitwarden can be finished at home. If the room is fast, extend the case study and let learners present their plans.

END OF SESSION 2

Next: Session 3 â€" Safe Browsing, Downloads and Recognising Scams.

SESSION 03 OF 9

Safe Browsing

CONCEPT DIAGRAM — SESSION 03



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 3 â€" SAFE BROWSING, DOWNLOADS AND RECOGNISING SCAMS

A. SESSION IDENTIFICATION

Item	Detail
Session number	3 of 9
Session title	Safe Browsing, Downloads and Recognising Scams
Week / Module	Week 1 â€" Module 1: Hygiene (Stopâ€"Thinkâ€"Verify)
Recommended duration	105 minutes
Difficulty level	Beginner
Prerequisite knowledge	Session 1 (threats, Stopâ€"Thinkâ€"Verify) and Session 2 (passwords, MFA, password managers). Basic browsing: opening Chrome, typing a web address, using search.

Item	Detail
Connection to previous work	Your accounts are now well protected. But most attacks arrive as a **link**, a **download** or a **scary pop-up**. Today you learn to look at a web address, a download source and a warning, and judge whether they are safe â€” protecting yourself even when the site is trying to trick you.
Preparation before class	Academy PCs on and logged in; Chrome open; internet available. Prepare the **fictional URL cards** (Section G/H) and the **Verdict Sheet** (printed per learner). Have the **fictional demo website** ready (a simple local HTML page is ideal, so no real site is visited). Test the projector. **Read the ethics reminder:** all links and samples are fictional or official/benign; never open a real suspicious link.

Instructor safety note: This session analyses web addresses. We will **never** click a suspicious or unknown link to "see what happens." We inspect, compare and reason â€” using printed cards, a local demo page, or clearly safe official sites only.

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Explain** what HTTPS/TLS does â€” it encrypts the connection between the browser and the website â€” and correctly state what the padlock does **and does not** mean.
2. **Inspect a web address (URL)** and identify the domain, the subdomain and the path, and spot suspicious elements (misspellings, extra words, unusual endings, numbers).
3. **Recognise** suspicious links, shortened URLs and urgency tricks, and decide whether a link is safe to click.
4. **Choose safe download sources**, avoid cracked/warez software, and check file types before opening.
5. **Perform basic browser safety habits:** keep the browser updated, manage extensions, and handle pop-up scareware without clicking.
6. **Explain** the risks of QR codes and public Wi-Fi, and outline safe behaviour for each.
7. **Verify a website** before entering personal or payment details.
8. **Correctly classify** at least 4 of 5 example web addresses as safe or unsafe, with a reason.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops). A shared computer is acceptable; pair learners so one reads the address and one writes the verdict, then swap.
- Instructor computer connected to a projector.
- A phone (optional) for the QR code demonstration.

Software

- Google Chrome (any recent version).
- A locally hosted **fictional demo website** (a simple HTML file the instructor creates â€” no real URL needed). Optional: the instructor may show the certificate viewer on a clearly safe, official site (e.g., the academy's own page) only.

Accounts

- None required. No logins today.

Sample files

- **Fictional URL Cards** â€” at least 10 example addresses, including safe and unsafe ones, all fictional (`...example` domains are fine, or clearly fake brand names). Printed or projected.
- **Verdict Sheet** â€” a one-page table: URL | Safe / Unsafe | Reason | Safe action.
- **Worksheet 3.1 â€” "Read the Address"** (identify domain and red flags).
- A slide explaining HTTPS versus HTTP in plain language.

Tools

- Chrome's address bar and the padlock/certificate viewer (used only on safe official sites).
- Chrome's extension manager (for demonstration).
- A QR code generator (instructor only) to show how a QR code can hide a URL.

Internet

- Helpful but not strictly required. All core analysis uses printed cards and a local demo page. If internet is available, the instructor may show **only clearly safe official sites**.

Alternative for learners who lack a facility

- Any device with a browser works. Phone-only learners can analyse the printed cards and join the verdict discussion.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: Put two web addresses on the screen, side by side:

> `https://www.mybank.com.ng` *(fictional example â€" the real bank's own address)*
>
> `https://mybank-secure-login.example.ng`

What the instructor says:

> *"Which of these two is your real bank? â€¦ Look closely. The second one has the word 'mybank' in it â€" but it also has 'secure-login', and the ending is* `.example.ng` *, not the bank's real name. Scammers use addresses that contain a trusted name to make you feel safe.*
>
> *And here is the shock for many people: both might show a* ***padlock****. The padlock does* ***not*** *mean the site is honest. It only means the connection is scrambled. A robber can have a padlock on his own door too.*
>
> *Today you will learn to read a web address like a professional â€" where the real name lives in the address, and where the fakes hide."*

Expected learner response: Many learners will say "the second looks safer because it says secure." That is exactly the misconception to correct. Others may notice the `.example.ng` . Praise careful eyes.

Then hook with a question: "When a page screams 'Your PC is infected! Click here to clean it!' â€" is that real security software?" Take answers. Most will now guess correctly: no. Say:

> *"By the end of today, you will know in seconds whether a link is worth clicking â€" and you will never fall for a scary pop-up again."*

Why this opener works: It attacks the widely held "padlock = safe" belief head-on, uses a banking context every learner cares about, and promises a skill they can use immediately.

E. PREREQUISITE REVIEW (7 minutes)

Run this as a quick oral round-robin. Put the questions on the projector.

Question 1: "What are the three failure modes of a weak password we said are most dangerous?"

- Expected answer: guessing/weak patterns, reuse, and breaches. (Length and uniqueness are the fix.)
- Common gap: learners focus on symbols. Re-state: length and uniqueness.

Question 2: "What does MFA add, and which is stronger â€" an authenticator app or an SMS code?"

- Expected answer: a second lock; the authenticator app is stronger because it is not tied to your phone number.

- Common gap: thinking SMS is safest. Clarify again.

Question 3: "What are the three words of the security mindset?"

- Expected answer: Stop â€" Think â€" Verify.
- Common gap: rushing. Remind them it applies to every link.

Question 4: "If a message tells you to click quickly 'or your account closes in 10 minutes,' what two things is it doing?"

- Expected answer: creating urgency and trying to stop you thinking/verifying â€" a scam pattern.
- Common gap: learners assume it must be real if it sounds official. Reinforce verification.

Bridge to today (say this):

> *"So far we have taught you to protect your accounts. Today we protect the journey â€" the link you click. In Session 1 you learned the trick. In Session 2 you locked the door. Today you learn to read the roadsigns so you never walk into the trap at all."*

If more than a third cannot answer Question 1, spend 3 extra minutes reviewing the S2 recap.

F. FULL LECTURE NOTES

F.1 How the web works â€" a simple picture

The idea. When you type an address and press Enter, your **browser** (Chrome) talks to a **web server** â€" a computer somewhere that holds the website â€" and asks it to send the page. The page travels back and appears on your screen.

Plain-English definition. The **internet** is a network of computers that can send information to each other. A **web server** is a computer that stores and delivers websites. Your **browser** is the program that requests and displays them.

Real-life comparison. Think of ordering food. You (the browser) call a restaurant (the server), place an order, and the food (the web page) is delivered to you. The address you type is like the restaurant's phone number â€" if it is wrong, you reach the wrong place or nobody.

Why this matters for safety. Because your browser is asking a stranger's computer for information, you must be careful *which* stranger you are talking to. That is what the address and HTTPS are about.

F.2 Web addresses (URLs) â€" reading the roadsign

The idea. A **URL** (Uniform Resource Locator) is the address of a page on the web. Learning to read it is the single most useful safe-browsing skill.

Plain-English definition. A URL has parts; the most important part is the **domain** â€" the actual name of the site.

Take this address apart:

```
https://shop.example.com.ng/login/page
  â”,        â”,        â”,    â”,   â”,
  â”,        â”,        â”,    â”,   â”""â”€â”€ path (the specific page)
  â”,        â”,        â”,    â”""â”€â”€â”€â”€â”€ top-level domain (country: .ng)
  â”,        â”,        â”""â”€â”€â”€â”€â”€â”€â”€â”€â”€ top-level domain (type: .com)
  â”,        â”""â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€ domain name (the ACTUAL site)
  â""â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€â”€ protocol (https = encrypted)
```

The key rule: the **real name of the site is the part just before the final domain ending** â€" here, `example`. Everything to the left (like `shop.`) is a **subdomain** chosen by the site owner, and attackers can put *anything* there.

Why scammers exploit this. An attacker can create a subdomain that looks trustworthy: `mybank.login-secure.example.com` â€" the domain is `example.com`, **not** the bank. People read from left to right and trust the first trusted-looking word. Train yourself to read the **domain**, not the decorations.

Red flags in an address:

- **Misspellings:** `faceb00k`, `gooogle`, `mybank.ng-secure.example`.

- **Trusted name in the wrong place:** `bank-verify.example.net` (the real name should be the domain, not a word in the path or subdomain).
- **Extra words of pressure:** `secure`, `login`, `verify`, `update`, `urgent`.
- **Strange endings:** a `.ng` business reached at a `.xyz` or random address.
- **Long numbers or random characters:** `pay-secure12345.example`.
- **Shortened links:** like `bit.example/3xY7` â€" you cannot see where they lead.

Real-life comparison. A URL is like a street address on an envelope. The **domain** is the actual building; the subdomain and path are rooms inside. A scammer may rent a room in a building with a similar name, hoping you deliver the parcel (your password) to the wrong address.

Misconception to correct: "If the word 'bank' appears in the link, it is the bank." No â€" the word can appear anywhere. Only the **domain** (just before the final ending) is the real site.

F.3 HTTPS, the padlock and what it really means

The idea. HTTPS is the secure version of the web protocol. It **encrypts** the traffic between your browser and the website so others on the network cannot easily read it.

Plain-English definition.

- **HTTP** â€" the connection is **not** encrypted; information travels in the open.
- **HTTPS** â€" the connection **is** encrypted. The "S" stands for **Secure**.
- **TLS** (Transport Layer Security) is the technology that does the encrypting behind the scenes. When people say "HTTPS/TLS," they mean this encryption.
- The **padlock** in the address bar is Chrome telling you: "This connection is encrypted."

Why it exists. On a public network (a cafÃ©, a hotel), someone could otherwise "listen in" and read your data as it travels. Encryption scrambles it so that even if they capture it, they cannot easily read it.

What HTTPS protects: the **journey** of your data â€" it stops eavesdroppers on the network from reading your password or card details in transit.

What HTTPS does NOT do (this is the crucial lesson):

- It does **not** prove the site is **honest**. A scam website can also get a padlock.
- It does **not** mean the site is the **official** one. Look-alike scam sites use HTTPS too.
- It does **not** protect you from a **fake download** or a virus you install yourself.
- It does **not** mean your device is safe.

Real-life comparison. HTTPS is like a **sealed, tinted envelope**. The postman cannot read your letter, so it is private in transit. But if you wrote to the wrong address (a scammer) on purpose, the sealed envelope still reaches the wrong person. **Encryption protects the journey, not the destination.**

Say this to the class, slowly:

> *"A padlock means 'the road is private.' It does **not** mean 'the shop is honest.' Check the **domain** first; the padlock is only the second question."*

Misconception to correct: "I only enter details on sites with a padlock, so I am safe." Better rule: *check the domain is exactly right, then confirm HTTPS, then think before typing.*

F.4 Spotting unsafe links and scams

The idea. A link can look innocent but lead somewhere dangerous. Learn the patterns.

Common unsafe-link patterns:

Pattern	What it looks like	Why it is risky
Look-alike domain	`gtbank-secure.example`	Uses a trusted name in the wrong place

Pattern	What it looks like	Why it is risky
Misspelling	`amaz0n.example` , `whatapp.example`	Tiny change to fool a quick glance
Shortened URL	`bit.example/abc123`	Hides the real destination
Urgency link	"Your account closes in 1 hour â€" click now"	Pressure to skip thinking
Unexpected link	A "delivery" link when you ordered nothing	Bait for a fake login page
Wrong context	A bank link in a WhatsApp group	Banks do not ask through groups

The safe-reading habit (Stopâ€"Thinkâ€"Verify for links):

1. **STOP** â€" do not click from a message. Never trust the link text; it can say "bank.com" but point anywhere.
2. **THINK** â€" "Was I expecting this? Does the domain match the real company exactly?"
3. **VERIFY** â€" type the company's known address yourself, or use the official app. Never rely on the link.

Real-life comparison. A link is like a signpost someone planted in your yard reading "This way to the bank." Anyone can plant a sign. You would rather walk to the bank you know than follow a sign a stranger left.

Misconception to correct: "The link text shows the bank's name, so it is safe." Link text is just a label. The *real* destination is hidden in the code. Never judge a link by its label.

F.5 Safe downloading â€" the software trap

The idea. Many infections happen because the user **installs** something unsafe. Safe downloading prevents this.

Plain-English definition. Downloading means copying a file from the internet to your computer. If the file is harmful, installing it can infect your whole device.

Rules for safe downloading:

1. **Use official sources.** Download from the official website, the official app store, or a trusted, well-known distributor.
2. **Avoid cracked or "warez" software.** "Free" cracked paid software, key generators and "activators" are a favourite hiding place for malware. If something expensive is offered free and illegally, ask yourself what the price really is.
3. **Check the file type.** Be cautious with `.exe` , `.msi` , `.scr` , `.bat` (Windows programs and scripts) and Office files with **macros** (`.docm` , `.xlsm`). A "video" that is secretly an `.exe` is a classic trick.
4. **Beware bundled extras.** Some installers sneak in unwanted toolbars or adware; read each screen and untick extra offers.
5. **Verify the address** before downloading â€" the same domain-reading skill from F.2.
6. **Let Defender scan it.** Keep Microsoft Defender on (next week's topic) and scan downloaded files from untrusted sources before opening.

Real-life comparison. Downloading from a random site is like buying medicine from a stranger in traffic instead of a proper pharmacy. It might be genuine â€" but if it is not, the harm is serious. Buy from the pharmacy you trust.

Misconception to correct: "If my antivirus is on, I can download anything." Not true. New malware can slip past, and you can be tricked into allowing it. Antivirus is a seatbelt, not permission to drive recklessly.

F.6 Browser safety basics

The idea. Your browser is your gateway to the internet; keep it safe and clean.

Safe browser habits:

- **Keep Chrome updated.** Updates fix known security holes. If Chrome asks to relaunch to update, let it.
- **Install only trusted extensions.** Extensions can read what you do. Fewer is safer. Remove ones you no longer use, and never add an extension from a pop-up or a random site.
- **Handle pop-ups and scareware correctly.** A website cannot truly scan your computer, and real antivirus does not lock your whole screen with a loud alarm and a phone number. That is **scareware** â€" a fake alert. **Close the tab** (or the browser) and, if worried, run a real scan with Windows Defender.
- **Do not save passwords in a shared browser.** On a shared PC, never let Chrome "remember" your password; use your password manager instead (from Session 2).

- **Use a browser profile/PIN** on shared computers so your history is not exposed.

Real-life comparison. Your browser is like your car. Keep it serviced (updates), do not fill it with junk gadgets (extensions), and do not believe every warning light a stranger installs on your dashboard.

Misconception to correct: "A pop-up told me I have a virus, so I must act now." Web pages **cannot** scan your PC. The warning is the attack. Close it.

F.7 QR codes and public Wi-Fi

QR code risks. A **QR code** is a square barcode you scan with a phone camera to open a link. Because you cannot read the address before scanning, a malicious QR code (a "quishing" trap) can send you to a fake site. QR codes on stickers in public places (parking meters, posters, restaurant tables) can be stuck over the real one.

- **Safe habit:** After scanning, **read the address that appears before tapping "Open."** If it looks wrong, do not proceed. Use the official app instead.

Public Wi-Fi caution. Public Wi-Fi (cafÃ©, hotel, airport, market hotspot) is convenient but shared.

- Prefer **HTTPS** sites (still check the domain) so your traffic is encrypted.
- **Avoid sensitive logins** (banking) on public Wi-Fi when possible; use your mobile data for that.
- **Beware fake hotspots** with names like "FreeWiFi" that are set up to capture data.
- Turn off **file sharing** and "automatic connect to open networks" on your device.
- Consider a **mobile hotspot** from your own phone for anything important.

Real-life comparison. Public Wi-Fi is a crowded market: convenient, but everyone can see and bump into you. Keep your valuables (bank logins) close, not out in the open.

Misconception to correct: "HTTPS makes public Wi-Fi completely safe." It encrypts your traffic to that site, but a fake hotspot or a malicious site can still trick you. Prefer mobile data for sensitive tasks.

F.8 Summary of the lecture

- The **internet** connects your browser to **web servers**; the **URL** is the address, and the **domain** is the real name of the site.
- **HTTPS/TLS** encrypts the connection; the **padlock** means "encrypted," **not** "honest."
- Read the **domain**; watch for misspellings, trusted names in wrong places, urgency and shortened links.
- Download from **official sources**; avoid cracked software; check file types.
- Keep the browser **updated**, manage **extensions**, and **never trust scareware pop-ups**.
- Read a QR code's address before opening; be cautious on **public Wi-Fi**.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

Goal: Teach the class to read addresses and judge links, using **fictional URL cards** and a **local demo page**. No real suspicious sites are visited.

Setup: The 10 fictional URL cards projected one at a time. A local `demo.html` page (created by the instructor) that mimics a login page, opened from the Desktop â€” this shows what a fake login page looks like without touching a real site. Chrome open.

G.1 Demonstration 1 â€” Reading the domain (6 minutes)

Say: "We are going to read addresses like a detective. Remember: find the **domain** first."

Show these cards one by one and think aloud (all fictional):

#	URL	Verdict	Reasoning
1	`https://www.example-bank.example.ng/login`	**Unsafe**	Domain is `example-bank.example.ng` â€” not the real bank; "bank" is used as bait

#	URL	Verdict	Reasoning
2	`https://www.cea.example/about`	**Safe (fictional demo)**	Domain is clearly the academy's demo; page is informational
3	`https://faceb00k.example.com`	**Unsafe**	`faceb00k` with zeros â€” a look-alike of a well-known name
4	`https://bit.example/3xY7Q`	**Unsafe (unknown)**	Shortened link hides the destination
5	`https://mail.example.com.verify-login.example.net`	**Unsafe**	The real domain is `example.net`, not the mail service; trusted name is only a subdomain decoration

Point at the projector: "Which part is the domain? Circle it with your eyes. Everything else is decoration."

G.2 Demonstration 2 â€” The padlock and the certificate (4 minutes)

1. Open the **local demo page** (or a clearly safe official informational page) in Chrome.
2. Point to the **padlock**; click it; show the site information panel.
3. **Say:** "Notice the padlock â€” it says the connection is encrypted. Now, if I opened a *scam* site with a padlock, it would also show one. So the padlock answers a small question: 'Is the road private?' It does not answer: 'Is this shop honest?'"
4. Show the certificate detail (Issued to / Issued by) and say: "This shows who is behind the encryption. But a scammer can register a certificate too. Certificate plus right domain â€” that is what to check, along with your own common sense."

Do not visit any questionable site to demonstrate.

G.3 Demonstration 3 â€” A fake login page and scareware (5 minutes)

1. Open the **local** `demo.html` which looks like a fake "Bank Secure Login" page. **Say:** "This looks real, but it is a file on my Desktop. A scam page can look exactly like this. The way to be safe is to *never arrive here from a link in a message* â€” always use the official app or type the address yourself."
2. Show a **fictional scareware image** (a screenshot prepared in advance â€” do not load a live scareware site): "WARNING! 5 viruses found! Call now!" **Say:** "Real security software does not scream in your browser and ask you to call a number. This is the attack. Close the tab."
3. Demonstrate the safe action: close the tab; show how to **clear a stuck pop-up** (close tab, or end the browser task); remind them to run a real **Windows Defender** scan afterwards if worried.

Questions to ask during the demo:

- "Which part of this URL is the domain?"
- "Does the padlock prove the site is honest?" (No.)
- "What is the safe action for a scary pop-up?" (Close it; do not call or click; scan with Defender.)

Expected result: Learners begin pointing out the domain and rejecting look-alikes on their own by card 3 or 4.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: With the instructor guiding, each learner completes a **Verdict Sheet** for 10 fictional URLs and 2 fictional scenario messages, deciding Safe/Unsafe and giving a reason and a safe action.

Starting materials: Printed Verdict Sheet; the 10 URL cards; a sample login page screenshot (fictional). Pen. No browsing of unknown sites.

Procedure (instructor calls out each step; learners work; instructor walks the room):

1. Write your name at the top. Today's rule: **we do not click any unknown link â€” we read it.**
2. For each URL card, do four things: a. **Underline the domain** (the part just before the final ending). b. Write **Safe** or **Unsafe**. c. Write a **reason** (misspelling? trusted name in the wrong place? shortened? unexpected?). d. Write the **safe action** (type the official address; ignore/delete; verify via app).

3. **Pause and predict** after card 2: "If I clicked the unsafe one, what would happen?" (It could take you to a fake login page that steals your password.)
4. Do the same for the two scenario messages (fictional): one fake delivery SMS with a link, one WhatsApp "bank alert" with a link.
5. Compare with a partner. Disagree? Explain your reason, do not just change your answer.

Expected result (instructor key â€" full model):

#	URL (fictional)	Verdict	Reason	Safe action
1	`https://example-bank.example.ng/login`	Unsafe	Real bank's domain is not this; "bank" bait	Use official app/known number
2	`https://www.cea.example/about`	Safe	Official academy demo address; informational	Can open
3	`https://faceb00k.example.com`	Unsafe	Look-alike (zeros) of a famous name	Do not click; go via official app
4	`https://bit.example/3xY7Q`	Unsafe	Shortened; destination hidden	Do not click; ask sender via a known channel
5	`https://mail.example.com.verify-login.example.net`	Unsafe	True domain is `example.net`; trusted name is decoration	Do not click
6	`https://www.example-news.example.org`	Safe (fictional demo)	Clear domain; informational; expected	Can read
7	`https://pay-urgent-verify12345.example`	Unsafe	Pressure words + random numbers	Do not click
8	`https://mybank.example.ng`	Safe (if this is genuinely the bank's real domain)	Domain matches exactly; check HTTPS	Use normally, but verify it is truly official
9	`https://gooogle-account.example.net`	Unsafe	Misspelling (`gooogle`)	Do not click
10	`https://shop.example.com.ng/product/123`	Safe (fictional demo)	Clear domain; normal path	Can open

Scenario messages (fictional):

- Fake delivery SMS: "Your parcel is held. Pay â‚¦2,000 here: `bit.example/x9`." â†' Unsafe; not expecting a parcel; shortened link; pressure. Action: delete; track parcels via official sites only.
- WhatsApp "bank alert": "Your account was debited â‚¦50,000. Reverse it: `example-bank.example.ng/reverse`." â†' Unsafe; wrong domain; panic bait. Action: do not click; check the official banking app.

Points to pause on and predict:

- After card 5: "Which part is the real website?" â†' `example.net`.
- After the delivery SMS: "Even if the link says a courier name, what do we check?" â†' The domain, not the label.

Troubleshooting while walking the room:

- Learner marks a look-alike "Safe" â†' Ask them to underline the domain and sound it out slowly.
- Learner wants to click to check â†' **Stop.** Remind: we never click unknown links; we read them.
- Learner confuses "Safe (fictional demo)" with a real site â†' Clarify these are teaching addresses; the skill is reading them.

Completion checklist (learner ticks each):

- ☐ All 10 URLs assessed
- ☐ Domain underlined for each
- ☐ A reason given for each verdict
- ☐ A safe action for each

- [ ] Both scenario messages assessed
- [ ] No unknown link clicked

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: You are building a **"Click Safety Poster"** for a cyber cafÃ© in Port Harcourt. It must teach customers how to judge a link in five seconds, using a simple method a non-expert can remember.

Scenario: The cafÃ© owner keeps losing customers to fake pop-ups and bogus links. She asks you for one poster she can stick near every computer.

Requirements:

1. Create a memorable **method with a short name** (you may use "Domain First" or invent your own) that tells a customer the order of checks:
   - Look at the **domain** (the real name).
   - Check for **misspellings and extra words** of pressure.
   - Check the **padlock** â€" and remember it does **not** prove honesty.
   - **Do not** click links from messages; type the official address or use the app.
2. Include **two example addresses** (fictional) â€" one safe, one unsafe â€" and label them.
3. Add one line on **scareware pop-ups**: what to do (close the tab; run a real scan).
4. Add one line on **downloads**: official sources only; no cracked software.
5. Keep it to one page, bold and simple, readable at a glance.

Constraints:

- Use only **fictional** example addresses.
- No real websites, no real phone numbers.
- Plain English; a first-time customer must understand it in seconds.

Time allowance: 15 minutes.

Success criteria:

- A clear, memorable method in a logical order.
- Correctly labelled safe and unsafe fictional examples.
- Correct advice on padlock, pop-ups and downloads.
- Readable at a glance; no real data.

Hints available if stuck:

- Hint 1: The order is: **Domain â†' Misspelling/pressure â†' Padlock â†' Verify (don't click from messages).**
- Hint 2: For the unsafe example, use a look-alike: `mybank-verify.example`.
- Hint 3: Use big words and arrows, like a road sign.

Instructor answer key / model (do not show learners until after):

> ***FIVE-SECOND LINK CHECK*** *(by [Your Name])*
>
> 1. ***DOMAIN FIRST.*** *The real site name is just before the final ending.* `mybank.com.ng` *is the bank.* `mybank-verify.example` *is NOT.*
> 2. ***SPOT THE TRICKS.*** *Misspellings (* `gooogle` *), extra pressure words (* `secure` *,* `urgent` *,* `verify` *), and shortened links hide the truth.*
> 3. ***PADLOCK = PRIVATE ROAD, NOT HONEST SHOP.*** *The padlock only means the connection is scrambled. Check the domain first.*
> 4. ***NEVER CLICK FROM A MESSAGE.*** *Type the official address or open the official app. Delete the link.*
> 5. ***SCARY POP-UP? CLOSE THE TAB.*** *A website cannot scan your PC. Run a real scan with Windows Defender if worried.*
> 6. ***DOWNLOADS:*** *official sites only. No cracked software. Check the file type.*

Safe examples: `https://www.mybank.com.ng` *(safe if this is the real bank domain) Â· Unsafe:* `https://mybank-verify.example` *(look-alike).***

Stop â€" Think â€" Verify.

Marking guidance (out of 10):

- Clear method in correct order (3)
- Correctly labelled safe/unsafe fictional examples (2)
- Correct padlock explanation (2)
- Correct pop-up and download advice (2)
- Readable, non-expert-friendly, no real data (1)

J. REAL-WORLD CASE STUDY

Situation. *(A realistic, non-identifying account typical of link-based scams. Names and details are illustrative.)*

A small school in Port Harcourt paid suppliers by internet transfer. One morning, the bursar received an email that looked like it came from a trusted building-supplies company, with an invoice PDF and a link: "Download the updated invoice to confirm the new account details." The address in the email read `supplies-school-verify.example`, and the page was a near-perfect copy of the supplier's website.

Relevant facts.

- The email displayed the supplier's real name and logo, but the **domain** was not the supplier's.
- The link led to a page asking for the school's online-banking login "to confirm the transfer."
- The school had never confirmed a supplier's bank details by email before.

Decision point. The bursar had to decide: download and log in to "confirm," or stop and verify.

Possible approaches.

1. **Follow the email** and log in to "confirm the transfer" â€" exactly what the attacker wants.
2. **Ignore the email** completely and lose the chance to pay on time.
3. **Verify through a second channel:** call the supplier on a number the school already had, and never log in through a link in an email.

Recommended solution. Approach 3. The bursar calls the supplier's known number; the supplier says the email is fake. Had the bursar already logged in, the correct steps would be: change the online-banking password immediately, tell the bank, and watch the account for unusual activity.

Trade-offs.

- Approach 1: the fake page captures the login â€" the account could be emptied.
- Approach 2: avoids the scam but may delay a legitimate payment.
- Approach 3: a two-minute phone call resolves everything, confirms the truth, and protects the school's money.

Professional connection. This is a classic **business email compromise**/invoice-fraud attempt and a **phishing** page. The professional defence is exactly what learners practised today: read the **domain**, distrust links from messages, and **verify through a second channel**. Invoices and payment details should always be confirmed by a phone call to a known number.

K. COMMON MISTAKES AND TROUBLESHOOTING

Use this table as the session's live troubleshooting guide.

K.1 "It has a padlock, so it is safe"

Symptoms: Learner trusts any HTTPS site and enters details. **Likely cause:** Confusing encryption (private road) with honesty (trustworthy shop). **How to investigate:** Ask them to point to the **domain** and compare it with the official one. **Safe corrective steps:** Re-teach: check the **domain** first; the padlock only confirms encryption. Scams use HTTPS too. **How to confirm**

resolved: Learner checks the domain before the padlock and can explain the difference. **How to prevent recurrence:** Use "Domain First" every session.

K.2 Reading the address from left to right

Symptoms: Learner trusts `mybank-secure.example` because "mybank" comes first. **Likely cause:** Natural reading direction; not knowing subdomains. **How to investigate:** Ask the learner to underline the **domain** (before the final ending). **Safe corrective steps:** Practise with several fictional addresses until the domain is found instantly. **How to confirm resolved:** Learner circles the correct domain on 5 addresses. **How to prevent recurrence:** Repetition with fresh examples.

K.3 Clicking to "check" a suspicious link

Symptoms: Learner says "let me just tap it and see." **Likely cause:** Curiosity; underestimating the risk. **How to investigate:** This is a **stop-and-correct** moment, not an investigation. **Safe corrective steps:** Firmly remind the class: never click unknown links; we read them. Use fictional cards only. **How to confirm resolved:** Learner restates the rule. **How to prevent recurrence:** Re-read the ethics reminder at the start of the session.

K.4 Believing a scareware pop-up

Symptoms: Learner panics at "Your PC is infected!" and wants to call the number. **Likely cause:** Fear; thinking a website can scan the device. **How to investigate:** Ask: "Can a web page actually read all your files?" (No.) **Safe corrective steps:** Close the tab; restart the browser; run a real **Windows Defender** scan if worried. **How to confirm resolved:** Learner calmly closes the pop-up and does not call/click. **How to prevent recurrence:** Repeat "websites cannot scan your PC."

K.5 Downloading from an unofficial source

Symptoms: Learner downloads paid software free from a random site. **Likely cause:** Cost; not knowing the malware risk. **How to investigate:** Check the **source domain** and **file type**. **Safe corrective steps:** Cancel; download from the official site or store; scan with Defender; keep only official copies. **How to confirm resolved:** Learner identifies the official source and explains why. **How to prevent recurrence:** Rule: official sources only; no cracked software.

Distinguish likely vs confirmed: "Unsafe" is a *likely* verdict from reading the address; it becomes *confirmed* only when you verify the domain against the official one (or after a controlled check). Teach learners to **reason and verify**, never to click to confirm.

L. SESSION ASSIGNMENT

Assignment title: "Link Detective â€" 8 Links From My Real Life"

Purpose: Apply the domain-reading skill to the learner's own everyday messages, safely and without clicking anything suspicious.

Realistic scenario: You are now your family's "link detective." Over the next few days, capture (describe) 8 links you encounter â€" from SMS, email, WhatsApp, or websites â€" and judge each one **without clicking the risky ones**.

Detailed instructions:

1. Collect **8** links or addresses you genuinely see (or use the fictional ones if you prefer). **Do not click any you suspect is unsafe.**
2. For each, record in a table:
   - The **address** (write it as text; if it is very long or personal, write only the **domain** â€" never copy a private tracking link).
   - **Underline/circle the domain.**
   - **Safe** or **Unsafe**.
   - **Reason** (misspelling? look-alike? shortened? unexpected? pressure words?).
   - **Safe action**.
3. Add a short paragraph: "Which red flag have I seen most often?" and "How will I explain 'Domain First' to my family?"
4. Do **not** include any real login link, password, or personal banking address. If a link contains your personal data, describe it in words instead.

Required deliverables:

- A table of 8 assessed links (domains only where necessary).
- A reflection paragraph.
- No clicking of unsafe links; no real personal data.

Submission format: Workbook or typed sheet, submitted at the start of Session 4.

Deadline: Before Session 4.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
8 links assessed	4	Clear, varied examples
Domain correctly identified	4	The real domain underlined/circled each time
Correct verdicts	4	Safe/Unsafe correct with sound judgment
Reasons given	4	Specific red flags or reasons, not vague
Safe actions	2	Practical, correct responses
Reflection quality	2	Thoughtful, in own words, safe

Common mistakes to avoid: judging by the link text instead of the domain; clicking a suspicious link; confusing padlock with honesty; including real personal/private links.

Instructor reference solution (two entries as a model):

> 1. `https://bit.example/aB12` *â€" Domain hidden (shortened).* ***Unsafe.*** *Reason: destination hidden; arrived unexpectedly in an SMS. Action: did not click; deleted.*
> 2. `https://www.example-market.example.ng/deals` *â€" Domain* `example-market.example.ng`*.* ***Safe (fictional demo).*** *Reason: clear domain, expected newsletter, normal path. Action: opened normally.*

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key.)

Q1. Short answer. What does HTTPS protect, and what does it **not** prove about a website?

Q2. Multiple choice. In the address `https://secure.login.mybank.example.com/verify`, what is the **real domain**? a) `secure` b) `login.mybank` c) `example.com` d) `mybank`

Q3. Explain in your own words. Why should you never judge a link by the words shown in the message (the link text)?

Q4. Practical identification. Is this safe or unsafe, and why?

> *A WhatsApp message: "Your parcel is held. Pay â¦2,000 here:* `bit.example/x9`*."*

Q5. Short answer. Give two rules for downloading software safely.

Q6. Scenario. A full-screen pop-up says, "WARNING! Your PC has 5 viruses! Call this number now!" What is happening, and what should you do?

INSTRUCTOR ANSWER KEY (Q1â€"Q6)

A1. HTTPS encrypts the connection between your browser and the website, protecting data in transit from eavesdroppers. It does **not** prove the site is honest or official â€" a scam site can also use HTTPS. Always check the **domain** as well.

A2. (c) `example.com`. (The real site name is just before the final ending; `secure` and `login.mybank` are only subdomains.)

A3. Because the visible text is only a label; the actual destination is hidden in the code behind the link. A link can display "mybank.com" but point anywhere. You must read/verify the **real domain** or type the official address yourself.

A4. Unsafe. It is unexpected (you did not order anything), it uses a **shortened link** that hides the destination, and it creates pressure with a payment demand. Safe action: do not click; track parcels only through official sites/apps; delete.

A5. (Any two) Use official sources only; avoid cracked/warez software; check the file type (beware `.exe`, macros); avoid bundled extras; verify the domain; scan with Defender.

A6. It is **scareware** â€" a fake alert. Websites cannot scan your computer, and real security software does not lock your screen and ask you to call a number. Actions: close the tab (or restart the browser); do not call or click; if worried, run a real scan with Windows Defender.

N. REFLECTION AND RECAP

Plain-English summary. Today you learned to read a web address like a professional: find the **domain** (the real site name), and watch for misspellings, trusted names in the wrong place, shortened links and urgency. You learned that **HTTPS/TLS** encrypts the connection and the **padlock** means "private road," not "honest shop." You learned to download only from **official sources** and avoid cracked software, to keep the browser updated and clean, and to recognise **scareware pop-ups** as attacks. Finally, you covered **QR code** risks and safe **public Wi-Fi** behaviour, and you practised classifying fictional links correctly.

Five important takeaways:

1. **Read the domain** â€" the real site name is just before the final ending.
2. The **padlock means encrypted, not honest**; check the domain first.
3. **Never click links from messages**; type the official address or use the app.
4. Download from **official sources only**; no cracked software; check file types.
5. **Scary pop-ups are the attack** â€" close the tab; a website cannot scan your PC.

Questions to help you recognise what you can now do:

- Can I find the domain in any web address?
- Can I explain what a padlock does and does not mean?
- Can I decide if a link is unsafe without clicking it?
- Can I tell a scareware pop-up from a real warning?

Connection to the next session: You can now judge a link. But the most common way links arrive is by **email** â€" and phishing has become very convincing. Next session we open the anatomy of a phishing email, learn the psychology attackers use, and practise the correct response to a suspect email: don't click, don't reply, verify, and report.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- Learner finds the **domain** instantly and ignores left-to-right distractions.
- Learner correctly separates "encrypted (padlock)" from "honest/ official."
- Learner refuses to click an unknown link and instead verifies through an official route.
- Learner recognises scareware and closes it calmly.
- Learner chooses official download sources and can say why.
- Learner checks a QR code's revealed address before opening.

Common misconceptions to watch for and correct:

- "Padlock means safe/honest." â†' It means encrypted only.
- "If the trusted word is in the link, it is the real site." â†' Only the domain is the real name.
- "A website warned me I have a virus, so it is real." â†' Websites cannot scan your PC.
- "Free cracked software is harmless." â†' A common malware hiding place.
- "Public Wi-Fi is safe if I use HTTPS." â†' Prefer mobile data for sensitive logins; watch for fake hotspots.

Suggested remedial exercises for learners who struggle:

1. **Domain hunt:** 10 addresses; the learner underlines only the domain, quickly.
2. **Safe/unsafe sort:** cards with URLs; the learner sorts into two piles and defends each.
3. **Pop-up drill:** show three fictional alerts; the learner states the safe action for each.

Differentiation:

- **Level 1 (supported):** give a domain-highlighted set of cards and a checklisk with the four checks in order.
- **Level 2 (standard):** the exercise as written.
- **Level 3 (challenge):** ask the learner to write a 5-question quiz for a family member on link safety, including the answer key, using only fictional examples.

Timing guidance: The domain-reading practical is the priority; if running late, shorten the QR/public-Wi-Fi discussion to a 2-minute summary and protect the guided practical (Section H). If the room is fast, extend the case study and let learners present their posters.

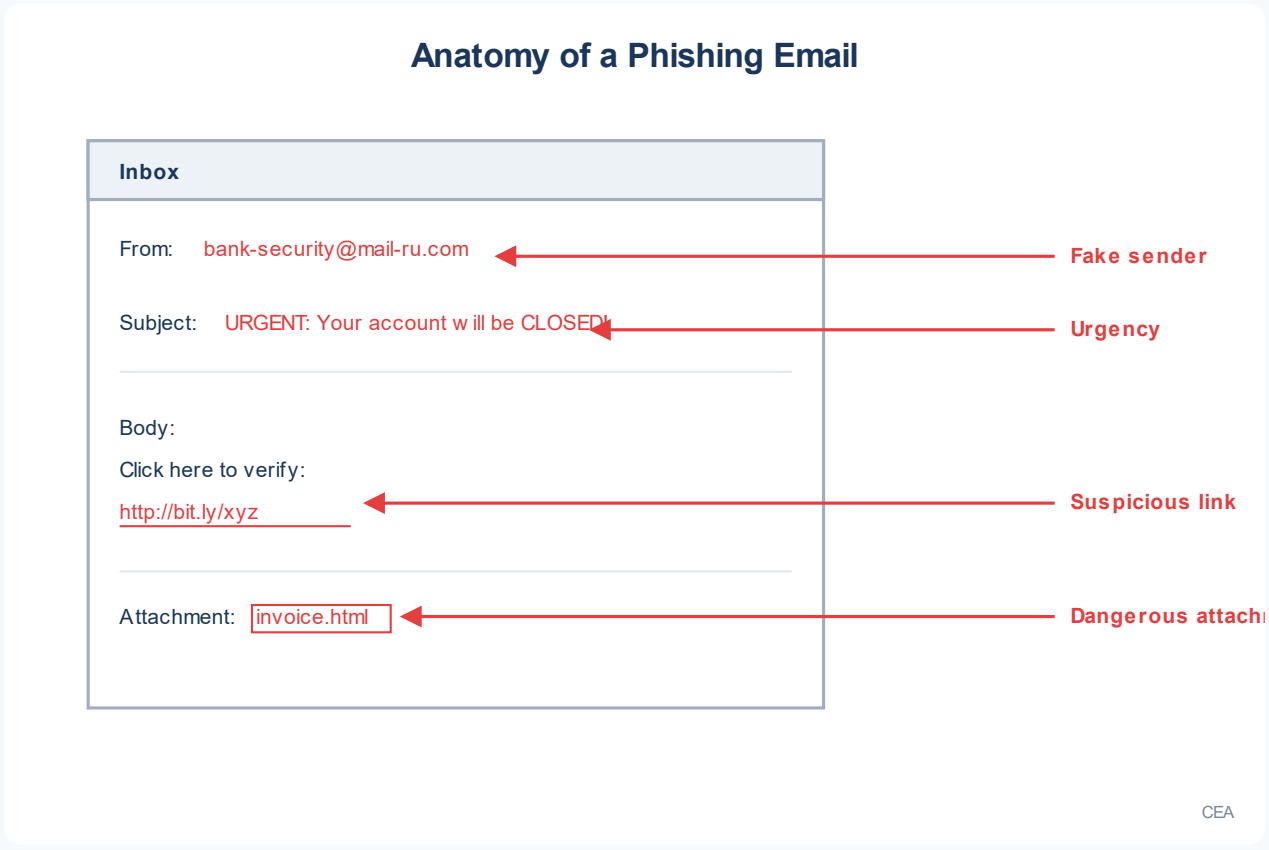
END OF SESSION 3

Next: Session 4 â€" Email Security, Phishing and Social Engineering.

SESSION 04 OF 9

Email Phishing

CONCEPT DIAGRAM — SESSION 04



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 4 â€" EMAIL SECURITY, PHISHING AND SOCIAL ENGINEERING

A. SESSION IDENTIFICATION

Item	Detail
Session number	4 of 9
Session title	Email Security, Phishing and Social Engineering
Week / Module	Week 2 â€" Module 2: Protecting People and Devices (theme: **Harden**)
Recommended duration	105 minutes
Difficulty level	Beginner (no prior security knowledge assumed)
Prerequisite knowledge	Session 1 (threat landscape and Stopâ€"Thinkâ€"Verify mindset), Session 2 (strong passwords and MFA), Session 3 (safe browsing, HTTPS, safe downloads). A learner must

Item	Detail
	be able to open a browser, read an email and find an address.
Connection to previous work	In Session 2 we locked the *front door* (passwords + MFA). In Session 3 we taught careful browsing and downloads. This session covers the attack that most often slips past both: a person being tricked into clicking or replying. Email and social engineering target the *human*, not the machine.
Preparation before class	Academy PCs on and logged in. Instructor email account ready (own account only, or a demo account). Five **fictional** phishing samples prepared (printed or on-screen) â€" see Section C. Projector ready. No real customer data, no real bank emails, and no live suspicious email should ever be opened in class.
Safety note (read aloud at the start)	"Everything today is defensive. We study *fake* and *fictional* examples only. We never open links in real suspicious emails, never reply to a scammer, and never touch anybody's account without written permission. We are learning to *recognise and avoid*, not to attack."

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Describe in simple terms** how an email travels from a sender to a recipient, naming the sender, the visible display name and the destination link as three things an attacker can fake.
2. **Explain** what phishing is and why it works, using the Stopâ€"Thinkâ€"Verify habit from Session 1.
3. **Identify at least six red flags** in a suspicious email, including look-alike domains, urgency, threats, unusual requests, generic greetings, spelling/grammar errors and mismatched link text versus destination.
4. **Demonstrate "hover before you click"** by moving the mouse over a link and reading the real destination without clicking it.
5. **Check the true sender address** rather than trusting the display name, and explain why the two can differ.
6. **Distinguish phishing from spear-phishing and pretexting**, and describe CEO fraud and fake-invoice scams in their own words.
7. **Follow the correct response steps** for a suspicious email: do not click, do not reply, report it, verify by a separate known channel, then delete/report as spam.
8. **Connect email account protection** to the work done in Session 2 â€" a unique strong password plus multi-factor authentication (MFA).
9. **Assess five fictional phishing emails**, correctly marking the red flags and the safe action for each.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops). Pairing is acceptable: one learner reads aloud, the other annotates, then swap.
- Instructor computer connected to a projector or large screen.

Software

- A modern browser (Chrome/Edge/Firefox). A webmail account (Gmail or similar) for the *instructor's own* demonstration only.
- No hacking tools, no "spoofing" tools, no live scam links. Ever.

Accounts

- The instructor may use their **own** email account to show the Report/Spam buttons and where to read full headers. Learners do **not** need to log into personal email for the practical; printed/laptop-viewed fictional samples are sufficient. If a learner wishes to practise in their own inbox, they must use only their **own** account and never open suspicious links.

Sample files (instructor-prepared, fictional)

- **Phishing Sample Pack (5 items)** â€" all invented. Each is a screenshot or a text document that *mimics* an email. No live links. Names used are fictional (e.g., "Zenith-alert.example", "GTBank-secure.example" â€" note the `.example` domain, which is reserved for teaching and cannot be a real attack site). Suggested five:
  1. Fake bank alert claiming "your account will be blocked in 24 hours".
  2. Fake employer HR email asking to "confirm your bank details for salary".
  3. Fake invoice from a "supplier" with an attached "receipt".
  4. Fake delivery/courier "you missed your parcel, pay a small fee".
  5. A look-alike domain email pretending to be a colleague (spear-phishing) with a request to buy gift cards.

Worksheets

- Worksheet 4.1 â€" "Spot the Six Red Flags" (one page, three emails to annotate).
- Worksheet 4.2 â€" "Safe Action Chooser" (learner workbook, Part 3).

Tools

- Browser hover tooltip (built in). Optionally, a printed "header anatomy" diagram prepared by the instructor.

Internet

- Not strictly required. If internet is available, the instructor may *show* the concept of full email headers on their own account, but the session must work fully offline.

Alternative for learners who lack a facility

- Any laptop or phone browser works for viewing the fictional samples. A phone learner can still practise "hover/long-press to preview a link" (on many phones, a long-press shows the destination). Pair them with a desktop learner.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: Put one fictional email on the projector â€" the "bank alert" sample â€" and read it aloud at normal speed, once.

> *"Dear Customer, Your account has been temporarily limited. To restore access, please confirm your details within 24 hours by clicking the link below. Failure to do so will lead to permanent suspension. Click here: [secure-zenith-alert dot example]"*

What the instructor says:

> *"Show of hands â€" who felt a small jump in the chest? Who felt like you should quickly click so your money is safe? … Good. That feeling â€" that small panic â€" is exactly what the attacker is counting on.*
>
> *Look closer at the greeting. It says 'Dear Customer'. Does your real bank call you 'Customer'? No â€" your bank knows your name. Now look at the link. The words say one thing. Where it actually goes is a different thing. Today you will learn to slow down, look at the truth behind the words, and never click in a panic."*

Expected learner response: Learners will likely say things like "the bank will never send that", "the greeting is generic", "there is a link", "they want my details". Some may admit they have received such messages. Accept all. Reinforce that receiving these is normal â€" the skill is recognising them without fear.

Then demonstrate the hook: Hover the mouse over the fake link *without clicking*, and let the browser show the real destination on the projector.

> *"See this? The words say 'Zenith secure'. But the real address is a strange domain ending in `.example`. The text lied; the destination told the truth.* ***Hover before you click.*** *That one habit will save you many times."*

Why this opener works: It creates an emotional "near-miss" moment safely, proving that phishing targets emotion first, and it ends with one concrete, repeatable action (hover before click) that the learner can use immediately.

E. PREREQUISITE REVIEW (7 minutes)

Run as an oral round-robin. Put the questions on the projector.

Question 1: "In Session 3, what does HTTPS and the padlock tell you about a website?"

- Expected answer: that the connection between your browser and the site is encrypted (private) and that the address is the one you typed. It does **not** prove the site is honest â€" a scam site can also have HTTPS.
- Common gap: learners think a padlock means "safe site". Re-state clearly: the padlock means *private connection*, not *trustworthy owner*. This matters today because phishing links increasingly use HTTPS too.

Question 2: "What is MFA, and name one type?"

- Expected answer: Multi-Factor Authentication â€" a second proof of who you are beyond the password, e.g., a code from an app/SMS, a fingerprint, or a hardware key.
- Common gap: confusing the *password* with the *second factor*. Remind them: MFA means "something you know PLUS something you have/are". Even if a phisher steals the password, MFA blocks the login.

Question 3: "Say the Stopâ€"Thinkâ€"Verify steps from Week 1."

- Expected answer: Stop (do not rush); Think (does this make sense? who really sent it?); Verify (check through a separate, known channel).
- Common gap: learners skip straight to Verify without Stopping. Emphasise that the *pause* is what breaks the attacker's trick.

Bridge to today (say this):

> *"Last session we made sure the website was who it claimed to be. But most attacks do not come through a website you chose â€" they come to you, in your inbox, in your WhatsApp, in a phone call. They ask you to do something: click, pay, confirm, forward. They are not hacking the computer; they are hacking the person. That is called social engineering, and today we learn to see it coming."*

If more than a third of the class cannot describe Stopâ€"Thinkâ€"Verify, spend 3 extra minutes re-teaching it before continuing.

F. FULL LECTURE NOTES

F.1 How email works â€" the simple truth

The idea. Email is a message that travels from a sender's mail service to a recipient's mail service over the internet, and then sits in a mailbox until you open it.

Plain-English definition. Think of email like the **postal service**. You write a letter, put an address on the envelope, and hand it to a post office. It is carried and delivered to another post office, then placed in a mailbox. Email does exactly this, but instantly.

The parts of an email you should care about as a defender:

Part	What it is	Why it matters
Display name	The friendly name shown, e.g., "GTBank Alert"	**Anyone can type any display name.** It is just a label. Never trust it.
Real sender address	The actual address, e.g., `alerts@gtbank.com`	This is the true origin. Learn to read it carefully.
Subject	The title line	Attackers use it to create urgency ("URGENT: Account blocked").
Body	The message text	Contains the trick, the request and the link.
Links	Text that, when clicked, opens a web address	The visible text and the real destination can **differ**.
Attachments	Files attached to the mail	A common way to deliver malware (covered fully in Session 5).

Part	What it is	Why it matters
Headers	The hidden technical details of the message	These show the true route and can expose fakes, but are hard to read â€” we only need to know they exist.

Why it exists / why the fakes are possible. Email was designed for convenience and openness, long before fraud was a concern. The system allows a sender to write almost any display name, and the *visible* link text is just words â€” the real destination is hidden behind it. These two facts are the attacker's main tools.

A familiar Nigerian scenario. You get an SMS or email: "Dear customer, your transfer of â‚¦150,000 is on hold. Call this number." The sender's name in your phone may even read "GTBank" because SMS sender IDs can be spoofed. The message is fake, but the *name* looks real. The same trick works by email.

Misconception to kill early. "If the email came from my bank's name, it is from my bank." Wrong. The name is a label, like writing "FROM THE PRESIDENT" on an envelope. It proves nothing.

Limitation. Email itself cannot fully stop phishing; it is a delivery channel. Protection comes from *your habits* plus *your mail provider's filters* (which help but are never perfect).

F.2 What phishing is, and why it works

Plain-English definition. Phishing is a fake message that pretends to come from a trusted person or organisation in order to trick you into giving information, clicking a link, paying money, or opening a harmful file.

The word itself. "Phishing" is like *fishing*: the attacker throws out many baits (fake emails) hoping to *catch* some people (the fish). Most people ignore the bait; the attacker only needs a few to bite.

Why it works â€” the psychology. Attackers do not need to fool everyone. They use emotions that make us act fast without thinking:

- **Fear / urgency** â€” "Your account will be closed today!"
- **Authority** â€” pretending to be a bank, an employer, or the government.
- **Greed / reward** â€” "You have won â‚¦500,000."
- **Curiosity** â€” "See what this person said about you."
- **Helpfulness** â€” "Please assist me, I am in a meeting, buy this urgently."

The familiar analogy. Phishing is like a stranger at the market gate wearing a shop uniform, calling you by a friendly greeting and saying "Come, there is a special discount inside â€” just give me your bag first." The uniform is fake; the friendliness is the bait; the goal is your bag.

A realistic Nigerian scenario. An email arrives with the subject "FINAL NOTICE: Your POS terminal will be deactivated." It says your POS provider needs you to "reconfirm your settlement account" by clicking a link. A busy shop owner, worried about losing POS income on a Saturday, clicks and types his banking details. The details go straight to the attacker.

Misconceptions.

- "Phishing is always badly written." Sometimes, but good attackers write clean, correct English. Do not rely on spelling alone.
- "Only foolish people fall for phishing." False â€” busy, tired, pressured and polite people fall for it. It is designed for human nature, not stupidity.
- "My email filter catches everything." Filters help a lot but miss some. You are the last line of defence.

Limitation. No single check is enough. That is why the answer is a *combination*: check sender, hover the link, be suspicious of urgency, and verify by another channel.

F.3 The red flags â€” how to recognise a phishing email

Teach these as a checklist. The learner should be able to name at least six.

1. Look-alike domain (the strongest clue). The real address is slightly wrong. Examples:

- `gtbank.com` (real-ish style) versus `gtbank-secure.example` or `gtb-ng.example`.
- `paypal.com` versus `paypa1.com` (the letter *l* replaced by the number *1*).
- Extra words, extra hyphens, or a different ending (`.net` , `.xyz` , `.top` , or a country you do not expect). **Rule:** read the address **right to left**, from the last dot backwards. The part just before the final dot is the real organisation name.

2. Urgency and deadlines. "Within 24 hours", "Immediately", "Your account will be blocked", "Act now". Real organisations rarely demand instant action by email.

3. Threats. "Permanent suspension", "Legal action", "Your money will be lost". Fear pushes you to click without thinking.

4. Unusual or sensitive requests. Asking for a password, PIN, card number, OTP code, or to "confirm your details". **No legitimate bank will ever ask for your full password or OTP by email.** The OTP is the second factor from Session 2 â€" it must never be shared.

5. Generic greeting. "Dear Customer", "Dear User", "Dear Sir/Madam". A real company that holds your account usually knows your name.

6. Spelling, grammar and strange formatting. Odd spacing, wrong logos, "Kindly do the needful", inconsistent fonts. A clue, but not proof on its own.

7. Mismatched link text versus destination. This is the one we demonstrate. The words say `www.gtbank.com` but hovering shows something completely different. Always hover before clicking.

8. The "from" address does not match the signature. The signature says "First Bank" but the sender address is `firstbank-help@randommail.example`.

9. Attachments you did not expect. Especially `.zip`, `.exe`, `.scr`, or a "receipt" you never asked for. (Full malware treatment is in Session 5, but flag it here.)

10. Reply-to differs from the sender. A scammer may set replies to go to a different address they control. (Advanced; mention only.)

Worked example (say this): "Subject: URGENT â€" verify your account. From: 'Access Bank' access.secure@mail-alert.example. Body: 'Dear Customer, your account is at risk…' " Let learners call out the flags: urgency, display-name mismatch, wrong domain, generic greeting, fear. That is five flags in one small message.

F.4 "Hover before you click" and checking the real sender

Hover before you click. Move the mouse pointer over a link (but do **not** press the button). After a short moment, the browser shows the **real destination address** in a small bar at the bottom-left of the window. On a phone, a **long-press** often reveals the link.

- If the destination does not match what the words claim â€" do not click.
- If the destination is a strange domain, a short-link service (like `bit.ly`), or an IP number â€" treat it as suspicious and do not click.

Reading the real sender address. In many mail apps, clicking the sender's name reveals the full address, e.g., `alerts@gtbank.com`. Read it carefully:

- Look at the domain (the part after the @).
- Compare it exactly with the official domain you know.
- Watch for swapped letters (`rn` looking like `m`), added hyphens, or added words.

Why the display name lies. The display name is free text, like the "From" line on a paper letter. An attacker writes "GTBank" there and it appears in your inbox. The real address behind it is what matters.

The analogy. Hovering is like checking a person's **ID card** before letting them in, instead of trusting the uniform.

> ***Important defensive rule:*** *We only hover and read in this session. We never click a link in a suspicious message â€" not even "just to see". Clicking can launch a fake login page, download malware, or tell the attacker your address is live.*

F.5 Social engineering: spear-phishing, pretexting, CEO fraud, fake invoices

Social engineering, defined. Social engineering is any trick that manipulates a **person** into breaking normal safety rules â€" giving information, clicking, paying, or granting access. Phishing is the *email form* of social engineering; the same tricks come by phone (vishing), SMS (smishing), and WhatsApp.

Spear-phishing. A **targeted** phishing message, written for one specific person or small group, using details gathered about them (their boss's name, the project they work on, a recent event). Where ordinary phishing is a wide net, spear-phishing is a

spear aimed at one fish.

- *Scenario:* A staff member at a Port Harcourt school receives an email addressed to her by name, mentioning the exact event she organised last term, "from the principal", asking her to "quickly share the parent contact list".

Pretexting. Inventing a **story (pretext)** to justify a request. The attacker plays a role â€" IT support, a new supplier, a stranded relative â€" to make the request seem reasonable.

- *Scenario:* "Hello, I am from your bank's fraud desk. We detected a suspicious transfer; to cancel it I need the OTP we just sent you." The story is the pretext.

CEO fraud (business email compromise). The attacker impersonates a **senior person** â€" the owner, MD, or CEO â€" and pressures a junior staff member to make an urgent payment or share data, often adding "keep this confidential" so the victim does not check.

- *Scenario:* A shop's accountant gets an email from "the MD" (spoofed display name) saying: "I am in a meeting, pay this new supplier â‚¦450,000 today, do not discuss with anyone." The accountant, wanting to be helpful and not embarrass the boss, pays.

Fake invoice scams. A message pretending to be a supplier or service provider sends an "invoice" or "receipt" and asks for payment to new bank details, or attaches a harmful file. Small businesses are prime targets because invoice payments are normal.

- *Scenario:* A market trader receives an email "from" a known supplier with an outstanding invoice but a *changed* account number â€" "we have switched banks".

Impersonation of family/employer/bank. On WhatsApp, a scammer may clone a relative's photo and name and message "It's me, I'm in trouble, send money fast." Voice can even be faked now, so verify by calling the person on a number you already know.

Misconceptions.

- "If they know my name, it must be genuine." Personal details leak in many breaches; knowing your name proves nothing.
- "It is rude to check." Checking is *professional*, not rude. A genuine boss will thank you for verifying.

Limitation. You cannot always tell if a voice or message is fake. Therefore the golden rule is **out-of-band verification**: never act using the contact details inside the suspicious message â€" use a channel *you* already trust.

F.6 What to do when you get a suspicious email

Teach this as a fixed sequence. This is the most important part of the session.

1. **Do NOT click** any link, button, or attachment in the message.
2. **Do NOT reply**, and do not forward it to friends and family to "check" â€" forwarding can spread the scam.
3. **Report it** using your mail app's **Report phishing** / **Report spam** button. If it claims to be your bank, your employer, or a known company, also report it to that organisation through their official website or app (a number or address *you* look up, not one from the email).
4. **Verify by a separate, known channel.** If the email claims to be your bank, open your bank app or call the official number on your card. If it claims to be your boss, walk to their office or call their known number. Never use the contact details inside the suspicious message.
5. **Delete the message** (if your mail app does not delete it automatically when you report it) and mark the sender as spam/blocked.
6. **If you already clicked or typed details:** change that account's password immediately, turn on/confirm MFA, tell the organisation, and watch your bank/app alerts. Speed matters.

The analogy. A suspicious email is like a letter that smells of smoke. You do not take it into your house to examine â€" you handle it safely, flag it, and confirm with the real sender through a channel you already trust.

F.7 Protecting the email account itself

Email is the **master key** to your digital life: password-reset links for almost every service go to your email. If an attacker gets into your email, they can reset your bank, your WhatsApp, your social media. So protect it like the key to your house.

- **A unique, strong password.** Use one you have never used anywhere else (Session 2). Email passwords are the most valuable to attackers, so they must be the strongest and most unique.
- **Turn on MFA.** Prefer an authenticator app or a hardware key over SMS if available. Even the best password can be stolen; MFA is the second lock.
- **Never share OTP/verification codes** with anyone, ever â€" not "bank staff", not "support", not family over the phone. No genuine organisation asks for your OTP.
- **Review active sessions/devices** in your mail settings and sign out anything you do not recognise.
- **Watch the login alerts** your provider sends and verify unusual sign-ins.
- **Do not reuse your email password** on shopping or entertainment sites.

Nigerian scenario. A trader's email password was the same as a football-betting site password. That site leaked, the password appeared on a breach list, and attackers logged into his email, reset his bank password, and moved money. One unique password would have stopped the chain. (HaveIBeenPwned was demonstrated with your own email in Session 2 â€" this is the real-world reason.)

Limitation. Even with all this, a clever spear-phish can still trick you. That is why *habits* (stopâ€"thinkâ€"verify, hover, verify out-of-band) remain essential and are not replaced by technology.

F.8 Summary of the session

- Email is like post: the **display name is a label** anyone can write; the **real address** is the truth.
- **Phishing** is a fake message that uses fear, urgency, authority or reward to make you act.
- Red flags: **look-alike domains, urgency, threats, unusual requests, generic greeting, bad spelling, mismatched link text vs destination**.
- **Hover before you click** â€" read the destination, do not trust the words.
- **Spear-phishing, pretexting, CEO fraud and fake invoices** are targeted forms of social engineering.
- Response: **do not click â†' report â†' verify by a separate known channel â†' delete/block**.
- Protect the email account with a **unique strong password + MFA**, and **never share OTPs**.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

G.1 What the instructor prepares

- The projector with an open browser.
- The five **fictional** phishing samples (printed or on-screen). No live scam links â€" all links are text and point only to non-existent `.example` addresses or to a safe blank page.
- The instructor's **own** email account logged in (optional) to show the Report/Spam buttons.
- Worksheet 4.1 printed for every learner.

G.2 Demonstration 1 â€" an anatomy walk-through (6 minutes)

Say: "I am going to read one fake email slowly and out loud, and we will hunt for the traps together."

Put the "bank alert" sample on the projector. Read line by line and ask the class to shout "flag!" when they hear a trap.

- `<display name: Zenith Bank Security>` â†' "Is this the real name? No, it is a label."
- `From: security@zenith-alert.example` â†' point at the domain: "The last two parts before the final dot are `zenith-alert`, not `zenithbank`. Look-alike."
- `Subject: URGENT` â†' urgency flag.
- `Dear Customer` â†' generic greeting flag.
- `...within 24 hours or your account will be suspended` â†' threat flag.
- `Click here to verify your details` â†' request for sensitive information flag.
- **Hover the link:** the destination appears, e.g. `https://zenith-verify.example/login`. The text said "Zenith Bank" but the destination is a completely different domain. Mismatch flag.

Count the flags out loud: "Urgency, generic greeting, threat, wrong domain, mismatched link. Five traps in one short email."

Questions to ask:

- "If the link text says your bank's name but the destination is different, which do you trust?" â†' the destination, and even then only the real domain.
- "Does the padlock save us here?" â†' No; a fake site can also show a padlock.

G.3 Demonstration 2 â€" the safe response, live (5 minutes)

Say: "Now watch what a professional does with this email. Watch my hands â€" I never click the link."

1. Hover the link again; show the destination.
2. Click **Report phishing** (or **Report spam**) in the mail app â€" show where the button is.
3. Say: "Now I verify â€" but NOT using anything in this email." Open the bank's official app or the number on a card (use a fictional demonstration or describe it), and show that there is no such alert.
4. Show **Delete** and **Block sender**.
5. Recap aloud: "Don't click. Report. Verify a different way. Delete."

What to watch for: Learners may want to click "just to see". Firmly explain that clicking can confirm your address to the attacker, open a fake login page, or download malware â€" and that in a *real* situation we never do it.

G.4 Demonstration 3 â€" the email account settings (4 minutes)

Say: "Now let us protect the master key â€" the email account itself."

On the instructor's own account (projector):

- Open **Security** settings.
- Show where **two-step verification / MFA** is enabled (do not reveal any real secret codes).
- Show the list of **signed-in devices/sessions** and explain: "If you see a device you do not know, sign it out and change your password."
- Point out where **login alerts** appear.

Questions to ask:

- "Why is email the most dangerous account to lose?" â†' it can reset your other passwords.
- "Would you share an OTP with 'support'?" â†' never.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: With the instructor guiding, learners examine **five fictional phishing emails**, annotate the red flags, and decide the safe action for each â€" using only fictional samples and their own observations.

Starting materials: The five fictional samples (printed or on-screen), Worksheet 4.1, and a pen. No live links, no clicking.

Procedure (instructor calls each step; learners work at their seats; instructor walks the room):

1. Hand out the **Phishing Sample Pack (5 items)** and Worksheet 4.1. Confirm every sample has a fictional address ending in `.example`.
2. Explain the task: "For each email, find the red flags and write the safe action in the box. Use only your eyes â€" do not click anything."
3. Read **Sample 1** together as a class, then let learners fill it in as a worked example:
   - Flags: urgency + look-alike domain + generic greeting.
   - Safe action: do not click; report; verify via the official bank app; delete.
4. **Pause and predict (Sample 1):** "Before you look at Sample 2 â€" what kind of trap do you expect next?" Let them guess (e.g., a delivery fee, an invoice, a WhatsApp-style relative). This trains pattern recognition.
5. Learners work through **Samples 2â€"5 individually** (about 10 minutes). For each, they record:
   - At least three red flags.
   - Whether they would click (answer must be no).
   - The correct safe action.

6. For the **mismatched-link** samples, learners must **hover** (or long-press) and write the real destination next to the visible text.
7. **Where is the real sender?** For each sample, learners circle the true sender address and underline the domain.
8. Instructor calls time; a quick share-out: two learners read one flag each.

Expected result: Each email fully annotated with red flags and the safe action. Sample findings should include: (1) bank alert â€" urgency, look-alike domain, generic greeting; (2) HR salary email â€" unexpected request for bank details, authority, generic greeting; (3) fake invoice â€" changed bank account, attachment not expected, plausible supplier story; (4) delivery fee â€" small payment request, short link; (5) spear-phish colleague â€" personalised, gift-card request, "keep it quiet".

Points to pause and predict:

- After Sample 3: "Would a real supplier email you new bank details out of the blue?" â†' No; verify by phone with a known number.
- After Sample 5: "Is it rude to refuse the boss?" â†' No; verifying is professional.

Troubleshooting while walking the room:

- Learner cannot find the real address â†' show that the display name must be expanded/clicked to reveal the address.
- Learner says "the English is correct, so it is safe" â†' remind them good phishing can be well written.
- Learner says "I will click to check" â†' firmly stop; clicking is never the safe move.

Completion checklist (learner ticks each):

- ☐ All five emails examined
- ☐ At least three flags per email
- ☐ Real sender address identified and domain circled for each
- ☐ Hovered the links and wrote the true destination
- ☐ Safe action written for each
- ☐ Never clicked any link

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: Build a one-page **"Shopping / Online-Banking Safety Card"** that a beginner could keep by the computer, and test it on **two new fictional emails** provided at the start of the exercise.

Scenario: Your church's youth group asks you (the class) to produce a simple, printable safety card for members who use online banking and online shopping. It must help a person who knows nothing about phishing decide, in under 30 seconds, what to do with a suspicious message.

Starting information (given):

- Two new fictional emails (Email A: a fake "you overpaid, please send back the difference" message; Email B: a fake "your WhatsApp will be deleted, verify now" message).
- The six-to-ten red flags from Section F.
- The response sequence from Section F.6.

Requirements:

1. On the card, list the **red flags in plain words** (no technical jargon) â€" at least seven.
2. Add a clear **"STOP â€" DO THIS"** sequence for receiving a suspicious message (do not click, report, verify by a separate channel, delete).
3. Add a rule about **OTP and passwords**: "Never share, ever."
4. Apply the card to **Email A and Email B**: for each, list the flags you find and the action you would take.
5. Keep it to **one page**, readable by a market trader with basic English.

Time allowance: 15 minutes.

Success criteria:

- At least seven clear red flags in everyday language.
- A correct and complete "STOP â€" DO THIS" sequence.
- Both sample emails correctly assessed.

- The card is genuinely simple enough for a non-technical user.

Hints available if stuck:

- Hint 1: Start each red flag with "If you seeâ€¦ then be careful."
- Hint 2: Use the sequence: don't click â†’ report â†’ verify differently â†’ delete.
- Hint 3: For Email A, ask "why would a stranger send me money and ask me to send it back?" For Email B, ask "would WhatsApp really delete me by email?"

Instructor answer key (do not show learners):

Red flags (model list, plain language):

1. It rushes you ("urgent", "within 24 hours").
2. It threatens you ("account will be blocked", "deleted").
3. It calls you "Customer" instead of your name.
4. The sender's address looks almost right but not quite.
5. The words of a link say one thing; the real link is different.
6. It asks for your password, PIN, card number or OTP.
7. There is an attachment you did not ask for.
8. The money offer is too good or the request is strange.

"STOP â€" DO THIS" sequence:

1. Stop. Do not click, do not reply.
2. Report it (Report phishing/spam) and tell the real organisation using a channel you look up yourself.
3. Verify by a separate known channel (bank app, official number on your card, boss's known number).
4. Delete and block the sender.
5. If you already clicked or shared details: change the password now, confirm MFA, alert the organisation, watch your bank alerts.

Email A (overpayment): Flags â€" unexpected money, request to send money back, urgency, generic greeting. Action â€" do not reply; this is a classic overpayment/advance-fee scam; report, verify with your bank through its official app, delete. Never send money back based on an email.

Email B (WhatsApp deletion): Flags â€" threat of deletion, urgency, "verify now", look-alike domain, generic greeting. Action â€" WhatsApp does not delete accounts by email; do not click; verify in the app itself; report and delete.

Marking guidance (out of 10):

- Seven-plus correct red flags (3)
- Complete and correct STOP sequence (3)
- Email A correctly assessed (2)
- Email B correctly assessed (2)

J. REAL-WORLD CASE STUDY

Situation (fictional, non-identifying). A small money-transfer and POS business in a busy part of Port Harcourt â€" we will call it *Rivers QuickCash* â€" has one owner, Mrs. Amaka, and two young staff who handle the counter and the business email. The business uses email to communicate with its POS terminal supplier and its bank.

What happened. One Friday, close to month-end, the "supplier's accounts officer" sent an email titled **"UPDATED SETTLEMENT ACCOUNT â€" ACTION REQUIRED TODAY"**. The email used the supplier's logo and a display name identical to the supplier's. It said the supplier had changed banks and that the monthly terminal service fee of **â‚¦180,000** should now be paid to a new account, "before 5pm or service will be suspended". The message was signed "Accounts Dept" and added: "Do not copy other staff, this is confidential."

A junior staff member, wanting to be diligent before the weekend and not to embarrass anyone, began the transfer. At the point of final confirmation, he paused â€" the new account was in a personal-sounding name, and the email address ended in `.example` when he hovered, not the supplier's known domain.

Relevant facts.

- The request was **urgent** and came just before a deadline and the weekend.
- The sender's **display name matched** the real supplier, but the **address did not**.
- The new bank details were a **change** from the usual account.
- The message asked for **secrecy**.
- The staff member had the **authority** to make routine payments â€" a risk.

Decision point. The transfer is ready for final confirmation. Does he send the money to the new account, or stop and verify?

Possible approaches.

1. Send the payment quickly to avoid "service suspension".
2. Reply to the email asking "are you sure?".
3. Stop, then verify the new account by phoning the supplier's **known, existing** number (from previous genuine invoices, not the email).
4. Ask the bank to check the beneficiary name first.

Recommended solution. Approach 3, supported by 4. He stops, calls the supplier's real accounts officer on the number already on file, and asks directly. The supplier confirms it sent no such email. He reports the message, blocks the sender, deletes it, and alerts the two other staff and the owner so nobody else pays.

Trade-offs.

- Approach 1 is fast but could lose **â‚¦180,000** that is almost never recovered.
- Approach 2 is dangerous: replying confirms to the attacker that the address is live and lets them keep the lie going.
- Approach 3 costs a few minutes and a phone call, and is the only approach that uses a **trusted channel**. Minor cost: if it had been genuine, the payment is a little late â€" a small inconvenience versus losing the money.
- Approach 4 adds bank verification, which is good practice for **changed** account details, but is not a substitute for calling the supplier.

Professional connection. This is exactly what "business email compromise" defence looks like in real entry-level office work: **verify any change of bank details by phone using a number you already have; never by replying to the email; and treat urgency plus secrecy as a warning, not a reason to hurry.** The same rule applies to a one-person shop and a bank.

K. COMMON MISTAKES AND TROUBLESHOOTING

Use this as the live troubleshooting guide. Where a learner hits an issue, ask them to check the relevant row rather than giving the answer immediately.

K.1 "I clicked the link before I thought"

Symptoms: Learner realises after clicking; may see a fake login page or a blank page. **Likely cause:** The urgency trick worked. (Confirmed once they admit they clicked.) **How to investigate:** Ask what the page asked for. Did they type anything? Did anything download? **Safe corrective steps:** Close the page. **Do not log in.** If any details were typed, change that account's password immediately, confirm MFA, and tell the organisation. Run a scan (Session 5). Delete the email and report it. **How to confirm resolved:** Account password changed; no unusual login alerts; reported. **How to prevent recurrence:** Practise the physical pause â€" hover first, always.

K.2 "But the sender's name was the bank's name, so it's real"

Symptoms: Learner trusts the display name. **Likely cause:** Not knowing a display name is free text. **How to investigate:** Expand the sender to reveal the **real address**; compare with the official domain. **Safe corrective steps:** Teach reading right-to-left through the domain. **How to confirm resolved:** Learner can state the real domain and whether it matches. **Prevention:** Always check the address, never the label.

K.3 "The website had a padlock, so it must be safe"

Symptoms: Learner uses the padlock as proof of honesty. **Likely cause:** Confusing encryption with trust (Session 3 gap). **How to investigate:** Check the **domain**, not the padlock. **Corrective steps:** Re-explain: padlock = private connection, not a good owner. **Prevention:** Judge the domain, hover the link.

K.4 "I wanted to check, so I replied to ask if it was real"

Symptoms: Learner replies to a suspicious email. **Likely cause:** Not knowing that replying confirms your address and keeps the attacker talking. **How to investigate:** Determine what was said in the reply and whether any details leaked. **Safe corrective steps:** Stop replying; report and block; if any details were shared, secure the account. **Prevention:** Verify only by a channel *you* choose â€" never inside the suspicious message.

K.5 "I forwarded it to my friend to ask if it was a scam"

Symptoms: Learner forwards suspicious email to others. **Likely cause:** Thinking a second opinion online is safe. **How to investigate:** Did the forward include the live link? Warn the friend not to click. **Corrective steps:** Tell the friend to ignore/delete; don't forward further. **Prevention:** Report through the proper button; verify with the real organisation.

K.6 "Someone asked for my OTP and sounded like the bank"

Symptoms: Learner nearly shared a code. **Likely cause:** Pretexting â€" a convincing story. **How to investigate:** Ask if any code was shared; if so, treat the account as compromised. **Corrective steps:** If shared â€" call the bank on the official number, change the password, confirm MFA, watch alerts. **Prevention:** Rule: **no genuine organisation ever asks for your OTP or full password.**

K.7 "The English was perfect, so I trusted it"

Symptoms: Learner uses writing quality as the only test. **Likely cause:** Believing the myth that phishing is always badly written. **Corrective steps:** Re-teach: good attackers write well; judge the domain, the request and the urgency, not the grammar. **Prevention:** Never rely on one single clue; use the whole checklist.

Distinguish likely vs confirmed: Every "likely cause" becomes "confirmed" only after checking â€" e.g., expanding the sender address, hovering the link, or seeing the actual charge/login alert. Teach learners to *confirm before they conclude*.

L. SESSION ASSIGNMENT

Assignment title: "Phishing Red-Flag Report and Family Safety Brief"

Purpose: Practise applying the red-flag checklist and the safe-response sequence to realistic fictional messages, then explain it clearly in plain English â€" the same skill needed for the capstone report in Week 3.

Realistic scenario: You are the informal "tech person" in your family or church. A relative forwards you two suspicious emails and asks, "Is this real?" You must write a short report answering them safely, and prepare a simple brief you could share so the family does not get scammed.

Detailed instructions:

1. Write a short report (about one page) covering **two fictional emails** supplied by the instructor (or, if you wish, two messages you invent yourself â€" but keep them fictional and safe).
2. For **each email**, include:
   - The **real sender address** and whether its domain is genuine.
   - **At least four red flags**, named in plain words.
   - The **safe action** to take, step by step.
   - What to do **if** the person already clicked or shared details.
3. Write a **five-line "Family Safety Brief"** in simple English that a non-technical relative could follow.
4. State the **OTP/password rule** clearly.
5. Do not include any real scam link, any real person's details, or any data belonging to someone else.

Required deliverables:

- `session4-assignment/red-flag-report.md` (or a typed page/photo).
- `session4-assignment/family-safety-brief.md`.
- A note confirming that all examples are fictional and that you did not click anything.

Submission format: In the class folder as files, or a photo of a handwritten report in your workbook.

Deadline: Before Session 5.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Correct identification of real sender/domain	3	Reads the address, not the display name
Red flags named in plain language	5	At least four accurate flags per email
Safe action steps correct and complete	4	No click, report, verify separate channel, delete
"Already clicked" recovery steps	3	Change password, MFA, alert org, watch alerts
Family Safety Brief clarity	3	Simple enough for a non-technical reader
Professionalism / all fictional & safe	2	No real links or data; clear note

Common mistakes to avoid: trusting the display name; forgetting the "already clicked" recovery; giving advice that involves clicking to check; using jargon the family cannot understand.

Instructor reference solution (model answer):

Email 1 â€" "Bank alert": Real address `alerts@zenith-secure.example`; domain `zenith-secure.example` is not the bank's real domain (look-alike + wrong ending). Flags: urgency ("24 hours"), threat ("suspended"), generic greeting ("Dear Customer"), link text says the bank but hover shows a different domain. Safe action: don't click; Report phishing; open the bank **app** to confirm no alert; delete and block. If already clicked/shared: change the bank password, confirm MFA, call the bank on the number on your card, watch alerts.

Email 2 â€" "Supplier changed bank account": Real address is a free mail domain, not the supplier's. Flags: request to change payment details, urgency, secrecy ("do not copy others"), plausible story (pretexting), unexpected attachment. Safe action: don't pay; phone the supplier's **known** number to confirm; report; delete. If already paid: call your bank **immediately** to try to recall the transfer, report to the police.

Family Safety Brief (model): "1. If a message is urgent, stop â€" that is the trick. 2. Never click a link in a message you did not expect; hover first to see where it goes. 3. Never share your password or the code sent to your phone â€" not with anyone. 4. If your 'bank' or 'boss' asks for money or details, call them on the number you already have. 5. Suspicious? Report it, delete it, and tell someone you trust."

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key.)

Q1. Multiple choice. What does the **display name** of an email prove about who sent it? a) That the sender is genuine. b) That the sender's company verified the email. c) Nothing â€" anyone can type any display name. d) That it passed the padlock test.

Q2. Short answer. Name **four** red flags of a phishing email.

Q3. Explain in your own words. What is the difference between the **link text** and the **link destination**, and what should you do about it?

Q4. True or false, with a reason. "If an email uses correct English, it cannot be phishing."

Q5. Practical identification. An email says it is from "First Bank" but the sender address is `firstbank-alerts@secure-mail.example`. What is the red flag, and why?

Q6. Scenario. A message "from your MD" asks you to urgently pay a new supplier and to keep it secret. List the red flags and say exactly what you would do.

Q7. Fill in the blanks. The safe response sequence for a suspicious email is: do not ____; ____ it to the proper place; ____ it through a separate known channel; then ____ and block it.

Q8. Fill in the blanks. No genuine organisation will ever ask you for your full ____ or your ____ (one-time code) by email, SMS or phone.

INSTRUCTOR ANSWER KEY (Q1â€“Q8)

A1. (c) Nothing â€” anyone can type any display name. **A2.** Any four of: look-alike/wrong domain; urgency; threats; request for sensitive information (password/OTP/details); generic greeting; spelling/grammar errors; link text not matching destination; unexpected attachment; display name not matching the real address; request for secrecy. (Accept any four correctly described.) **A3.** The **link text** is just words the attacker wrote (what you see); the **link destination** is the real web address the click would open (what the browser shows when you hover). If they do not match, or the destination is a strange domain or short link, do not click â€” treat it as suspicious. **A4.** False. Good attackers can write clean, correct English, sometimes better than the real company. Grammar is only one clue; check the domain, the request and the urgency. **A5.** The domain `secure-mail.example` is not First Bank's real domain â€” this is a **look-alike / wrong domain** flag. The display name says "First Bank" but the real address goes elsewhere, so the message is likely fraudulent. **A6.** Red flags: authority (the MD), urgency, unusual request (new supplier/payment), secrecy ("do not discuss"), change of bank details. Action: do not pay; verify by calling the MD on their **known** number or walking to their office; if genuine, follow the organisation's normal payment process for changed account details; report the email; never use the contact details inside the message. **A7.** do not **click**; **report** it; **verify** it; then **delete** and block. **A8.** full **password** (or PIN/card number); your **OTP** (one-time password / verification code).

N. REFLECTION AND RECAP

Plain-English summary. Today you learned that most attacks do not hack the computer first â€” they hack the *person*. Email is like post, where the sender's display name is only a label anyone can write, and the real address is the truth. Phishing uses fear, urgency, authority and reward to make you act before you think. You learned to spot the red flags, to **hover before you click**, to check the real sender, to recognise spear-phishing, pretexting, CEO fraud and fake invoices, and to respond the professional way: don't click, report, verify through a separate known channel, then delete. You also connected this to protecting the email account itself with a unique strong password and MFA.

Five important takeaways:

1. The **display name lies**; the **real address** and the **hover destination** tell the truth.
2. Phishing exploits **emotion** â€” stop the panic and you stop the trick.
3. **Hover before you click**, and never click "just to check".
4. Response order: **don't click â†' report â†' verify a separate way â†' delete/block**.
5. Email is the **master key**: unique strong password + MFA, and **never share an OTP**.

Questions to help you recognise what you can now do:

- Can I read a real sender address and tell whether the domain is genuine?
- Can I hover a link and explain the difference between the text and the destination?
- Can I name six red flags without looking at my notes?
- Can I explain to a relative, in plain words, what to do with a suspicious message?

Connection to the next session: Phishing often leads to a second danger â€” **malware** hidden in links and attachments, and unsafe devices. Next session, **Device Hardening**, we turn to the machine itself: Windows Updates, Windows Defender, the firewall, and controlling which apps can run and install. If a bad file ever gets through, your hardened device is your next line of defence.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- The learner expands the sender and reads the **real address**, not the display name, without prompting.
- The learner **hovers** a link and correctly compares text versus destination.
- The learner names red flags in **plain language** (not just "it's a scam").
- The learner states the response sequence in the correct order.
- The learner understands that a padlock and correct English are **not** proof of honesty.
- The learner can explain **why** OTPs must never be shared, linking back to MFA from Session 2.

Common misconceptions to watch for and correct:

- "The name in my inbox is the real sender." â†’ Expand and check the address.
- "Phishing is always badly written." â†’ Good phishers write well.
- "Replying to ask is a safe way to check." â†’ Replying confirms your address; verify out-of-band.
- "A padlock means the site is safe." â†’ Padlock = private connection, not trust.
- "Only gullible people fall for it." â†’ It targets human nature under pressure, not intelligence.

Suggested remedial exercises for learners who struggle:

1. **Domain drill:** give ten sender addresses, mix real and look-alike; learners mark genuine or fake and explain.
2. **Hover drill:** provide a page of safe dummy links whose text differs from the destination; learners write the true destination beside each.
3. **Sequence drill:** hand learners the four response steps jumbled; they re-order them and justify the order.
4. **Plain-English drill:** learner explains one red flag to a partner pretending to be a market trader with no computer knowledge.

Differentiation:

- **Level 1 (supported):** Provide a partly filled worksheet with the flags already listed for two emails; the learner only decides the safe action.
- **Level 2 (standard):** The exercises as written.
- **Level 3 (challenge):** Give an email that uses **correct** English, a genuine-looking domain with one swapped letter, and a plausible pretext; the learner must find the single subtle clue and explain why all the "obvious" tests fail.

Timing guidance: If the room is slow, trim the case study (Section J) to a 3-minute mention and protect the guided and independent practicals â€" the *doing* is the priority. If the room is fast, extend the independent exercise by having learners pair up and verbally walk a partner through one email, then add a third sample.

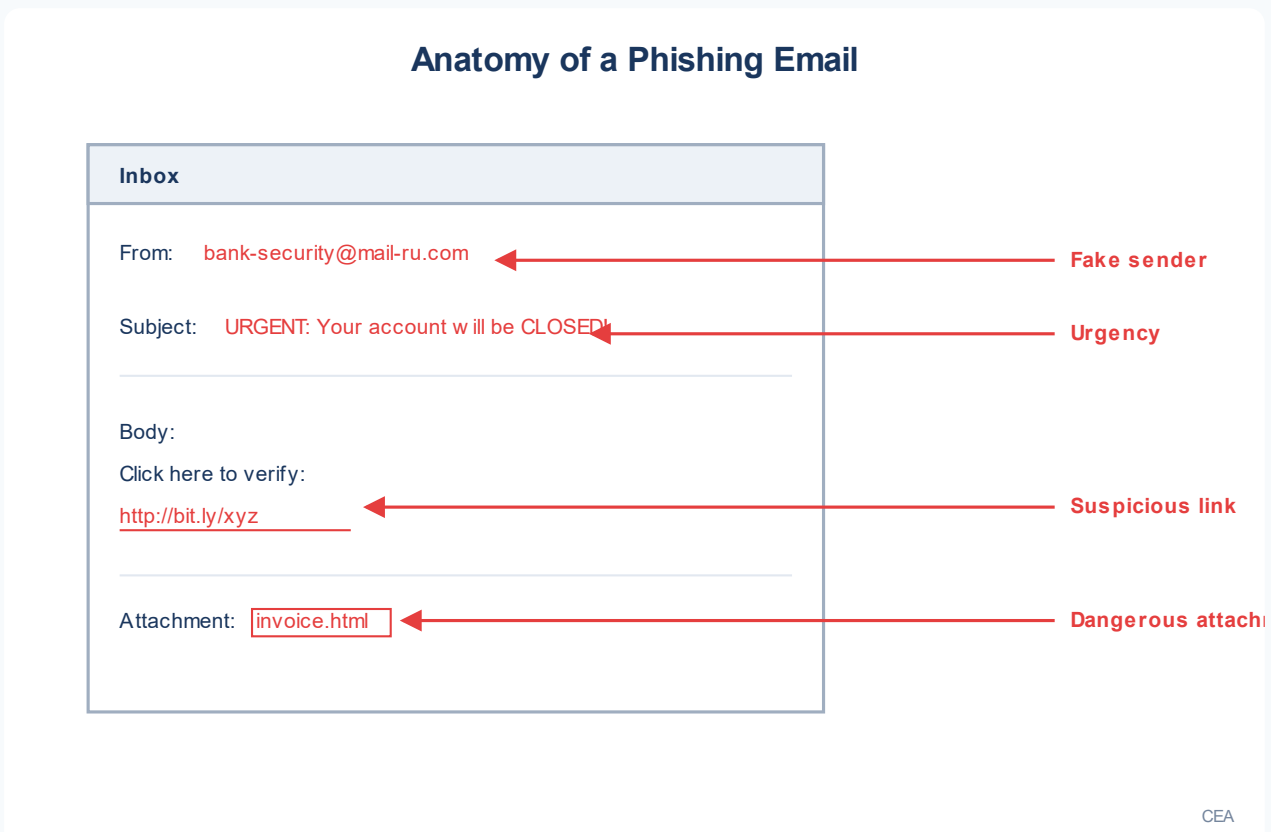
END OF SESSION 4

Next: Session 5 â€" Device Hardening: Updates, Windows Defender and Firewall.

SESSION 05 OF 9

Device Hardening

CONCEPT DIAGRAM — SESSION 05



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 5 â€" DEVICE HARDENING: UPDATES, WINDOWS DEFENDER AND FIREWALL

A. SESSION IDENTIFICATION

Item	Detail
Session number	5 of 9
Session title	Device Hardening: Updates, Windows Defender and Firewall
Week / Module	Week 2 â€" Module 2: Protecting People and Devices (theme: **Harden**)
Recommended duration	105 minutes
Difficulty level	Beginner (no prior security knowledge assumed)

Item	Detail
Prerequisite knowledge	Session 1 (threats and Stopâ€"Thinkâ€"Verify), Session 2 (strong passwords + MFA), Session 3 (safe browsing/downloads), Session 4 (phishing and social engineering). A learner must be able to use the Windows Start menu, open Settings, and read a screen.
Connection to previous work	Last session we removed the "human door" for attackers. This session we lock the *machine*: we make sure Windows is updated, antivirus protection is on, the firewall is active, and that apps cannot install or run freely. If a bad file ever gets in, a hardened device limits the damage.
Preparation before class	Academy PCs on Windows 10 or 11. Instructor machine logged in **as a standard user or with admin rights clearly understood**. Learners work on their **own or academy practice machines** â€" never a machine they do not have permission to change. Instructor confirms Defender and Firewall features exist on the lab devices before the session.
Safety / permission note (read aloud)	"Changing updates, firewall settings or installing software can affect a shared machine. We only do these tasks on our **own** device or an **academy practice machine**, and only with the instructor's permission. We never change settings on someone else's computer. These are defensive actions â€" we are protecting our own device, not attacking anyone."

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Explain in simple terms** what an operating-system update is and why leaving a device un-updated is dangerous (the "locked-door" idea).
2. **Check Windows Update status** on a Windows 10/11 device and confirm whether automatic updates are on.
3. **Verify that Windows Defender real-time protection is on** and **run a Quick scan**, then read the result correctly.
4. **Confirm the Windows Firewall is on** for the current network profile and explain what the firewall does in plain words.
5. **Explain the difference between a standard user and an administrator account**, and describe what a UAC prompt is asking.
6. **Decide whether a piece of software comes from a safe source**, and apply a rule for downloading and installing apps.
7. **Manage startup programs** so fewer unnecessary applications run automatically at boot.
8. **Explain "defence in depth"** â€" why antivirus alone is not enough and why several layers must work together.
9. **Produce a short "device hardening checklist"** about a device they are authorised to use.

C. REQUIRED MATERIALS

Hardware

- One Windows 10 or Windows 11 computer per learner (academy desktops, or the learner's **own** laptop with permission).
- Instructor computer connected to a projector or large screen.

Software

- Windows 10 or Windows 11 with the built-in **Windows Security** (Windows Defender) and **Windows Firewall**. These are built into Windows â€" no purchase needed.
- A web browser to *look at* (not download from) the official Windows support pages if internet is available. Optional.

Accounts

- The learner works in their **own** Windows account. Some tasks (like changing some update settings) may require an administrator login; if the academy machine is administered centrally, the instructor performs the admin steps on the projector and learners observe and record. **Never** use an admin account the learner is not authorised to use.

Worksheets

- Worksheet 5.1 â€" "Device Hardening Checklist" (learner fills in on their authorised device).
- Worksheet 5.2 â€" "Defence in Depth Layers" diagram to label (learner workbook, Part 3).

Tools

- Windows Security (Defender), Windows Update, Windows Firewall, Task Manager / Startup apps settings. All built into Windows.

Internet

- Ideally available so updates can actually check and download. If no internet, learners still complete the checks and record the status; the instructor explains that the checks are the skill, and updates apply later when connected.

Important accuracy note for the instructor: Menu names and wording in Windows change between versions and updates. In Windows 10, security tools are collected under **Windows Security** (also called **Windows Defender Security Center** in older builds). In Windows 11 the same tool exists and is usually found via **Settings â†' Privacy & security â†' Windows Security**, or by searching "Windows Security". Always tell learners: "The wording may differ slightly by version â€" look for the meaning, not the exact words." Do **not** claim a specific screenshot; walk the actual menus on the real machine.

Alternative for learners who lack a facility

- If a learner has no Windows machine, they pair with a desktop user, follow along, and complete the checklist by observing and reading aloud. A phone user cannot complete the Windows tasks but can still learn the concepts and pass the knowledge check.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: On the projector, show a familiar picture â€" a house with a front door. Then show a second picture: the same house with a **broken window** and a note "we never fixed it".

What the instructor says:

> *"Look at this house. Strong door, strong lock â€" we did that in Sessions 2 and 4. But look again: the window has been broken for months and nobody repaired it. Is the house safe? No. A thief does not fight the strong door; he climbs through the window you forgot.*
>
> *A computer is the same. You can have the best password and never click a phishing link â€" but if you never install your Windows updates, you are leaving a broken window open. Attackers know exactly which windows are broken. Today we fix the window. We will update Windows, make sure your antivirus and firewall â€" your security guards â€" are awake, and control what is allowed to run on your machine."*

Expected learner response: Learners may say "I always click 'Later' on updates", or "I have never updated my phone/laptop". Some will ask if updates really matter. Accept all; note honestly that updates can be inconvenient (they restart the machine) but the protection is worth it.

Then demonstrate the hook: On the projector, open Windows Update and show the current status. If an update is pending, point at it.

> *"See this? Windows is telling us a window needs repair. Notice how it says 'Restart to install'. Most people keep pressing Later. Today you will learn why 'Later' is exactly what the attacker hopes you will say."*

Why this opener works: It connects the abstract idea of *updates* to a concrete, visual danger (a broken window) that every learner understands, and it frames the whole session as fixing something broken rather than learning settings for their own sake.

E. PREREQUISITE REVIEW (7 minutes)

Run as an oral round-robin. Put the questions on the projector.

Question 1: "From Session 3, why is it safer to download software from the official website or an official app store rather than from a random link?"

- Expected answer: Random links may deliver malware disguised as software; official sources are far more likely to give you the real, unmodified program.
- Common gap: learners think "free cracked" versions are just cheaper, not more dangerous. Re-state: cracked/pirated apps are a very common way malware gets in.

Question 2: "From Session 4, name two of the red flags of a phishing email."

- Expected answer: e.g., look-alike domain, urgency, generic greeting, mismatched link, request for OTP.
- Common gap: learners remember "scam" but not *specifically why*. Prompt them to name the actual clue.

Question 3: "What is MFA, and why does it matter if a password is stolen?"

- Expected answer: a second proof of identity; even if the password leaks, the attacker still cannot log in without the second factor.
- Common gap: confusion between password and second factor; re-clarify.

Bridge to today (say this):

> *"We have protected the accounts and trained the person. But the device itself â€" the actual laptop â€" can still be attacked. Malware does not care how strong your password is. So today we harden the machine with four layers: keep it updated, keep the antivirus awake, keep the firewall on, and keep control of what runs. This is called* ***defence in depth*** *â€" many locks, not one."*

If more than a third of the class cannot answer Question 1, spend 3 extra minutes re-teaching safe download sources before continuing.

F. FULL LECTURE NOTES

F.1 What device hardening means

Plain-English definition. Device hardening means changing the settings and habits on your computer so that it is harder for an attacker or a harmful program to get in, spread, or do damage â€" without making the device unpleasant to use.

Why the word "harden". Think of a snail's shell. The snail is soft, but the shell is hard, so a small knock does not hurt it. Hardening a device is building that shell around your data.

Why it exists. Attackers look for the **easiest way in**. If your Windows is fully updated, your antivirus is on, your firewall is active, and random apps cannot install, the attacker moves to an easier target. You do not need to be *impossible* to attack; you need to be *harder than the alternative*. This is called reducing your "attack surface" â€" fewer open doors means fewer ways in.

The four layers we harden today (defence in depth):

1. **Updates** â€" repair the broken windows (fix known holes).
2. **Antivirus / Defender** â€" a guard dog inside the house.
3. **Firewall** â€" a gate keeper on the boundary.
4. **App control and user accounts** â€" decide who is allowed to bring things inside.

Realistic Nigerian scenario. A cyber-cafÃ© in Port Harcourt keeps its machines updated and locked down. A customer plugs in a flash drive with an infected file. The antivirus catches it, the account is a standard user so nothing installs silently, and the cafÃ© stays running. The shop down the road with no updates and admin accounts for everyone loses all its machines in one afternoon.

Limitation / misconception. "My antivirus will protect me from everything." No â€" antivirus is one layer. New and clever malware can slip past antivirus, which is exactly why updates, the firewall and safe habits also matter.

F.2 Windows Update â€" repairing the broken windows

Plain-English definition. An **operating-system update** is a package from Microsoft that fixes problems and security holes in Windows, and sometimes adds features.

Why updates matter â€" first principles. All software has mistakes in it (called **bugs**). Some bugs can be used by attackers to break in; these are called **vulnerabilities**. When Microsoft finds a security vulnerability, it writes a **patch** (a fix) and sends it in an update. If you do not install the update, your machine keeps the known hole open â€" a broken window that the whole world of attackers can see and use.

The analogy. A **vaccine for your computer**. One person catching a disease is bad; a whole community protected is good. Updates immunise your device against known attacks, and installing them protects others too, because an infected machine can spread to the network.

Why automatic updates matter. Most people forget, or keep pressing "Later". **Automatic updates** mean the protection arrives without you remembering. It is like a guard who does his rounds whether or not you are watching.

How to check Windows Update (Windows 10 and 11):

- Open **Settings** (press `Windows key + I`).
- Windows 11: **Windows Update** appears directly on the left menu; or **Settings â†' Windows Update**.
- Windows 10: **Settings â†' Update & Security â†' Windows Update**.
- Look for:
  - "**You're up to date**", or pending updates and a **Check for updates** button.
  - **Restart required** / **Restart now** â€" this means a fix is waiting and needs a restart to finish.
- Learner action: click **Check for updates**, then **restart** if asked (with permission, and warn about saving work first).

Worked example. A learner sees "Updates available" and a **Restart** button. They save all files, click Restart, and the machine applies the patch. On returning, status reads "You're up to date". That is one window fixed.

Misconceptions.

- "Updates only add features / change my screen." Many updates are **security** updates that repair holes â€" the most important kind.
- "I can update once a year." Some attacks work within days of a vulnerability being known, so regular, automatic updates are safest.
- "A restart is not needed, I will leave it." Often the fix does not take effect until you restart.

Limitation. Updates fix *known* problems. They cannot fix a brand-new "zero-day" attack â€" that is why the other layers matter too.

F.3 Windows Defender â€" the guard dog (antivirus and real-time protection)

Plain-English definition. Microsoft Defender Antivirus (part of **Windows Security**) is the built-in antivirus in Windows. It looks for harmful software (**malware**) and stops it.

Why it exists. Microsoft builds antivirus into Windows so that every machine has at least basic protection without buying anything. On a modern Windows 10/11 machine, Defender is usually on by default and is a genuinely capable antivirus.

What it does:

- **Real-time protection** â€" watches files as they open, download and run, and blocks suspicious activity immediately (the guard dog that stays awake).
- **Scans** â€" checks the whole device or specific areas for malware (Quick scan, Full scan, Custom scan).
- **Definitions / updates** â€" frequent updates that teach Defender about new malware (the guard dog learning new smells).
- **Firewall and other protections** appear in the same **Windows Security** app.

The analogy. Defender is a **security guard inside your shop**. **Real-time protection** is the guard standing awake at the door checking every visitor. If you switch real-time protection off, the guard is asleep â€" the door is open.

How to check Defender and run a Quick scan (Windows 10 and 11):

- Open the **Start** menu and search **Windows Security** (in older Windows this may be called **Windows Defender Security Center**).
- Open it. On the left/centre you see areas such as **Virus & threat protection**, **Firewall & network protection**, **App & browser control**, etc.

- Click **Virus & threat protection**:
  - Look for "**No current threats**" and, under **Virus & threat protection settings**, check that **Real-time protection** is **On**.
  - Click **Quick scan** and wait for it to finish.
  - Read the result: usually "No current threats" or a list of anything found, with **Actions** if needed.
- If you see a red or yellow warning, that is a sign to fix something â€” read the text carefully.

Worked example. A learner opens Virus & threat protection, sees green ticks, confirms real-time protection is On, runs a Quick scan, and reads "No current threats found". Defender is awake.

Misconceptions.

- "I have to buy antivirus; Windows has none." Modern Windows has Defender built in and on by default.
- "I can turn off real-time protection to make my PC faster." That leaves the door open; only do this if a trusted technician asks, and re-enable afterwards.
- "If Defender flags software I trust, it is broken." Sometimes Defender is right to be cautious; check the file's source before overriding.

Limitation. Defender cannot catch everything, and no antivirus can. It works with updates, the firewall and safe habits â€” defence in depth.

F.4 Windows Firewall â€” the gate keeper

Plain-English definition. A **firewall** is a filter that watches the network traffic going in and out of your computer and blocks connections that are not allowed.

Why it exists. Computers are connected to networks (home Wi-Fi, cafÃ© Wi-Fi, the internet). Without a gate keeper, a stranger on the network could try to connect to your machine directly. The firewall decides who may come in and who may go out.

What it does:

- Blocks **unsolicited incoming connections** by default (someone outside cannot just barge in).
- Allows outbound connections from your own trusted apps.
- Lets you allow or block a specific program when needed.

The analogy. The firewall is the **gate keeper at the compound gate**. He has a list. Unknown visitors at the gate are turned back; recognised deliveries are allowed through. (Updates are the broken window, Defender is the guard inside, and the firewall is the gate keeper.)

Network profiles. Windows has different firewall profiles for **Domain**, **Private** and **Public** networks:

- **Private** â€” for your home/trusted network.
- **Public** â€” for cafÃ©, airport, hotel Wi-Fi (stricter, hides your machine more).
- **Domain** â€” managed by an office domain.

How to check the Firewall (Windows 10 and 11):

- Open **Windows Security â†’ Firewall & network protection**.
- You will see the active network and whether the firewall is **On** (green) or off.
- Confirm the firewall is **On** for the network you are currently using.
- If it is off and you are allowed to change it, switch it **On**. On a managed machine, the instructor handles admin steps.

Misconceptions.

- "The firewall slows my internet." A properly configured firewall has almost no visible effect for normal use.
- "The firewall is the same as antivirus." No â€” the firewall filters *network connections*; antivirus looks for *malicious files*. They do different jobs.
- "I should allow everything so nothing is blocked." That defeats the gate keeper; only allow what you recognise and need.

Limitation. A firewall does not stop you from *yourself* clicking a bad link and running a bad program â€” which is why Defender and safe habits matter.

F.5 Controlling what apps can run and install â€” standard vs admin accounts and UAC

Plain-English definition. On Windows, a **standard user account** can use the computer but cannot make big system changes; an **administrator account** can install software, change settings and manage other accounts.

Why this matters. Most malware needs **administrator permission** to install itself deeply into the system. If you use a **standard account** day to day, the malware cannot install silently â€" it must ask for permission through a prompt, and you can say **No**. This is a big, cheap, powerful protection.

The analogy. A **standard user** is a guest in a hotel â€" comfortable, but cannot change the building's wiring. An **administrator** holds the master key to the plant room. You only need the master key when genuine building work is done.

What is UAC? User Account Control (UAC) is the prompt that appears when something wants administrator rights: a box saying "Do you want to allow this app to make changes to your device?" with **Yes/No**.

How to read a UAC prompt â€" teach the three questions:

1. **What** is asking? Read the app name â€" is it something you chose to run, or something unexpected?
2. **Why** is it asking *now*? Did you just open a program, or did a prompt appear out of nowhere (a red flag)?
3. **Who** published it? A genuine installer shows a trusted publisher name; "Unknown publisher" deserves caution.

Rule: If a UAC prompt appears when you did not start anything, do not click Yes. In Session 4 we saw that malware often arrives through a fake update or a "click here" link; a sudden UAC prompt can be the payload trying to install.

How to check your account type (Windows 10/11):

- **Settings â†' Accounts â†' Your info** (the wording varies). It shows **Administrator** or **Standard user**.
- For advice on daily use: **use a standard account for everyday work, and keep an administrator account for when real changes are needed.**

Misconceptions.

- "Admin is always better." More power means more damage if something goes wrong. Day to day, standard is safer.
- "UAC is annoying, I always turn it off." UAC is a seat belt â€" do not disable it to avoid the click.
- "Clicking Yes is fine, it is just Windows." Read the prompt; a stranger asking for admin should alarm you.

Limitation. On a **shared or single-user home PC**, many people use an admin account for convenience. Even then, **reading the UAC prompt before clicking Yes** gives most of the benefit.

F.6 Safe software sources and managing startup programs

Safe software sources â€" the rule. Only get software from:

1. The **official website** of the company that makes it (typed by you, not clicked from a random link), or
2. The **official app store** built into Windows (**Microsoft Store**), or
3. A **trusted, official package source** your organisation has approved.

Avoid: links from emails/WhatsApp, "download" ads, free **cracked/pirated** software, and "keygen" tools. Cracked software is a classic way to get malware, and pirated apps often come bundled with harmful extras.

The analogy. Candies handed out by a random stranger on the street versus candies bought from a real supermarket. Same wrapper, very different trust.

Managing startup programs. Startup programs are apps that launch automatically when Windows starts. Too many start-up apps make the machine slow and, more importantly, keep unnecessary programs running (more code running = more possible weaknesses).

How to check (Windows 10 and 11):

- **Settings â†' Apps â†' Startup** (Windows 11) or **Settings â†' Apps â†' Startup** (Windows 10 has this too); or
- **Task Manager** (`Ctrl + Shift + Esc`) â†' **Startup apps** tab.
- You see a list with an **enabled/disabled** status and a **Startup impact** rating (Low/Medium/High).
- For programs you do not need at boot, set them to **Disabled** (you can re-enable any time).
- **Caution:** do not disable security tools, drivers, or things you do not recognise. When in doubt, leave it and ask.

Misconceptions.

- "More startup apps means my PC is more ready." It usually just means slower and busier.
- "Disabling a startup app deletes it." No â€" it only stops it auto-starting, the app is still installed.

Limitation. Managing startup apps is a performance and tidiness habit more than a firewall; it reduces risk a little but does not replace the other layers.

F.7 Why antivirus alone is not enough â€” defence in depth

Plain-English definition. Defence in depth means using **several layers** of protection together, so that if one fails, the others still protect you.

The idea with a Nigerian picture. Think of protecting a market stall at night:

- A **strong door lock** (password + MFA),
- A **gate keeper at the compound** (firewall),
- A **guard dog inside** (antivirus),
- **Repairing the fence** (updates),
- **Telling the family the safe routine** (safe habits).

Any one alone can fail. Together, the stall is very hard to rob.

Why needed. Every layer has limits we noted:

- Updates cannot fix brand-new attacks.
- Antivirus cannot catch everything.
- The firewall cannot stop you from running a bad program yourself.
- Even a careful person can be tricked once.

Stacking them means an attacker must beat *all* of them, not just one.

Misconception. "I have antivirus, so I am safe." If that were true, there would be no malware infections. Layers are why professionals use many controls together.

F.8 Summary of the session

- **Hardening** = making your device harder to break into, without making it painful to use.
- **Updates** fix known holes (broken windows) â€” turn on automatic updates and restart when asked.
- **Windows Defender** is the built-in antivirus; confirm **real-time protection is On** and run a **Quick scan**.
- **Windows Firewall** is the gate keeper; confirm it is **On** for your network.
- Use a **standard account** for daily work; **read every UAC prompt** before clicking Yes.
- Get software only from **official sources**; avoid cracked apps.
- Review **startup programs**; disable what you do not need.
- **Defence in depth** â€” many layers â€” because antivirus alone is not enough.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

G.1 What the instructor prepares

- The instructor machine (or an academy practice machine) logged in.
- Windows Security, Windows Update, Firewall, and Task Manager ready to open.
- Worksheet 5.2 (defence-in-depth diagram) printed for learners.
- Confirmation that the learner tasks require only standard-user actions; admin steps are done by the instructor on the projector.

G.2 Demonstration 1 â€” Windows Update (4 minutes)

Say: "Watch me repair the broken window. Do not do anything yet â€” just watch and note the steps."

1. Press `Windows key + I` to open **Settings**.
2. Go to **Windows Update** (Windows 11: directly on the left; Windows 10: **Update & Security â†' Windows Update**).
3. Show the status line. If updates are pending, point at **Check for updates** and press it (with internet).

4. If a **Restart required** appears, explain: "The fix is downloaded but needs a restart to take effect." **Do not** restart without warning; announce: "Save work, then restart."
5. Show the **Update history** and the **Advanced options** and point at the automatic-update setting.

Expected result: Status shows "You're up to date" or a list of pending updates and a restart button. **What to watch:** Do not let learners press Restart mid-task; warn about unsaved work. **Questions:** "Why does a fix need a restart?" â†' the core system files are in use while Windows runs. "Why automatic?" â†' so you never forget.

G.3 Demonstration 2 â€" Defender checks and Quick scan (5 minutes)

Say: "Now let us wake up the guard dog and see if it is awake."

1. Open **Start**, search **Windows Security**, open it.
2. Click **Virus & threat protection**.
3. Show "**No current threats**" (or whatever the real status is).
4. Under **Virus & threat protection settings**, click to show **Real-time protection: On**. Explain: "This is the guard standing awake at the door."
5. Click **Quick scan**. While it runs, explain what it is checking (common locations where malware hides).
6. When finished, show the result: "No current threats found" (or the found items and their **Actions**).

Expected result: A completed Quick scan with a clear result line. **What to watch:** If a threat appears, do not panic â€" show how to read the item name and the **Action** (Quarantine/Remove) and note that the instructor handles the action on lab machines. **Questions:** "What is the difference between real-time protection and a scan?" â†' one watches continuously, the other checks on demand. "Does Defender replace the firewall?" â†' no, different jobs.

G.4 Demonstration 3 â€" Firewall and UAC (4 minutes)

Say: "Now the gate keeper, and a look at the seat belt."

1. In **Windows Security**, click **Firewall & network protection**.
2. Show whether the firewall is **On** for the current network, and show the three profiles (Domain/Private/Public).
3. Explain the current profile: "If I am on cafÃ© Wi-Fi, Windows treats it as Public and is stricter."
4. **UAC:** open an app or setting that triggers a UAC prompt (e.g., opening a system tool). When the prompt appears, do **not** click Yes immediately. Walk the three questions: What is asking? Why now? Who published it? Then choose the correct answer (usually Yes for a tool you deliberately opened).

Expected result: The learner sees the firewall status and a real UAC prompt. **What to watch:** Do not actually change firewall settings on a managed machine unless authorised; demonstrate reading, not breaking. **Questions:** "What does the firewall stop?" â†' unsolicited incoming connections. "What would a sudden UAC prompt mean?" â†' something unexpected is trying to install â€" a red flag.

G.5 Demonstration 4 â€" Startup apps (2 minutes)

1. Open **Task Manager** (`Ctrl + Shift + Esc`) â†' **Startup apps** (or **Settings â†' Apps â†' Startup**).
2. Show the **Startup impact** column.
3. Point at one low-impact, non-security app and show where the **Disable** option is (but only disable if this is a demonstration machine and it is safe).
4. Warn: "Never disable something you do not recognise â€" it could be your security or a driver."

Expected result: Learner sees how to review and disable a startup app safely. **Questions:** "Does disabling delete the program?" â†' no, it only stops auto-start.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: On the learner's **own or authorised practice Windows machine**, check update status, confirm Defender real-time protection is on, run a Quick scan, and verify the firewall is on â€" with the instructor guiding step by step.

Starting materials: One authorised Windows 10/11 machine per learner or pair. Worksheet 5.1. The instructor manages any admin steps.

> ***Permission and safety reminder (say before starting):*** *"Only work on your **own** machine or an academy practice machine. Do not change settings on a shared machine without permission. We are reading status and making our own device safer â€" nothing more."*

Procedure (instructor calls each step; learners follow; instructor walks the room):

1. **Check Windows Update.** Press `Windows key + I` â†' **Windows Update**. Read the status. Click **Check for updates** if internet is available. On Worksheet 5.1, write the status: "Up to date" or "X updates pending".
2. **Decide about restarting.** If it says **Restart required**, note it. **Save all your work first.** Restart only with the instructor's go-ahead.
3. **Pause and predict:** "If there is a pending security update and I keep pressing Later, what is happening to my machine?" (Answer: it keeps the known hole open.)
4. **Open Defender.** Start â†' search **Windows Security** â†' open it.
5. **Confirm real-time protection.** Go to **Virus & threat protection** â†' check **Real-time protection: On**. Record it on the worksheet.
6. **Run a Quick scan.** Click **Quick scan**; wait for it to finish; record the result ("No current threats" or the items found).
7. **Pause and predict:** "What is the difference between the scan we just ran and the real-time protection that is always on?" (Answer: on-demand vs continuous.)
8. **Check the Firewall.** In Windows Security, open **Firewall & network protection**; note the current network profile and whether the firewall is **On**. Record it.
9. **Check your account type.** Settings â†' **Accounts â†' Your info** (wording may vary); note whether your daily account is **Administrator** or **Standard user**.
10. **Review startup apps.** `Ctrl + Shift + Esc` â†' **Startup apps**; note any high-impact apps you could safely disable later (do not disable anything you do not recognise).

Expected result: Worksheet 5.1 filled in with: update status, restart-needed (yes/no), Defender real-time protection On, Quick scan result, firewall On, account type, and one startup observation.

Points to pause and predict:

- After Step 1: "Why do we not just ignore updates?" â†' known holes stay open.
- After Step 6: "If the scan finds nothing, does that mean we are 100% safe?" â†' no; defence in depth and safe habits still matter.

Troubleshooting while walking the room:

- "Windows Security" not found â†' it may be called **Windows Defender Security Center** on older builds; search "Defender" too.
- Some settings greyed out â†' a managed/admin policy controls it; that is normal on academy machines â€" record what you see.
- Quick scan takes long â†' let it run; if time is short, note it is running and continue.
- No internet â†' updates cannot check; record "unable to check â€" offline" and note the skill is the same once online.

Completion checklist (learner ticks each):

- ☐ Windows Update status checked and recorded
- ☐ Restart-needed noted (and work saved)
- ☐ Defender opened
- ☐ Real-time protection confirmed On
- ☐ Quick scan run and result recorded
- ☐ Firewall confirmed On
- ☐ Account type identified
- ☐ One startup program reviewed

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: Apply the hardening checklist to the **fictional small business scenario below**, producing a **prioritised hardening plan** and a filled **checklist** you would give the owner â€” without touching any real system.

Scenario: *Ada's Fashion & Fabrics* is a small shop in Port Harcourt with **one shop computer** running Windows 11. The owner, Ada, uses it for:

- checking the business email (supplier invoices),
- browsing and online banking,
- keeping a simple customer list in a spreadsheet,
- the POS software.

Ada tells you: "Sometimes it's slow. I keep clicking 'Later' when the update box comes. I don't know if any security is on. My nephew installed some free download accelerator a while ago. Everyone uses the same account, and it's an admin account."

Given facts:

- Windows 11, single shared computer.
- Updates repeatedly postponed.
- Unknown antivirus/Defender status.
- Some free software installed from a random link.
- One shared **administrator** account.

Your tasks (produce on paper or a document):

1. List the hardening problems you can identify from Ada's description (at least five).
2. For each, write **what to check** and **what to fix**, in plain words Ada can understand.
3. Give each fix a **priority** (High / Medium / Low) and one sentence saying **why**.
4. Fill in a **hardening checklist** with checkboxes that Ada could follow on the computer.
5. Add a short "safe habits" note (2â€“3 lines) so the fixes are not undone by behaviour.

Time allowance: 15 minutes.

Success criteria:

- At least five correctly identified problems.
- Fixes match the correct Windows feature (Update / Defender / Firewall / accounts / software source / startup).
- Priorities are sensible (updates and antivirus/firewall are High).
- The checklist is genuinely usable by a non-technical owner.

Hints available if stuck:

- Hint 1: Think of the four layers: updates, antivirus, firewall, app control/accounts.
- Hint 2: "Free download accelerator from a random link" points at **unsafe software sources**.
- Hint 3: "Everyone uses the same admin account" points at **standard vs admin accounts**.

Instructor answer key (do not show learners):

Problems (model list):

1. Updates repeatedly postponed â†' **known vulnerabilities left open** (High).
2. Defender/antivirus status unknown â†' could be off or out of date (High).
3. Firewall status unknown â†' gate keeper may be off (High).
4. Free software from a random link ("download accelerator") â†' likely unwanted/malicious software (High; scan and remove, then re-check source).
5. Single shared **administrator** account â†' any mistake or malware has full power (High/Medium; create a standard daily account).
6. (Bonus) Machine is slow â†' too many startup apps or unwanted software; review **Startup apps** (Medium).

Fixes & priorities (model):

Problem	Check	Fix	Priority	Why
Updates postponed	Windows Update status	Enable automatic updates; apply and restart	High	closes known attack holes

Problem	Check	Fix	Priority	Why
Defender unknown	Virus & threat protection	Confirm real-time protection On; run scan	High	stops malware
Firewall unknown	Firewall & network protection	Turn firewall On	High	blocks unsolicited connections
Unsafe free software	Installed apps / scan result	Scan, remove if unwanted; reinstall only from official source	High	likely malware
Shared admin account	Accounts â†' Your info	Create a standard account for daily use	High/Medium	limits damage
Slow PC	Startup apps	Disable unneeded startup apps	Medium	tidiness/performance

Hardening checklist (model):

- ☐ Windows Update set to automatic and "You're up to date"
- ☐ Defender real-time protection On; Quick scan clean
- ☐ Firewall On
- ☐ Only software from official sources installed; no cracked apps
- ☐ Daily account is a Standard user
- ☐ Startup apps reviewed

Safe habits note: "Save work before restarting updates; read every UAC prompt; do not install 'free' tools from random links; only the owner uses the admin account for real changes."

Marking guidance (out of 10):

- Five-plus problems correctly identified (3)
- Correct fixes matched to Windows features (3)
- Sensible priorities with reasons (2)
- Usable checklist (1)
- Safe-habits note (1)

J. REAL-WORLD CASE STUDY

Situation (fictional, non-identifying). A small private school in Rivers State â€" call it *Bright Futures Academy* â€" runs its fee records, results and staff email on **five Windows computers** in the admin office. There is no IT officer; the bursar "manages" the computers between other duties.

What happened. Over a term, staff noticed machines getting slower. One morning, three computers showed a message demanding payment in a cryptocurrency to unlock encrypted files (a **ransomware** attack). The fee records for the term were encrypted and unreadable. The bursar admitted the machines had **not been updated for over a year** ("the update box was always in the way"), the same **admin account** was used by all five staff, and a staff member had recently installed a **"free typing tutor"** from a link in an email.

Relevant facts.

- No updates for a year â†' many known vulnerabilities left open.
- Shared **administrator** account â†' malware had full power.
- Software from an unofficial link â†' probable entry point.
- No clear antivirus/firewall check habit; no backups known to be tested (backups are Session 6's topic, but note the link).

Decision point. The attack has already happened. But the school now asks: *what device-hardening changes would prevent this next time?* (The immediate incident response â€" isolate, report, restore â€" is covered in Session 8; here we focus on hardening.)

Possible approaches.

1. Reinstall Windows, change nothing else, and hope it does not happen again.
2. Buy expensive third-party security software and do nothing else.
3. Apply the **four layers**: turn on and apply **automatic updates**, confirm **Defender real-time protection + regular scans**, confirm the **firewall is on**, move daily work to a **standard account**, allow software only from **official sources**, and review **startup programs**.

Recommended solution. Approach 3. It uses the protections already built into Windows, costs nothing extra, and addresses the *actual* causes: unpatched holes, full-power accounts, and unsafe software. Combined with the backups taught next session (tested restores), it makes a repeat far harder and the damage far smaller.

Trade-offs.

- Approach 1 is quick but leaves every cause in place â€" high chance of repeat.
- Approach 2 may help, but buying more software while leaving updates off and everyone on admin is like buying a guard dog and leaving all the doors open.
- Approach 3 needs some setup time, a small change in habit (standard accounts, restarts), and one person responsible â€" but it fixes the root causes and uses free built-in tools. Its cost is *discipline*, not money.

Professional connection. This is exactly what an entry-level IT/security support person does: **check patch status, confirm antivirus and firewall, apply least privilege (standard accounts), and control software sources.** These are core junior cyber-support tasks and appear directly in the Week 3 assessment checklist. It also shows why **backups** (next session) are the safety net when prevention fails.

K. COMMON MISTAKES AND TROUBLESHOOTING

Use as the live troubleshooting guide. Ask the learner to check the relevant row before giving the answer.

K.1 "I keep clicking 'Later' on updates"

Symptoms: Device shows pending updates for weeks; restart reminders ignored. **Likely cause:** Inconvenience â€" not wanting the interruption. (Confirmed once you see the pending list and repeated postponements.) **How to investigate:** Windows Update â†' check history and pending list. **Safe corrective steps:** Save work, apply updates, restart; enable automatic updates so it happens without reminders. **How to confirm resolved:** Status shows "You're up to date". **How to prevent recurrence:** Schedule a regular low-use time for updates (e.g., end of day).

K.2 "Real-time protection is off"

Symptoms: Defender shows real-time protection Off (often with a warning). **Likely cause:** Someone disabled it (sometimes to install software, or malware did it). **How to investigate:** Windows Security â†' Virus & threat protection â†' settings. Check for any admin policy. **Safe corrective steps:** Turn it back On (admin may be needed); run a scan; if malware is found, act on the result. **How to confirm resolved:** Real-time protection shows On; a scan is clean. **Prevention:** Do not disable it; if a trusted technician asks, re-enable straight after.

K.3 "The firewall is off for my Wi-Fi"

Symptoms: Firewall & network protection shows the active profile Off. **Likely cause:** Changed manually, or by another program, or a network profile change. **How to investigate:** Check which profile (Domain/Private/Public) is active and its status. **Corrective steps:** Turn it On; if greyed out, an admin policy controls it â€" escalate. **How to confirm resolved:** Active profile shows On. **Prevention:** Never turn the firewall off to "fix" a connection; ask what is actually blocked.

K.4 "A UAC prompt appeared and I clicked Yes without reading"

Symptoms: Unexpected admin prompt accepted; possibly new software or changed settings. **Likely cause:** An unexpected program (possibly malware) requested admin rights. **How to investigate:** Review recently installed programs and running processes; run a Defender scan; check startup apps. **Safe corrective steps:** Remove anything you did not install; run a scan; if unsure, escalate to the instructor/IT. **How to confirm resolved:** No unknown programs; scan clean. **Prevention:** Always read the prompt's three questions (What? Why now? Who?).

K.5 "My PC is slow, so I installed a 'cleaner'"

Symptoms: Slowness; a random "optimizer" or "accelerator" installed from a link. **Likely cause:** Untrusted software (often bundled with unwanted extras or malware). **How to investigate:** Check installed apps and startup apps; run a scan. **Safe corrective steps:** Uninstall unknown tools; scan; disable unneeded startup apps. **How to confirm resolved:** Startup list is tidy; scan clean; machine faster. **Prevention:** Only install from official sources; avoid "free cleaner" links.

K.6 "Windows Security will not open or is showing red"

Symptoms: Windows Security app fails to open, or shows red warnings. **Likely cause:** A third-party antivirus is managing protection, or malware is interfering, or a system issue. **How to investigate:** Check whether another antivirus is installed; try again after a restart; check for admin policy. **Safe corrective steps:** If another AV is present, that may be intended â€" confirm with the owner/IT. If malware is suspected, run an offline scan (Defender's **Microsoft Defender Offline scan**) with permission. **How to confirm resolved:** Windows Security opens and shows green/expected state. **Prevention:** Keep one antivirus; keep updates current.

Distinguish likely vs confirmed: Each "likely cause" becomes "confirmed" only after checking â€" e.g., seeing the actual toggle state, the installed-app list, or the scan result. Teach learners to verify before concluding.

L. SESSION ASSIGNMENT

Assignment title: "Home Device Hardening Report"

Purpose: Practise applying the four hardening layers (updates, antivirus, firewall, accounts/software) to a real device the learner is authorised to use, and communicate the findings and fixes in plain language â€" the same skill needed for the capstone report in Week 3.

Realistic scenario: You have been asked to check a **family or personal Windows computer** (one you have permission to use) and write a short hardening report for the owner.

Detailed instructions:

1. On a Windows 10/11 machine you are **authorised** to use, complete the following checks and record the actual result:
   - Windows Update status (up to date? pending? restart needed?).
   - Defender **real-time protection** (On/Off) and a **Quick scan** result.
   - **Firewall** status for the active network.
   - The account type used daily (Administrator / Standard user).
   - One observation about **startup programs**.
2. Identify at least **three** hardening improvements and write a plain-language fix for each.
3. Give each improvement a **priority** (High/Medium/Low) with a one-line reason.
4. Write a **5-step "What to do" checklist** the owner can follow.
5. Add a **privacy note**: do not record any passwords, personal files, or other people's data; describe only the security settings.

Required deliverables:

- `session5-assignment/hardening-report.md` (or a typed page/photo).
- `session5-assignment/hardening-checklist.md`.

Submission format: In the class folder, or a photo of a handwritten report in your workbook.

Deadline: Before Session 6.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Accurate checks recorded	5	Real update/Defender/firewall/account results
Correct problem identification	4	At least three genuine hardening gaps
Correct fixes & priorities	4	Fix matches feature; sensible priority + reason
Usable owner checklist	3	Clear steps a non-technical person can follow

Criterion	Marks	Description of a strong answer
Plain-language clarity	2	No unexplained jargon
Professionalism & privacy	2	No personal data recorded; authorised device only

Common mistakes to avoid: recording guesses instead of actual status; turning off real-time protection to "speed things up"; mixing up firewall (network) with antivirus (files); forgetting to restart after an update; including personal data.

Instructor reference solution (model):

Sample findings: Update status "3 updates pending, restart required" â†' **High** (known holes open). Defender real-time protection "On", Quick scan "No threats" â†' **good, note as OK**. Firewall "On (Public)" â†' **OK**. Daily account "Administrator" â†' **Medium** (create a standard account). Startup: "6 apps enabled, 2 high impact" â†' **Low/Medium** (disable unneeded).

Sample checklist: 1) Open Settings â†' Windows Update, click Check for updates, restart when prompted after saving work. 2) Open Windows Security â†' Virus & threat protection, confirm Real-time protection is On, run Quick scan. 3) Open Firewall & network protection, confirm firewall On. 4) Create and use a Standard account for daily work. 5) Review Startup apps and disable ones you do not need.

Privacy note (model): "I did not record passwords or any personal files; I only listed security settings and app names."

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key.)

Q1. Multiple choice. What is the main reason to install Windows updates regularly? a) To change the wallpaper. b) To fix known security holes (vulnerabilities). c) To make the internet faster. d) To increase the hard disk size.

Q2. Short answer. What is the difference between **real-time protection** and **running a scan** in Windows Defender?

Q3. Explain in your own words. What does the **firewall** do, and how is it different from antivirus?

Q4. True or false, with a reason. "Using a standard (non-administrator) account for everyday work is safer than using an administrator account."

Q5. Practical identification. A box appears saying "Do you want to allow this app to make changes to your device?" You did not open any app. What should you do, and why?

Q6. Fill in the blanks. Four layers of defence in depth are: keep the OS ____; keep ____ (antivirus) awake; keep the ____ on; and control what ____ and who has ____ rights.

Q7. Scenario. A friend's PC is slow and they want to install a "free PC cleaner" from a random website. Using today's lesson, what do you advise, and what should they check instead?

INSTRUCTOR ANSWER KEY (Q1â€"Q7)

A1. (b) To fix known security holes (vulnerabilities). **A2.** Real-time protection watches files **continuously**, as they open/download/run, and blocks threats immediately; a **scan** is an **on-demand** check of the device (e.g., Quick or Full scan) that you start yourself. **A3.** The firewall is a **gate keeper** that filters **network connections** going in and out of the computer, blocking unsolicited incoming connections. Antivirus looks for **malicious files** and programs. They do different jobs and work together. **A4.** True. A standard account cannot install software or make deep system changes without an admin prompt, so malware and mistakes are limited. The admin account should be used only when real changes are needed. **A5.** Do **not** click Yes. An unexpected admin prompt when you started nothing is a **red flag** â€" something (possibly malware) is trying to make changes. Read the prompt (What? Why now? Who?), and if it is not something you chose, click **No** and investigate/scan. **A6.** keep the OS **updated**; keep **Windows Defender** (antivirus) awake; keep the **firewall** on; control what **apps run/install** and who has **administrator** rights. (Accept equivalent wording.) **A7.** Advise **against** installing the "free cleaner" from a random site â€" such tools are often unwanted or malicious. Instead, check: Windows Update status, run a Defender scan, review **Startup apps** and disable unneeded ones, and remove any unknown installed software. Only install software from **official sources**.

N. REFLECTION AND RECAP

Plain-English summary. Today we hardened the device itself. An un-updated computer is like a house with a broken window â€" attackers know exactly where the holes are, so we apply **Windows updates** (and turn on automatic updates, restarting when asked). **Windows Defender** is the built-in antivirus; we confirmed **real-time protection is On** and ran a **Quick scan**. The **Windows Firewall** is the gate keeper that filters network connections, and we confirmed it is On. We learned that a **standard account** limits the damage a mistake or malware can do, and that we must **read every UAC prompt**. We also learned to use only **official software sources**, to review **startup programs**, and why all of this together is called **defence in depth** â€" because antivirus alone is not enough.

Five important takeaways:

1. **Updates** fix known holes â€" turn on automatic updates; restart when asked.
2. **Defender real-time protection** is the guard dog â€" confirm it is On and scan regularly.
3. The **firewall** is the gate keeper for network connections.
4. Use a **standard account** daily and **read every UAC prompt**.
5. Install software only from **official sources**; **defence in depth** beats any single tool.

Questions to help you recognise what you can now do:

- Can I check Windows Update and explain why a restart matters?
- Can I confirm Defender real-time protection is on and run a Quick scan on my own?
- Can I check the firewall status and explain what it does?
- Can I explain in plain words why antivirus alone is not enough?

Connection to the next session: We have hardened the computer, but what about the network it connects to and the phone in your pocket â€" and what happens if prevention still fails? Next session, **Wi-Fi Security, Mobile Safety and Backups**, we secure the router, protect the mobile device, and build the safety net â€" **backups** â€" so that even if a device is lost, stolen or infected, your important files survive. Remember: *a backup you have never restored is not a backup*.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- The learner navigates to Windows Update, Defender and Firewall unaided (or with minimal prompting) and reads the real status.
- The learner explains *why* updates matter in terms of known vulnerabilities, not just "it's good".
- The learner distinguishes real-time protection from an on-demand scan.
- The learner distinguishes firewall (network) from antivirus (files).
- The learner reads a UAC prompt before deciding, and can state the three questions.
- The learner can name the four layers of defence in depth.

Common misconceptions to watch for and correct:

- "Updates are optional/annoying." â†' They close known holes; automatic updates remove the burden.
- "Antivirus is enough." â†' Defence in depth; layers matter.
- "Firewall and antivirus are the same." â†' Network gate keeper vs file scanner.
- "Admin is always better." â†' Least privilege: standard for daily use.
- "Clicking Yes on a UAC prompt is always fine." â†' Read it; a surprise prompt is a red flag.

Suggested remedial exercises for learners who struggle:

1. **Location drill:** give five tasks ("check firewall", "run a scan"â€¦) and have the learner write the exact path from the Start menu for each.
2. **Layer sorting:** provide ten controls (e.g., "restart after update", "block incoming connection") and have learners sort each under Updates / Antivirus / Firewall / Accounts.
3. **UAC role-play:** present three UAC scenarios (a tool you opened; a sudden prompt; a game installer from a random site) and ask the learner what to click and why.

4. **Plain-English drill:** the learner explains "defence in depth" to a partner pretending to be a non-technical shop owner.

Differentiation:

- **Level 1 (supported):** Provide a pre-filled report template with tick-boxes and sentence starters; the learner only fills in the actual status values.
- **Level 2 (standard):** The exercises as written.
- **Level 3 (challenge):** Have the learner analyse a machine with a *third-party antivirus* installed and explain how Windows Security behaves when another antivirus manages protection; also design a simple update-and-scan schedule for a small shop and justify it.

Timing guidance: If the room is slow, shorten the case study (Section J) to a 3-minute mention and protect the guided practical (Section H) â€" the hands-on checks are the priority. Warn learners early that a restart may be needed, so they save work. If the room is fast, extend the independent exercise with a second scenario (a phone-only learner describing how they would apply the same principles on Android/iOS, previewing Session 6).

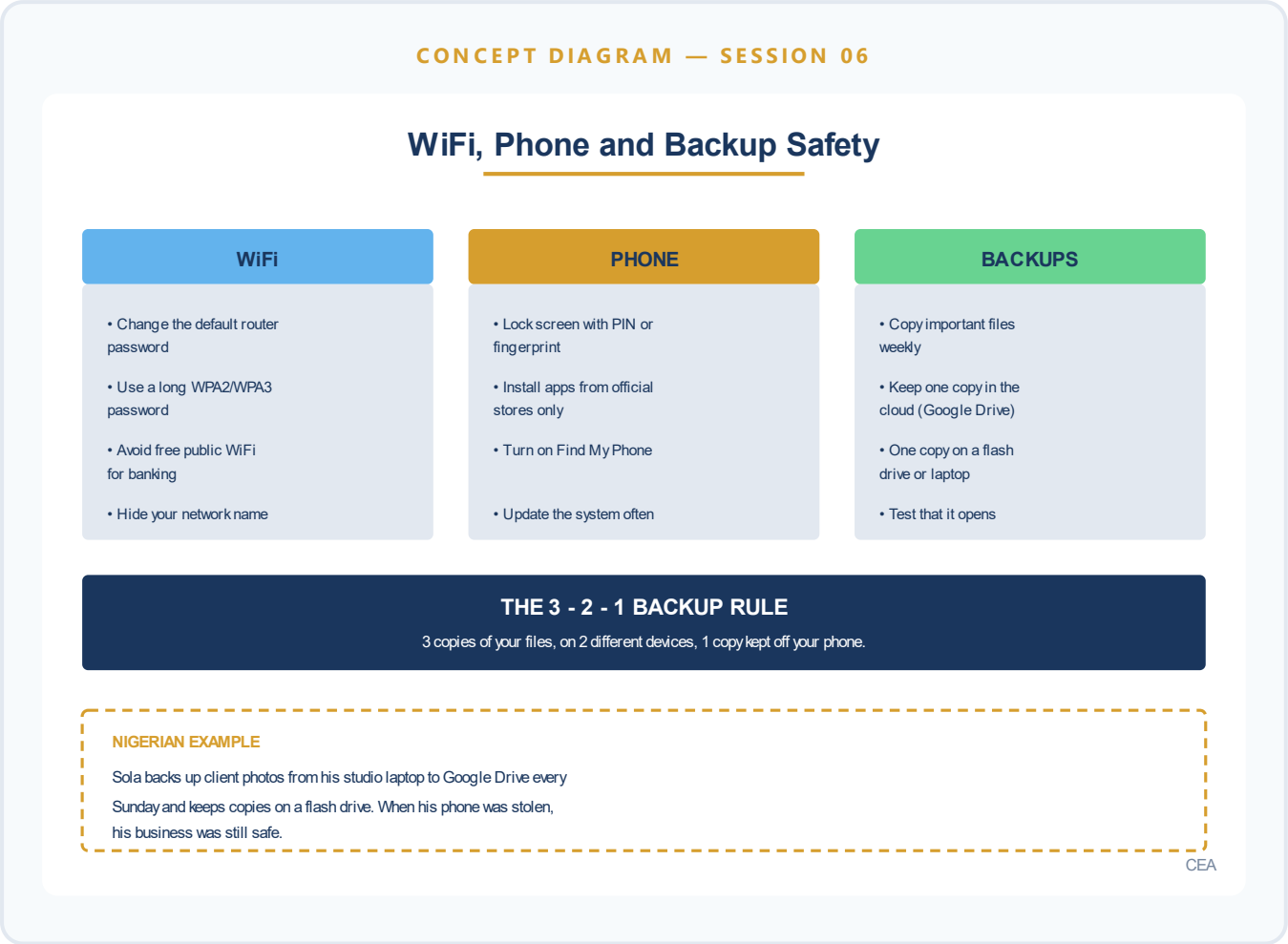
END OF SESSION 5

Next: Session 6 â€" Wi-Fi Security, Mobile Safety and Backups.

SESSION 06 OF 9

WiFi Mobile Backups

CONCEPT DIAGRAM — SESSION 06



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 6 â€" WI-FI SECURITY, MOBILE SAFETY AND BACKUPS

A. SESSION IDENTIFICATION

Item	Detail
Session number	6 of 9
Session title	Wi-Fi Security, Mobile Safety and Backups
Week / Module	Week 2 â€" Module 2: Protecting People and Devices (theme: **Harden**) â€" final session of Week 2
Recommended duration	105 minutes
Difficulty level	Beginner (no prior security knowledge assumed)

Item	Detail
Prerequisite knowledge	Sessions 1â€"5. In particular: strong passwords + MFA (S2), safe browsing and HTTPS (S3), phishing (S4), and device hardening â€" updates, Defender, firewall (S5).
Connection to previous work	We have protected accounts, people and the computer itself. This session closes the loop in three ways: secure the **network** the computer uses (Wi-Fi/router), secure the **phone** in every pocket (mobile safety), and build the **safety net** so that even if a device is lost, stolen or infected, the important files survive (**backups**).
Preparation before class	Academy PCs on. Instructor machine for demonstrations. An **external USB drive/flash drive or a spare folder** for the backup demonstration. If demonstrating router settings, use a **practice/fictional router interface** or the instructor's own home router *screenshots described verbally* â€" never change a live router the class depends on, and never change a router the learner does not own. Learners need a USB drive or access to an external drive/folder for the practical.
Safety / permission note (read aloud)	"We only change settings on networks and devices we **own or have written permission to change**. We never touch someone else's router, and we never try to access anyone else's Wi-Fi. All practical backup work uses **your own** harmless practice files â€" never other people's private data. This is defensive work: we protect, we do not intrude."

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Explain** why Wi-Fi encryption (WPA2/WPA3) matters and describe what happens to data on an open network.
2. **List and explain** the key router hardening steps: change the default admin password, set a strong Wi-Fi password, turn off WPS, and enable a guest network.
3. **Describe the risks of public Wi-Fi** and state what they should avoid doing on it.
4. **Apply mobile safety basics**: screen lock, reviewing app permissions, updating apps, using only official app stores, enabling find-my-device, and avoiding sideloaded/cracked apps.
5. **Explain the 3-2-1 backup rule** in simple words: 3 copies, 2 different media, 1 offsite.
6. **Decide what is worth backing up** and compare cloud, external drive and USB options with their trade-offs.
7. **Explain why a backup must be tested** ("a backup you have never restored is not a backup") and describe how to test a restore.
8. **Build a backup plan** for a small business and **perform a folder backup to an external drive/USB and restore one file**.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops or the learner's own laptop with permission).
- An **external drive or USB flash drive** per learner or pair for the backup practical. (A spare practice folder will do if drives are limited, but a real external/USB device is strongly preferred so learners feel the real process.)
- Instructor computer connected to a projector or large screen.

Software

- Windows 10/11 (for the backup practical). A browser for looking at router help pages (optional).
- No hacking or Wi-Fi "cracking" tools of any kind. This course is defensive only.

Accounts

- No online accounts required. If the instructor wishes to show cloud backup options (e.g., OneDrive/Google Drive), they use their **own** demo account only.

Worksheets

- Worksheet 6.1 â€" "Router Hardening Checklist".
- Worksheet 6.2 â€" "My 3-2-1 Backup Plan" (learner workbook, Part 3).
- Worksheet 6.3 â€" "Mobile Safety Audit" (for learners' own phones, with privacy).

Tools

- Windows File Explorer (for copy/restore). Optionally a USB drive.
- The learner's own mobile phone for the mobile-safety audit (read-only checks; no data is collected or shared).

Internet

- Not required. If available, the instructor may show a router's help page or a cloud provider's backup explanation, but the session works fully offline using local drives.

Alternative for learners who lack a facility

- A phone-only learner can complete the mobile safety audit and the backup plan on paper, and pair with a desktop user for the physical backup/restore. Router hardening can be taught as a checklist to apply at home.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: On the projector, show two Wi-Fi networks in the list: one named **"ShopWiFi"** (open, no lock icon) and one named **"ShopWiFi-Secure"** (with a padlock). Do not connect to either. Just point.

What the instructor says:

> *"Look at these two Wi-Fi names. This one, 'ShopWiFi', has no padlock â€" it is open. Anyone nearby can join, and anything sent on an open network can be seen or changed by someone on the same network. This other one has a padlock and a password â€" that is encryption.*
>
> *Now think of your phone. Your whole life is in it â€" bank app, WhatsApp, photos, contacts. And now think of the folder on your computer with your shop records. If this laptop is stolen tonight, or a ransom attack locks your files, what happens to that folder? ... For many people, it is gone forever.*
>
> *Today we close three gaps: the **network** you connect to, the **phone** you carry, and the **backup** that saves you when everything else fails."*

Expected learner response: Learners may say they have used open Wi-Fi before ("at the market", "in a cafÃ©"), or admit they have never made a backup. Some may not know their router password. Accept all; make it clear this is common and fixable.

Then demonstrate the hook: On the projector, open a folder of harmless practice files (e.g., "CEA Practice Files") on the Desktop. Copy it to a USB drive, then delete one file from the original folder and show how it can be **restored from the USB copy** in seconds.

> *"Watch: I made a copy, then 'lost' a file, then got it back from the backup in one step. That is the whole idea. Simple â€" but most people never do it, and pay a heavy price later."*

Why this opener works: It uses the familiar Wi-Fi list to make "encryption" visible, connects the phone and the shop records to a concrete loss the learner can imagine, and ends with a live, satisfying restore that proves the value of backups in seconds.

E. PREREQUISITE REVIEW (7 minutes)

Run as an oral round-robin. Put the questions on the projector.

Question 1: "From Session 5, name two device-hardening layers and say what each does."

- Expected answer: e.g., updates fix known holes; Defender antivirus finds malware; firewall filters network connections; standard account limits damage.
- Common gap: mixing up firewall and antivirus. Re-clarify: firewall = network gate keeper; antivirus = file scanner.

Question 2: "Why is a unique strong password important, and what adds a second lock?"

- Expected answer: so one leaked site does not unlock your other accounts; MFA adds a second factor.
- Common gap: password reuse. Re-state: reuse is the chain that breaks everything.

Question 3: "From Session 3, what does a padlock in the browser mean, and what does it *not* mean?"

- Expected answer: the connection is encrypted/private; it does **not** mean the site owner is honest.
- Common gap: equating padlock with trust. This links directly to today's Wi-Fi encryption idea.

Bridge to today (say this):

> *"We have hardened the computer. But three things remain: the **network** it joins, the **phone** we carry everywhere, and our **last line of defence** â€" the backup. Remember the school case from last time? Prevention is best, but backups are what let you recover even when prevention fails. Today we protect all three."*

If more than a third of the class cannot name two hardening layers, spend 3 extra minutes re-teaching them before continuing.

F. FULL LECTURE NOTES

F.1 Wi-Fi security basics â€" encrypting the air

Plain-English definition. Wi-Fi security means protecting the data that travels wirelessly between your device and the router so that other people nearby cannot read or change it.

Why it exists. Wi-Fi travels through the air as radio waves. On an **open** network (no password), the data is like a postcard â€" anyone nearby with the right tool can read it. With encryption, the data is like a sealed, coded letter â€" even if someone intercepts it, they cannot read it.

The standards (just enough):

- **WPA2** â€" strong encryption; the common secure standard for years. Uses AES encryption.
- **WPA3** â€" the newer, stronger standard; better protection, especially against guessing the Wi-Fi password. If your router supports it, prefer it.
- **WEP** â€" very old and weak; should **not** be used. If your router only offers WEP, it is old and should be replaced or configured carefully.
- **Open / no security** â€" no encryption; avoid for anything private.

The analogy. WPA2/WPA3 are like a **strong safe** for the messages in the air; WEP is like a paper envelope someone can easily open; an open network is a postcard anyone can read.

A realistic Nigerian scenario. A POS operator runs an open Wi-Fi "to help customers". A nearby attacker on the same network watches traffic and redirects a customer to a fake page. Had the Wi-Fi used WPA2/WPA3 with a strong password, the traffic would have been encrypted and far harder to read or redirect.

Misconception. "My Wi-Fi has a password, so it is fully safe." A password protects *joining* the network and encrypts traffic only if the security type is WPA2/WPA3. Also, a weak Wi-Fi password can be guessed. The *type* of security matters, not just the presence of a password.

Limitation. Wi-Fi encryption protects the *air link* between your device and the router. It does not protect you from a malicious website you choose to visit, or from malware. It is one layer.

F.2 Router hardening â€" locking the front gate

The **router** is the device that brings the internet to your home/shop and shares it out. It is the front gate. Hardening it is one of the highest-value, lowest-cost security steps â€" and it is done **once**, then mostly forgotten.

Step 1 â€" Change the default router admin password. Every router ships with a default admin username/password (often "admin/admin"), printed on a sticker or in the manual, and known to attackers. If you never change it, anyone on your network (or even remotely, in some cases) can log in and change your settings. **Change it to a strong, unique password** and store it safely.

Step 2 â€" Set a strong Wi-Fi password. The Wi-Fi password (the one you give guests) must be long and not guessable. A short password like "12345678" or the shop name can be guessed. Use a long passphrase (several words) â€" remember the idea from Session 2.

Step 3 â€" Turn off WPS. WPS (Wi-Fi Protected Setup) is a feature meant to make connecting easy, often via a button or a PIN. Its PIN method has known weaknesses and can be abused. **Turn WPS off** unless you truly need it.

Step 4 â€" Use a guest network. Most modern routers let you create a **guest network** â€" a separate Wi-Fi for visitors, customers and smart devices. Guests get internet but cannot reach your main devices (your shop computer, your files). This is like keeping visitors in the sitting room instead of letting them roam the whole house. If your router supports it, enable it; use the guest network for customers and unknown devices.

Optional good practices: keep the **router firmware updated** (check the manufacturer's app/admin page), and change the default **network name (SSID)** so it does not reveal the router model. (Renaming is a small benefit; the password and WPS matter more.)

The analogy. The router is the **gate to your compound**: the Wi-Fi password is the lock on the gate; the admin password is the lock on the control room; WPS-off removes a spare hidden key under the mat; the guest network is a separate visitors' area.

How to access router settings (general guidance only): You usually open a browser and go to the router's admin address (often printed on the sticker, e.g., `192.168.0.1` or `192.168.1.1`), then log in. **Wording and layout differ by brand** â€" the instructor should tell learners: "the exact menu names vary, look for Security / Wireless / WPS / Guest Network options." Do not change a router you do not own or are not authorised to change.

Realistic Nigerian scenario. Many homes and small shops never change the router admin password. When the router is replaced or returned after repair, or when a neighbour or a visitor knows the default, settings can be changed without the owner's knowledge. Changing the admin password and disabling WPS takes ten minutes and closes this.

Misconceptions.

- "The default is fine, nobody knows it." Attackers and manuals know it; it is published.
- "WPS is convenient, I will leave it on for guests." Convenience for you is also convenience for an intruder; turn it off.
- "Guests only need internet, they won't touch my files." Without a guest network, guests are on the same network as your devices.

Limitation. Router hardening protects your home/shop network. It does not protect you when you join *someone else's* network (public Wi-Fi), which is why Section F.3 matters.

F.3 Public Wi-Fi risks â€" and what to avoid

Plain-English definition. Public Wi-Fi is a wireless network you do not control, such as in a cafÃ©, hotel, airport, or at an event. You cannot see who else is on it or how it is configured.

The risks.

- **Snooping** â€" on an open network, others may be able to observe unencrypted traffic.
- **Fake hotspots** â€" an attacker sets up a network with a tempting name ("Free Airport WiFi") so devices connect to *their* network instead.
- **Rogue redirects** â€" being sent to a fake login page to steal details.

The analogy. Using public Wi-Fi is like making a phone call in a crowded market â€" someone may be listening. Using mobile data (your GSM network) or a trusted network is like a private line.

What to avoid on public Wi-Fi (teach this list):

- **Banking and mobile-money transactions** â€" avoid, if possible, unless you are on mobile data or a trusted network.
- **Entering passwords or card details** on pages you do not absolutely trust.
- **Accessing sensitive work systems** without an approved secure method (e.g., a company VPN).
- Connecting automatically to unknown networks â€" **turn off "auto-connect to open networks"** on your phone.

What to do instead (defensive):

- Use **mobile data** (your SIM data) for anything sensitive.
- If you must use public Wi-Fi, prefer networks **you or your organisation control**, and use **HTTPS** sites (padlock) â€" though remember from Session 3 that a padlock is only one clue.
- If your workplace provides a **VPN**, use it, and follow your organisation's rules.

- **Forget the network** after use, and avoid saving auto-connect.

Misconception. "Public Wi-Fi is safe if it asks for a password." A password you are given for a cafÃ© network does not make it private or trustworthy; everyone in the cafÃ© has it.

Limitation. You can reduce public-Wi-Fi risk but never fully trust it. The safest habit is to keep sensitive activity on mobile data or trusted networks.

F.4 Mobile security â€" protecting the phone in your pocket

The phone is often the most important and least-protected device we own. It holds bank apps, WhatsApp, photos and contacts. The same Stopâ€"Thinkâ€"Verify mindset applies, plus a few mobile-specific controls.

1. Screen lock. Set a **PIN, password, pattern, or biometric** (fingerprint/face) lock with a short auto-lock time (e.g., 30 seconds). This is the first barrier if the phone is lost or stolen. Avoid obvious PINs (birthdates, `0000`, `1234`).

2. App permissions. When you install an app, it asks for permissions (camera, microphone, location, contacts, files, SMS). Give **only what the app truly needs** for its job. A torch app does not need your contacts; a simple game does not need your SMS. Review permissions in your phone's settings and revoke anything unnecessary.

3. Update apps and the phone. Keep both the **operating system** and the **apps** updated â€" the same "broken window" logic as Session 5. Updates fix known security holes in apps.

4. Only official app stores. Install apps from the **official store** for your phone (Google Play on Android, App Store on iPhone). Avoid downloading app files (APKs) from random sites or links, and avoid **"cracked" or "modded" apps** â€" these are a common source of malware and of stolen data. A cracked app is like buying a cheap phone from a stranger in the market with the case already opened.

5. Find-my-device. Enable **Find My Device** (Android) or **Find My** (iPhone). If the phone is lost or stolen, you can locate, lock, or erase it remotely. Test that it is on *before* you need it.

6. Screen privacy and sharing. Be careful with **screen sharing** and shoulder-surfing; use a screen lock and do not leave the phone unlocked around strangers.

7. Be careful with links and OTPs on mobile. Phishing arrives by SMS and WhatsApp constantly. Apply Session 4's rules: **hover/long-press before tapping**, never share OTPs, verify by a separate known channel.

8. Back up the phone too. Contacts, photos and messages matter. Enable the phone's built-in backup (to your account/cloud) so a lost phone does not mean lost memories.

The analogy. Your phone is a **wallet that also holds your house keys**. Lock it, do not hand out copies, only install trusted apps, and enable the "lost wallet" finder.

Realistic Nigerian scenario. A trader installs a "free" modded version of a popular app from a link on WhatsApp. The app asks for SMS permission, which the trader grants. It then reads incoming OTPs and the attacker drains the account. A screen lock alone would not stop this â€" the real fix was **official app stores only** and **minimal permissions**.

Misconceptions.

- "iPhone/Android is secure, so I do not need to do anything." Both need updates, a screen lock and safe app habits.
- "Permissions are harmless." Permissions are exactly what let a bad app steal data.
- "Cracked apps are just cheaper." They often carry malware or spyware.

Limitation. Mobile security reduces risk but cannot stop every trick; the habits from Sessions 1â€"5 remain essential.

F.5 Backups â€" the safety net

Plain-English definition. A **backup** is an extra copy of your important data kept somewhere else, so that if the original is lost, stolen, corrupted or locked by ransomware, you still have the data.

Why it exists. Prevention can fail. Devices get stolen (a laptop in traffic), damaged (water, fire), infected (ransomware encrypts files), or files get deleted by mistake. A backup is the *only* guaranteed recovery for data â€" this is why security professionals treat it as essential, not optional.

The 3-2-1 rule â€" explained simply:

- **3** â€" keep **three copies** of your important data: the original **plus two** backups.

- **2** â€" keep them on **two different types of media** (for example, an external drive **and** the cloud), so a single failure cannot destroy all copies.
- **1** â€" keep **one copy offsite** (not in the same building), so a fire, flood or theft at one place cannot destroy every copy.

Example for a small shop. Copy 1: the shop computer (original). Copy 2: an external hard drive kept in the shop. Copy 3: a cloud backup (offsite). If the shop burns or is robbed, the cloud copy survives; if the internet is down, the external drive works.

What to back up. The data you cannot recreate:

- Business records, invoices, customer lists, spreadsheets.
- Photos and videos, important documents (certificates, ID copies, contracts).
- Phone contacts and messages (via phone backup). **What not to bother with:** the operating system and installed programs (they can be reinstalled) â€" though a full system image is an option for advanced setups.

Options and trade-offs:

Method	Good for	Pros	Cons
Cloud (e.g., OneDrive/Google Drive)	Offsite copy, phone data	Offsite automatically; accessible anywhere	Needs internet; may cost money; privacy settings matter
External hard drive	Large amounts, fast restore	No internet needed; large space	Can fail or be stolen; sits in one place
USB flash drive	Small, simple backups	Cheap, portable	Easy to lose; limited space; less reliable long-term

Best practice: combine at least two methods â€" e.g., a **USB/external drive** for a local copy **and** a **cloud** copy for offsite. This satisfies 3-2-1 without much cost.

The golden rule (teach this phrase): "A backup you have never restored is not a backup." Always **test** that you can actually restore a file. An untested backup may be incomplete, corrupted, or encrypted with a forgotten password â€" and you only discover that when you desperately need it.

How to test a restore: pick one unimportant file from your backup, delete the original (or use a copy), and restore it from the backup. If it opens correctly, your backup works.

Realistic Nigerian scenario. A shop owner "backed up" every month to a USB drive â€" but the drive was always left plugged into the same computer. When the computer was stolen, the backup was stolen with it. 3-2-1 would have kept an offsite cloud copy. Another owner never tested a restore; when needed, the "backup" folder was empty.

Misconceptions.

- "I have a backup, so I am safe." Only if it is **separate, current and tested**.
- "The cloud is enough." Cloud is excellent for offsite, but you also want a local copy for speed and when offline. (3-2-1 covers this.)
- "I will do it later." Data loss does not wait; set backups to run **automatically** where possible.

Limitation. Backups protect data, not devices. You still need the other layers to prevent the loss in the first place â€" but when prevention fails, backups are what let you recover.

F.6 Summary of the session

- **Wi-Fi encryption**: prefer **WPA2/WPA3**; an open network is a postcard anyone can read.
- **Router hardening**: change the **admin password**, set a **strong Wi-Fi password**, **turn off WPS**, enable a **guest network**.
- **Public Wi-Fi**: avoid banking/sensitive logins; prefer **mobile data** or trusted networks; turn off auto-connect.
- **Mobile safety**: **screen lock**, minimal **permissions**, **update** apps/phone, **official stores only**, enable **find-my-device**, avoid cracked apps.
- **Backups**: the **3-2-1 rule** (3 copies, 2 media, 1 offsite); back up what you cannot recreate.
- **Test your restore** â€" "a backup you have never restored is not a backup."

G. INSTRUCTOR DEMONSTRATION (15 minutes)

G.1 What the instructor prepares

- A folder of harmless practice files on the Desktop named `CEA Practice Files` containing a few dummy documents (e.g., `note1.txt`, `note2.txt`, `logo.png`).
- An external drive or USB flash drive, or a second practice folder if no drive.
- A **practice/fictional router interface** or a set of described router screens for the router-hardening walk-through. **Do not change a live router the class uses.** If showing the instructor's own router, use **described/remembered** settings or a screenshot prepared in advance â€" never fiddle with a network others depend on.
- The instructor's **own** phone (or a phone they are authorised to demonstrate on) for the mobile-safety walk-through â€" never a learner's phone, and never collect any of its data.

G.2 Demonstration 1 â€" router hardening walk-through (5 minutes)

Say: "I cannot change the academy's router â€" that would knock us all offline, and I do not have permission. So I will walk you through what the settings look like in general, and you will apply it at home on **your own** router with **your** permission."

Using a prepared screenshot or description (projector):

1. **Admin password:** "The router has an admin login, often `admin/admin` by default. We change this to a strong, unique password."
2. **Wi-Fi security type:** show where WPA2/WPA3 is selected (not WEP, not "None"). "Choose WPA2 or WPA3, whichever the router supports."
3. **Wi-Fi password:** show where the Wi-Fi password is set. "Long passphrase, not the shop name."
4. **WPS:** show the WPS toggle and turn it **Off**. "This removes the hidden spare key."
5. **Guest network:** show the guest-network option. "Turn it on for customers and visitors."

Expected result: Learners can identify the five settings to look for. (Actual changes happen on their own routers at home.) **What to watch:** Emphasise brand differences in menu names; warn that some routers require a restart. **Questions:** "Why turn off WPS?" â†' known weakness. "Why a guest network?" â†' isolates visitors from your devices.

G.3 Demonstration 2 â€" mobile safety walk-through (5 minutes)

Say: "Now the phone. I will use my own phone. Watch â€" and apply the same checks to yours with the screen facing away from anyone if you prefer."

On the instructor's own phone (projector via screen/camera or described):

1. **Screen lock:** show the lock settings and auto-lock time.
2. **Permissions:** open the app list â†' choose one app â†' show its permissions and revoke/deny an unnecessary one (e.g., a game with location/SMS).
3. **Updates:** show the app store's update list; show OS update location.
4. **Official store:** point at the store icon; "this is the only place to get apps."
5. **Find My Device:** show where it is enabled (do not reveal any real location/account data).

Expected result: Learners see what the controls look like and where to find them on Android/iOS. **What to watch:** Never use a learner's phone; never display personal notifications or account details on the projector. **Questions:** "Why does a torch app asking for contacts worry you?" â†' unnecessary permission = red flag. "Who can find a lost phone with Find My Device?" â†' you, via your own account.

G.4 Demonstration 3 â€" backup and restore, live (5 minutes)

Say: "Now the most important demo of the day: making a backup and proving it works."

1. Open **File Explorer** and show the `CEA Practice Files` folder.
2. **Copy** the folder to the **USB/external drive** (drag, or right-click â†' Copy, then Paste to the drive). Show it appearing on the drive.
3. **Simulate a loss:** delete one file (e.g., `note1.txt`) from the Desktop folder (or move it to the Recycle Bin).
4. **Restore:** copy `note1.txt` back from the USB drive to the Desktop folder. Open it to show the content is intact.

5. Say: "That is 3-2-1 in action: this USB is copy 2. A cloud copy would be copy 3 *offsite*. And I just **tested** the restore â€" which is the step almost everyone skips."

Expected result: The deleted file is restored and opens correctly. **What to watch:** Use only harmless practice files; never learner data. **Questions:** "Why test the restore?" â†' a backup only counts if it can be restored. "What would the third, offsite copy be?" â†' cloud or a drive kept elsewhere.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: Build a simple **backup plan for a small business**, then **back up a folder to an external drive/USB and restore one file**, on the learner's own/authorised machine with harmless practice files.

Starting materials: One Windows machine per learner/pair. A USB/external drive (or a second practice folder). A set of harmless `CEA Practice Files` placed on the Desktop by the instructor. Worksheet 6.2.

> ***Permission and privacy reminder (say before starting):*** *"Use only **your own** or academy practice files. Never back up anyone else's private data without permission. We are practising the method, not collecting data."*

Procedure (instructor calls each step; learners follow; instructor walks the room):

1. **Design the plan (on paper first).** On Worksheet 6.2, write the **3-2-1 plan** for a fictional small shop ("Ada's Fashion & Fabrics"):
   - Copy 1 = the shop computer (original).
   - Copy 2 = an external drive kept in the shop.
   - Copy 3 = a cloud backup (offsite).
   - List **what** to back up (customer list, invoices, photos).
2. **Plug in the drive.** Connect the USB/external drive. Open **File Explorer** and confirm you can see it.
3. **Pause and predict:** "Before we copy â€" if this drive is left plugged into the same computer and the computer is stolen, does it satisfy 3-2-1? Why not?" (Answer: no; it is the same place â€" no offsite copy.)
4. **Back up the folder.** Copy the `CEA Practice Files` folder to the drive (right-click â†' Copy, then Paste into the drive). Confirm the copy appears.
5. **Verify the copy.** Open the copied folder on the drive and check that the same files are present (compare names and count).
6. **Pause and predict:** "Have we finished making the backup?" (Answer: no â€" we have not **tested a restore**.)
7. **Simulate a loss.** Delete one file (e.g., `note2.txt`) from the Desktop folder (or move it to the Recycle Bin).
8. **Restore the file.** Copy `note2.txt` from the drive back to the Desktop folder. Open it and confirm the content is correct.
9. **Record the result** on Worksheet 6.2: date, what was backed up, where each copy is, and "restore tested: yes/no".
10. **Safely remove the drive** (use the "Safely Remove Hardware / Eject" option) and unplug it.

Expected result: The folder is copied to the drive; the deleted file is restored successfully; the 3-2-1 plan and restore record are written on the worksheet.

Points to pause and predict:

- After Step 3: the same-location rule (no offsite copy).
- After Step 6: the test-restore step.

Troubleshooting while walking the room:

- Drive not detected â†' try another USB port; check the drive appears in File Explorer/This PC; re-seat the cable.
- "Paste" greyed out â†' confirm the destination folder is open and writable; check the drive is not full or read-only.
- Copied folder empty â†' the copy may have been interrupted; re-copy and verify.
- Restored file will not open â†' the copy may be corrupted; re-copy from the source; check the file was fully copied.

Completion checklist (learner ticks each):

- ☐ 3-2-1 plan written (3 copies, 2 media, 1 offsite)
- ☐ List of what to back up written

- ☐ Drive connected and detected
- ☐ Practice folder copied to the drive
- ☐ Copy verified (same files)
- ☐ A file deleted and restored from the backup
- ☐ Restore tested and recorded
- ☐ Drive safely removed

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: Produce a **one-page "Small Business Backup & Mobile Safety Plan"** for a fictional small business, and answer a short **"Wi-Fi decision"** problem â€" all on paper, using the learner's own knowledge (no real systems changed).

Scenario: *Ngozi's Provisions* is a small shop in a Port Harcourt market. Ngozi keeps:

- a customer-credit book (spreadsheet of who owes what) on a shop laptop,
- supplier invoices as photos on her Android phone,
- family and product photos on the same phone,
- one small USB drive.

She connects the laptop to the market's **open Wi-Fi** to check prices online, and she logs into her **bank app** on that same open Wi-Fi. Her phone has **no screen lock** because "it is faster to answer customers".

Your tasks (on paper or a document):

1. **Backup plan:** Write Ngozi's **3-2-1** plan. Say explicitly what is copy 1, copy 2 and copy 3, and what should be backed up from the laptop and the phone.
2. **Wi-Fi decision:** Explain the risk of banking on the open market Wi-Fi and what Ngozi should do instead.
3. **Mobile safety:** List at least three mobile-safety problems here and the fixes.
4. **Test-the-restore:** Explain in one or two sentences why Ngozi must test a restore, and how she would do it.
5. **One-liner:** Write the golden rule about backups in your own words.

Time allowance: 15 minutes.

Success criteria:

- A correct 3-2-1 plan with a genuinely offsite copy.
- Correct Wi-Fi advice (avoid banking on open Wi-Fi; use mobile data/trusted network).
- Three-plus correct mobile problems and fixes, including the missing screen lock.
- A clear explanation of test-the-restore.
- The golden rule stated correctly.

Hints available if stuck:

- Hint 1: 3-2-1 = three copies, two media types, one offsite.
- Hint 2: The open market Wi-Fi is like a postcard; banking there is risky.
- Hint 3: A phone with no screen lock has no first barrier if lost.

Instructor answer key (do not show learners):

1. 3-2-1 plan (model):

- Copy 1: shop laptop (original) â€" customer-credit spreadsheet; and phone (original) â€" invoices + photos.
- Copy 2 (different medium, local): the small USB drive for the laptop files; **phone-to-laptop or phone-to-SD** copy for the phone photos; or an external drive when she can afford one.
- Copy 3 (offsite): a **cloud** copy (e.g., email the spreadsheet to her own mailbox, or use a cloud drive app) â€" stored offsite, not in the shop.
- What to back up: customer-credit spreadsheet, supplier invoices, product/family photos, contacts. (Programs/OS are not needed.)

2. Wi-Fi decision: Banking on the **open** market Wi-Fi is risky â€" the network is unencrypted and unknown people may observe or redirect traffic. Ngozi should do banking on **mobile data** (her SIM) or a **trusted** network, and remember the padlock only

proves encryption, not honesty.

3. Mobile safety problems + fixes:

- No screen lock â†' set a PIN/biometric with short auto-lock.
- Banking on open Wi-Fi via phone â†' use mobile data.
- Possible unnecessary app permissions â†' review and revoke.
- Possibly sideloaded/cracked apps â†' use official store only.
- No find-my-device/backup â†' enable Find My and phone backup.

4. Test the restore: An untested backup may be empty or corrupted. Ngozi should pick one unimportant file (e.g., a spare photo copy), delete the original, restore from the backup, and open it to confirm it is intact.

5. Golden rule (model): "A backup you have never restored is not a backup."

Marking guidance (out of 10):

- Correct 3-2-1 plan incl. genuine offsite copy (3)
- Correct Wi-Fi advice with reason (2)
- Three-plus mobile problems + fixes (3)
- Clear test-the-restore explanation (1)
- Golden rule stated correctly (1)

J. REAL-WORLD CASE STUDY

Situation (fictional, non-identifying). A growing catering business in Port Harcourt â€" call it *Mama Eka's Kitchen* â€" keeps all its orders, supplier prices, customer contacts and food photos on a single laptop. The owner also keeps a notebook of repeat customers on her Android phone. The business connects to the **open Wi-Fi** at a nearby plaza because it is free, and she does her **bank transfers from that network** on the phone.

One evening, a thief snatched the laptop bag at a bus stop. The laptop had the only copy of the customer and supplier records. There was no backup. The phone's screen was unlocked, and it also had no cloud backup of contacts and photos. It took the business months to rebuild its records from memory, paper scraps and customer messages â€" and it lost supplier price history it could not recover at all. A few weeks earlier, the owner had also noticed a strange bank alert that she could not explain; she wondered whether the open Wi-Fi had played a part.

Relevant facts.

- Single copy of critical data on one laptop â†' no backup at all.
- Phone had no screen lock and no backup.
- Business banking on **open Wi-Fi**.
- No find-my-device enabled on the phone.
- Records were business-critical and impossible to fully recreate.

Decision point. The loss has already happened. The business asks: *what should have been in place, and what should be set up now?*

Possible approaches.

1. Buy a new laptop and carry on as before.
2. Set up only a cloud backup and change nothing else.
3. Implement the **full package**: the **3-2-1 backup** (days-saved records, tested restores), a **phone screen lock + find-my-device + backup**, move **banking off open Wi-Fi to mobile data**, and secure the home/shop Wi-Fi with **WPA2/WPA3, a changed admin password and WPS off**.

Recommended solution. Approach 3. It addresses every cause: no backup, an unprotected phone, and sensitive activity on an untrusted network. It uses mostly free or low-cost tools (cloud, built-in phone features, router settings) and, crucially, **tests the restore** so the backups can be trusted.

Trade-offs.

- Approach 1 replaces hardware but repeats the same mistake â€" the next theft would hurt just as much.
- Approach 2 is a good start but leaves the phone unprotected and banking on open Wi-Fi still risky.

- Approach 3 takes some setup time and a little discipline (regular backup, test the restore), and cloud space may have a small cost â€" but it turns a business-ending loss into a minor inconvenience. The one real cost is *habit*: if backups are not kept current and tested, the protection fades.

Professional connection. This is the heart of defensive security work for small businesses: **protect the network, protect the mobile device, and ensure recoverable, tested backups.** These map directly to the capstone assessment in Week 3 (findings table with risk levels, fixes and priorities). It also reinforces a professional mantra: **prevention first, recovery always.**

K. COMMON MISTAKES AND TROUBLESHOOTING

Use as the live troubleshooting guide. Ask the learner to check the relevant row before giving the answer.

K.1 "I left the router on default settings"

Symptoms: Router admin still `admin/admin`; WPS on; no guest network. **Likely cause:** Never changed since installation. (Confirmed by logging into the router â€" only on your own authorised router.) **How to investigate:** Open the router admin page (address on the sticker) on **your own** router and check the settings. **Safe corrective steps:** Change the admin password to a strong unique one; set Wi-Fi security to WPA2/WPA3; turn off WPS; enable a guest network. **How to confirm resolved:** Settings show the new admin password, WPA2/WPA3, WPS off, guest network on. **Prevention:** Do this once at setup/replacement; keep the firmware updated.

K.2 "My Wi-Fi password is simple so customers can type it"

Symptoms: Short Wi-Fi password like "shop123" or the business name. **Likely cause:** Convenience. (Confirmed by reading the password rules/setting.) **How to investigate:** Check the Wi-Fi security settings. **Safe corrective steps:** Change to a long passphrase; share it via a displayed sign only with trusted people; consider a **guest network** for customers. **How to confirm resolved:** A long, non-obvious passphrase is in use; guest network used for visitors. **Prevention:** Use the guest network so customers need not get the main password.

K.3 "I do banking on free public Wi-Fi"

Symptoms: Sensitive logins on open/unknown networks. **Likely cause:** Free data, not understanding the risk. **How to investigate:** Ask where the banking is done; check whether mobile data is available. **Safe corrective steps:** Move banking/transfers to **mobile data** or a trusted network. If a work VPN is provided, use it. Turn off auto-connect to open networks. **How to confirm resolved:** Sensitive activity is done on mobile data/trusted network. **Prevention:** Treat public Wi-Fi as untrusted; assume it can be watched.

K.4 "My phone has no screen lock"

Symptoms: Phone opens without PIN/biometric; sometimes no auto-lock. **Likely cause:** Convenience. (Confirmed by checking lock settings.) **How to investigate:** Phone Settings â†' Security/Lock screen. **Safe corrective steps:** Set a PIN/biometric with a short auto-lock; avoid obvious PINs; enable Find My Device. **How to confirm resolved:** Device locks automatically; Find My Device shows enabled. **Prevention:** Set this on day one and enable phone backup.

K.5 "I installed a cracked/modded app from a link"

Symptoms: Apps from outside the official store; unexpected ads, pop-ups, battery drain, strange permissions. **Likely cause:** Sideloaded/cracked app, often carrying malware or spyware. **How to investigate:** Check app list and permissions; note apps not installed via the store. **Safe corrective steps:** Uninstall the app; scan the phone; review and revoke unnecessary permissions; reinstall from the official store if genuinely needed. **How to confirm resolved:** Unknown app gone; no strange behaviour; permissions tidy. **Prevention:** Official stores only; no cracked apps.

K.6 "My backup is on the same computer / I never tested it"

Symptoms: Backup drive always plugged into the same machine; no record of a test restore; backup may be stale or empty. **Likely cause:** Only one copy and no testing. (Confirmed by checking where the backup lives and when it was last restored.) **How to investigate:** List where each copy is; try restoring one file. **Safe corrective steps:** Add an **offsite** copy (cloud or a drive kept elsewhere); schedule regular automatic backups; **test a restore** and record the date. **How to confirm resolved:** 3-2-1 satisfied; a test restore succeeded and is recorded. **Prevention:** Calendar a monthly test restore; keep one copy offsite always.

Distinguish likely vs confirmed: Each "likely cause" becomes "confirmed" only after checking â€" e.g., actually logging into your own router, reading the backup location list, or performing a test restore. Teach learners to verify before concluding.

L. SESSION ASSIGNMENT

Assignment title: "My 3-2-1 Backup Plan and Safety Audit"

Purpose: Apply Wi-Fi/mobile safety and the 3-2-1 backup rule to a real, authorised device, and produce a clear, tested backup â€" the recovery skill required for the capstone and for real small-business support.

Realistic scenario: You are helping a family member or a small shop set up safer habits on a device you are authorised to use. You must (a) write a 3-2-1 backup plan, (b) actually perform and test one backup, and (c) do a short mobile-safety audit of your **own** phone.

Detailed instructions:

1. **Backup plan:** Write a 3-2-1 plan for the chosen device/business. Clearly label copy 1 (original), copy 2 (different medium, local) and copy 3 (offsite). List what data is worth backing up.
2. **Perform a backup:** Copy one folder of **your own/harmless** files to an external drive/USB **and** (if available) a cloud/email copy for offsite.
3. **Test a restore:** Delete one unimportant file (or use a copy) and restore it from the backup. Record the date and result.
4. **Mobile safety audit (your own phone):** Check and record (do **not** share any personal data): screen lock on? permissions reviewed? apps updated? official store only? find-my-device on? phone backup on?
5. **Wi-Fi note:** State one Wi-Fi habit you will change (e.g., no banking on open Wi-Fi) and why.
6. **Privacy:** Do not include passwords, account numbers or anyone else's private data.

Required deliverables:

- `session6-assignment/backup-plan.md` (the 3-2-1 plan + what to back up).
- `session6-assignment/restore-test-log.md` (date, file, result).
- `session6-assignment/mobile-safety-audit.md` .

Submission format: In the class folder, or photos in your workbook.

Deadline: Before Session 7.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Correct 3-2-1 plan	4	Three copies, two media, one genuinely offsite
What-to-back-up list sensible	3	Business/personal data, not programs/OS
Backup actually performed & verified	3	Copy exists and matches
Restore tested & logged	4	A file was restored and the result recorded
Mobile safety audit complete	3	Screen lock, permissions, updates, store, find-my-device
Wi-Fi habit & privacy	3	Sensible habit stated; no personal data included

Common mistakes to avoid: "backing up" to the same drive that is always plugged in; never testing the restore; forgetting the offsite copy; recording personal data; thinking cloud alone is the whole answer.

Instructor reference solution (model):

Backup plan: Copy 1 â€" shop laptop `customer-credit.xlsx`. Copy 2 â€" USB drive kept separately (not always plugged in) with a copy of the spreadsheet and invoices. Copy 3 â€" cloud: email the spreadsheet to my own mailbox / upload to a cloud drive (offsite). What to back up: customer-credit spreadsheet, invoices/photos, contacts.

Restore test log: Date 2026-10-14; deleted `customer-credit.xlsx` copy from Desktop; restored from USB; opened successfully; result: PASS.

Mobile audit: Screen lock ON (PIN + biometric); permissions reviewed â€" revoked location from a game; apps updated; all apps from official store; Find My Device ON; phone backup ON. Wi-Fi habit: "I will no longer do bank transfers on open Wi-Fi; I will use mobile data."

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key.)

Q1. Multiple choice. Which Wi-Fi security setting is the strongest of these choices? a) WEP b) Open (no password) c) WPA2/WPA3 d) A hidden network name only

Q2. Short answer. Name **three** router hardening steps.

Q3. Explain in your own words. Why should you avoid doing banking on open public Wi-Fi, and what could you use instead?

Q4. List. Give **five** mobile safety practices.

Q5. Fill in the blanks. The 3-2-1 backup rule means **3** ____, **2** different ____, and **1** copy kept ____.

Q6. True or false, with a reason. "If I have a backup, it is guaranteed to save my data."

Q7. Scenario. You back up your shop files to a USB drive every month, but the drive is always left plugged into the shop computer. A thief steals the computer. What was wrong with this backup, and how would you fix it?

Q8. Fill in the blank (the golden rule). "A backup you have never ____ is not a backup."

INSTRUCTOR ANSWER KEY (Q1â€"Q8)

A1. (c) WPA2/WPA3. **A2.** Any three of: change the default router admin password; set a strong Wi-Fi password; choose WPA2/WPA3; turn off WPS; enable a guest network; keep firmware updated. (Accept any three.) **A3.** Open public Wi-Fi is unencrypted and unknown people on the network may be able to observe or redirect traffic, so bank details/passwords could be exposed. Use **mobile data** (SIM) or a **trusted** network instead; if work provides a **VPN**, use it; turn off auto-connect to open networks. **A4.** Any five of: set a screen lock (PIN/biometric); review and limit app permissions; keep apps and OS updated; use official app stores only; enable find-my-device; avoid sideloaded/cracked apps; enable phone backup; be careful with links/OTPs on mobile. (Accept any five.) **A5. 3 copies**, **2** different **media**, **1** copy kept **offsite**. **A6.** False. A backup only saves your data if it is **separate, current and tested**. An untested or same-place backup may be empty, corrupted, or stolen along with the original. **A7.** The USB drive was kept in the **same place** as the computer, so the theft took the backup too â€" and it was likely always plugged in (no separate copy, no offsite copy). Fix: follow **3-2-1** â€" keep a second copy on a **different medium** and a **third copy offsite** (e.g., cloud), and don't leave the only backup in the same location. **A8.** "A backup you have never **restored** is not a backup."

N. REFLECTION AND RECAP

Plain-English summary. Today we protected the network, the phone and your data's survival. On Wi-Fi, encryption (WPA2/WPA3) turns the "postcard" travelling through the air into a sealed coded letter, and we harden the **router** by changing the admin password, setting a strong Wi-Fi password, turning off WPS and enabling a guest network. On **public Wi-Fi** we avoid banking and sensitive logins, preferring mobile data or a trusted network. On the **phone** we set a screen lock, limit app permissions, update apps, use official stores only, and enable find-my-device â€" and we avoid cracked apps. Finally, the **3-2-1 backup rule** (3 copies, 2 media, 1 offsite) is our safety net, and we learned the golden rule: **a backup you have never restored is not a backup.**

Five important takeaways:

1. Prefer **WPA2/WPA3**; an open network is readable by others.
2. Harden the router: **change admin password, strong Wi-Fi password, WPS off, guest network**.
3. On **public Wi-Fi**, avoid banking â€" use **mobile data** or a trusted network.
4. **Lock the phone, limit permissions, update apps, official stores only, enable find-my-device.**
5. Follow **3-2-1** and always **test a restore**.

Questions to help you recognise what you can now do:

- Can I explain WPA2/WPA3 versus an open network?
- Can I list the router steps to apply on my own router?
- Can I audit my own phone for the five mobile-safety items?
- Can I build a 3-2-1 plan and prove a restore works?

Connection to the next session: We have now completed Week 2: accounts, browsing, email, device and now network + mobile + backups are hardened. In Week 3 we switch from *doing* to *assessing*. Next session, **Session 7 â€" Assessment Method and Risk Rating**, you will learn how to examine a fictional business's setup systematically, record findings with a risk rating, and prepare for the capstone. Everything from Sessions 1â€"6 becomes the checklist you will use.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- The learner explains Wi-Fi encryption using the postcard/letter idea and distinguishes WPA2/WPA3 from open/WEP.
- The learner lists the router hardening steps in a sensible order and can say why WPS should be off.
- The learner refuses to bank on open Wi-Fi and chooses mobile data instead.
- The learner audits their own phone and finds real gaps (e.g., an unnecessary permission) without needing prompts.
- The learner builds a correct 3-2-1 plan with a genuinely **offsite** copy.
- The learner **tests a restore** and understands why that step matters.

Common misconceptions to watch for and correct:

- "A Wi-Fi password makes me fully safe." â†' only if the security type is WPA2/WPA3 and the password is strong.
- "WPS is fine, it's convenient." â†' known weaknesses; turn it off.
- "Public Wi-Fi is safe if it has a password." â†' everyone there has it; treat it as untrusted.
- "I have a backup so I'm safe." â†' only if separate, current and tested.
- "Cloud alone is enough." â†' good for offsite, but keep a local copy too (3-2-1).

Suggested remedial exercises for learners who struggle:

1. **Encryption sorting:** give scenarios (open cafÃ© network, home WPA3, WEP router) and ask which is safest and why.
2. **Router checklist drill:** hand out a blank router hardening checklist; learners fill in the step and the reason for each.
3. **3-2-1 diagram:** learners draw three boxes (original, local backup, offsite) and label each with a real example; then mark which one survives a fire and which survives a theft.
4. **Restore drill:** repeat the copy-delete-restore cycle on harmless files; insist on writing the test date.

Differentiation:

- **Level 1 (supported):** Provide a partly completed 3-2-1 worksheet with the three copies already labelled; the learner only fills in the data to back up and performs the copy/restore with a printed step list.
- **Level 2 (standard):** The exercises as written.
- **Level 3 (challenge):** Design a backup and restore **schedule** for a small business with two computers and two phones, including frequency, who is responsible, where each copy lives, and how the monthly restore test is logged; add a short public-Wi-Fi policy for staff.

Timing guidance: The physical backup/restore (Section H) is the priority â€" protect it. If the room is slow, trim the case study (Section J) to a 3-minute mention and shorten the router walk-through to the five key settings. If the room is fast, extend the independent exercise with the Level 3 challenge and have learners explain their plans to a partner.

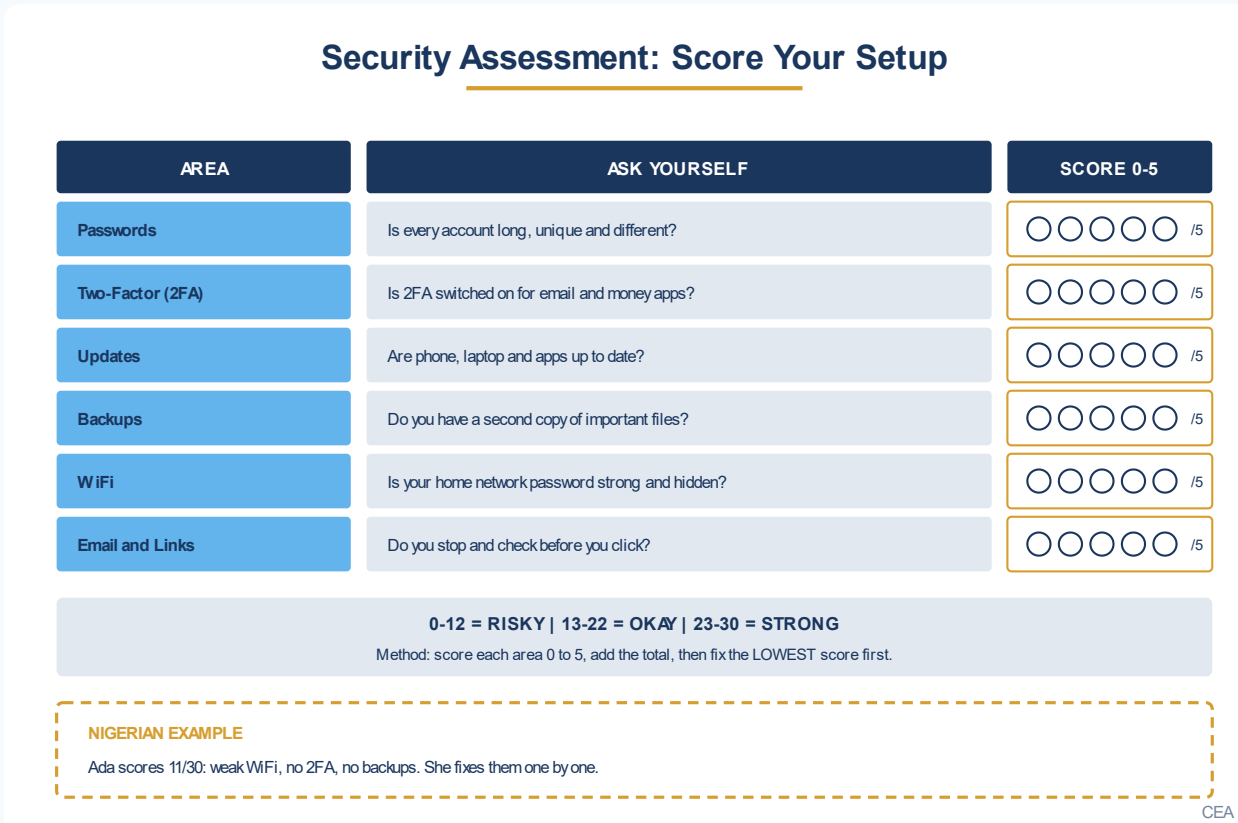
END OF SESSION 6

Next: Session 7 â€" Assessment Method and Risk Rating (Week 3: Assess).

SESSION 07 OF 9

Assessment Method

CONCEPT DIAGRAM — SESSION 07



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 7 â€" SECURITY ASSESSMENT METHOD AND RISK RATING

A. SESSION IDENTIFICATION

Item	Detail
Session number	7 of 9
Session title	Security Assessment Method and Risk Rating
Week / Module	Week 3 â€" Module 3: Assess and Improve
Recommended duration	105 minutes
Difficulty level	Beginner (first time assessing a whole business)
Prerequisite knowledge	Sessions 1â€"6. Learners must already know the basics of accounts and passwords, MFA, safe browsing, phishing, device hardening (updates, Windows Defender, firewall), Wi-Fi safety,

Item	Detail
	and backups. If a learner cannot explain two of those in one sentence each, run the 15-minute refresher at the start of the prerequisite review.
Connection to previous work	In Sessions 1â€"6 learners learned individual defensive skills â€" one lock, one door, one room at a time. This session teaches them to walk through a whole small business, room by room, write down what they find, and decide which problems matter most. It is the bridge from "I can secure my own phone" to "I can advise a small business."
Preparation before class	Academy PCs on and logged in; projector ready; printed vignette cards (one business per pair) from Appendix 7A; printed findings-table worksheets (Section H); whiteboard divided into a 3Ã—3 risk grid drawn before class; the running example *Adaeze Fashion* written on the board.

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Define** a defensive security assessment in their own words and explain how it differs from hacking or penetration testing.
2. **State the rule of authorisation** â€" that a system may only be assessed with the owner's written permission â€" and give one example of an authorised target and one of an unauthorised target.
3. **Build a written checklist** covering at least seven areas of a small business: accounts and passwords, MFA, device updates, antivirus and firewall, Wi-Fi, backups, staff awareness and phishing risk, and data handling.
4. **Gather evidence safely** by describing and recording what is seen, without changing anything and without testing other people's systems.
5. **Rate a finding's risk** using likelihood Ã— impact and assign Low, Medium or High.
6. **Prioritise findings** and justify which problem should be fixed first.
7. **Produce a findings table** with columns for the issue, the risk level, and the reason, for a fictional business scenario.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops). Pairing two learners on one machine is fine â€" one reads the vignette aloud, the other writes the findings, then swap.
- Instructor computer connected to a projector or large screen.

Software

- Google Chrome (for showing a real website's padlock and address bar as a safe illustration only).
- Notepad or a word processor for typing the findings table. Pen and paper is equally acceptable and is the fallback if power or machines are limited.
- Windows 10 or Windows 11 with Windows Defender present (used only to *look at* settings, never to change another person's machine).

Printed materials

- Vignette cards â€" Appendix 7A (cut into cards, one fictional business per pair).
- Worksheet 7.1 â€" "My Assessment Checklist" (blank checklist with the eight areas listed).
- Worksheet 7.2 â€" "Findings Table" (pre-drawn table: Issue | Risk Level | Reason | Fix First?).
- A copy of the risk grid (3Ã—3) for each learner, or drawn on the board.

Accounts

- None required. No account, email or business login is used at any point. All assessment targets are fictional and described on paper.

Internet

- Optional. If the academy has internet, the instructor may show the padlock and the `https://` prefix on one real, public website to illustrate evidence-gathering. Do not type anything into any website. If there is no internet, the printed vignette cards are complete on their own.

Important safety note for the instructor: Nothing in this session involves connecting to, scanning, logging into, or testing any system that does not belong to the learner. All "assessment targets" are fictional businesses described on paper. Say this out loud at the start.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: On the projector, show a simple, familiar picture on the board: a small shop drawn with a door, a window, a padlock on the door, and a back gate left open. Write underneath it: *Adaeze Fashion, Port Harcourt.*

What the instructor says:

> *"Imagine you are the person Adaeze calls when something feels wrong with her shop's security. She says: 'I think my shop is okay, but I am not sure.' What do you do? You do not force the door to see if it opens â€" that is breaking in. Instead, you walk around the shop with her permission, look at the door, the window, the padlock, and you notice the back gate is open. Then you write it down: 'Back gate â€" not locked â€" very easy for someone to enter.' That is today's whole lesson.*
>
> *Look at the back gate in my drawing. Would you say that is a small problem or a big problem? Why?"*

Expected learner response: Learners will likely say the back gate is a **big** problem, because it is easy to enter and dangerous. Some may say "small because nothing was stolen yet." Accept both. Then steer toward the key idea:

> *"The gate is a big problem not because of what already happened, but because it is easy to do (high likelihood) **and** if it happens the loss is serious (high impact). That combination is what we call risk. Today you will learn to look at a business the same way â€" politely, with permission â€" and score every weakness as Low, Medium or High."*

Why this opener works: It gives a physical, everyday picture (a shop gate) before any technical term, and it introduces the two ingredients of risk â€" likelihood and impact â€" through a question the learners can already answer.

E. PREREQUISITE REVIEW (7 minutes)

Run this as a fast oral round-robin. Put the five prompts on the projector. This deliberately re-uses the eight areas that will become the checklist.

Question 1: "Name two things that make a password strong."

- Expected answer: long, and unique (not reused); mixing letters, numbers and symbols helps; a password manager helps you keep them unique.
- Common gap: learners say only "mix symbols". Remind them that **length and uniqueness** matter most.

Question 2: "What is MFA, and give one example?"

- Expected answer: Multi-Factor Authentication â€" logging in with two different kinds of proof, e.g. password **plus** a code from an app or SMS.
- Common gap: confusing MFA with "just a strong password." Clarify: MFA is a *second* lock.

Question 3: "Why do we install updates on phones and computers?"

- Expected answer: updates fix known weaknesses and bugs that attackers use; an out-of-date device is an easier target.
- Common gap: "updates make it faster." Redirect to **security fixes**.

Question 4: "What does a backup protect you against?"

- Expected answer: losing data â€" from theft, fire, accidental deletion, or ransomware.
- Common gap: thinking a backup is only for phones. Explain it also applies to business records.

Question 5: "If a strange email asks you to click a link and 'confirm your bank details urgently', what do you do?"

- Expected answer: do not click; verify through the official app or a known phone number; report it.
- Common gap: "click to check if it's real." Correct: clicking is exactly what the attacker wants.

Bridge to today (say this):

> *"Notice something: every question I just asked is a room in the shop. Passwords, MFA, updates, backups, and phishing awareness are five rooms. Today we turn those into a written checklist, walk through a fictional business, and score every problem. When we are done, you will have a findings table â€" which is the exact document a real small business would pay for."*

If more than a third of the class cannot answer Questions 1 and 4, spend an extra 10 minutes re-teaching passwords and backups from Session 2 and Session 6 notes before continuing.

F. FULL LECTURE NOTES

F.1 What a security assessment actually is

Plain-English definition. A **security assessment** is a careful, organised look at how a business uses its computers, accounts, phones, network and people, in order to find weak points and write down what should be improved. It is done **with the owner's permission** and its output is a **report**, not damage.

Why it exists. A small business owner is busy selling. She cannot see her own blind spots â€" nobody can easily see their own blind spots. An outside (or internal) person with a checklist can look calmly and notice the open back gate. The assessment exists so that problems are found **before** an attacker finds them.

What it does.

- It records the current state of security honestly ("here is how things are now").
- It identifies weaknesses ("here is where you are exposed").
- It rates how serious each weakness is ("this one is High, that one is Low").
- It recommends improvements ("do these first").

Familiar analogy. A security assessment is like a **health check-up at a clinic**. The doctor does not make you sick to test you. The doctor asks questions, measures, looks, and then writes a report: "Your blood pressure is high â€" please change your diet." A security assessment is a check-up for a business's computers and habits.

Real-life Nigerian scenario. A small *POS* operator in Rumuokoro keeps his phone unlocked, uses the same PIN as his bank app, and has never updated the phone. A friend who does "small IT work" offers to look at it â€" but the right way is to ask: "Do I have your permission and can I write down what I find?" He says yes. The assessment finds three issues and a simple fix list. Nothing is broken; everything is just written down and improved.

Important limitation / misconception. "Assessment" does **not** mean breaking in. Some people hear "security assessment" and picture a hacker in a dark room. That is a different activity. Our course is **defensive only**. We look, we ask, we record, we advise. We never attack, exploit, or test someone else's system to prove a point.

F.2 Assessment versus hacking and penetration testing

This distinction is the heart of the course's ethics. Learn it properly.

Activity	Permission	What it does	Who does it	In this course?
Defensive security assessment	Written permission from owner (or your own system)	Looks, asks, records, rates risk, recommends fixes	You, an IT support person, a consultant	**Yes â€" this is what we do**

Activity	Permission	What it does	Who does it	In this course?
Penetration test ("pen test")	Written permission, usually a formal contract	Deliberately tries to break in using attack techniques, to prove weaknesses	Trained, certified professionals only	**No**
Hacking (cybercrime)	**No permission**	Breaks in to steal, damage, or extort	Criminals	**Never â€" illegal**

The key words: the same action can be legal or criminal depending only on **permission**. A pen tester and a criminal might use a similar technique; what separates them is a **signed authorisation** document. Even a pen tester without permission is a criminal.

What you, as a Cyber Elias Academy learner, are allowed to assess:

1. Systems **you personally own** (your own phone, your own laptop).
2. Systems you are given **written permission** to assess (a real client who signs an authorisation form, or the fictional businesses in this course).

What you are never allowed to assess: any system that belongs to someone else without their written permission â€" a school, a church, a shop, your friend's phone, a website, an office network. Not even "just to check if it's safe." Not even "for their own good."

Say this to the class:

> *"There is a very short sentence that separates a professional from a criminal: Do I have written permission? If the answer is no, you stop. In this course the only systems we touch are our own, and the only businesses we assess are the fictional ones written on paper. That is the rule for the rest of your career."*

Why this matters professionally. If you ever accept payment to assess a business and you did not get written permission, you could lose your job, be sued, or be arrested â€" even if you found nothing and damaged nothing. Written permission protects the business **and** you.

F.3 Scope and authorisation

Scope means: *exactly what am I allowed to look at, and what am I not?* A proper assessment always begins with scope, agreed with the owner before anyone touches anything.

A simple authorisation checklist (used even for fictional clients):

1. **Who owns the system?** (Name the business and the person giving permission.)
2. **What is included?** (Which computers, accounts, Wi-Fi, phones, records.)
3. **What is excluded?** (Everything else â€" say it out loud.)
4. **When?** (Start and end time of the assessment.)
5. **What will we NOT do?** (We will not change settings, we will not test other companies' systems, we will not attempt to break in.)
6. **Permission in writing.** For a real client: a signed form. For this course: the fictional client's name on the vignette card.

Familiar analogy. Scope is like a **landlord giving a repairman a list of flats**. "You may enter flats 1, 2 and 3. Do not enter flat 4 â€" a tenant lives there." Even if flat 4's door is open, you do not go in. Scope is respect written down.

Real-life Nigerian scenario. A church asks you to check whether its WhatsApp group is safe. The scope is the **group's settings and the leaders' phones** â€" not the personal chats of every member. If you start reading the members' private messages, you have gone outside scope, even though the church trusted you. Staying inside scope protects that trust.

Misconception. "The owner said 'do whatever you need to.'" That is not scope; it is a vague sentence. Convert it into a written list of included and excluded items, and ask the owner to confirm it. A real professional never works from a vague verbal permission.

F.4 Building the checklist â€" the eight rooms

A checklist is just the eight areas we already learned, written down so we do not forget any. Walk through each room and ask the same questions every time.

Room 1 â€" Accounts and passwords.

- Are passwords long and unique for each service?
- Is there a shared password written on a paper or a WhatsApp message? (Very common in small businesses.)
- Are old accounts (former staff) still active?

Room 2 â€" MFA (multi-factor authentication).

- Is MFA switched on for bank, email, and any business app?
- On which accounts is it missing?

Room 3 â€" Device updates.

- Are the operating system and apps set to update automatically?
- How long has it been since the last update?

Room 4 â€" Antivirus and firewall.

- Is Windows Defender (or another protector) switched on and up to date?
- Is the firewall switched on?

Room 5 â€" Wi-Fi and network.

- Is the Wi-Fi password strong and changed from the default?
- Is the Wi-Fi encrypted (WPA2 or WPA3)?
- Is guest Wi-Fi separated from the business devices?

Room 6 â€" Backups.

- Does a backup exist?
- Is it done regularly (daily or weekly)?
- Is one copy kept **off the machine** â€" for example in Google Drive or on a USB kept elsewhere?
- Has anyone actually tried to *restore* from the backup? (A backup you have never restored is a hope, not a guarantee.)

Room 7 â€" Staff awareness and phishing risk.

- Have staff been taught to spot a fake bank alert, a fake WhatsApp link, a fake "POS reversal" message?
- Does anyone know what to do if they click something wrong?

Room 8 â€" Data handling.

- Where is customer information kept (names, phone numbers, account details)?
- Is sensitive data sitting in an unlocked phone or a shared notebook anyone can photograph?
- Is old data deleted when it is no longer needed?

Say this to the class:

> *"Eight rooms. Every assessment you ever do is just walking these eight rooms with the same questions. When you remember the eight rooms, you can never be stuck staring at a blank page."*

F.5 Gathering evidence safely

Evidence is what you actually observed, written down in a way that can be trusted. "I *think* the Wi-Fi is weak" is not evidence. "The router login page still uses the default password label `admin`" is evidence â€" if you saw it with permission.

Rules for safe evidence gathering:

1. **Look and ask first.** Most evidence comes from asking the owner and reading settings *with permission*, not from scanning.
2. **Change nothing.** Do not switch settings, do not delete files, do not "quickly fix it" during the assessment. You are a doctor doing a check-up, not a surgeon operating. Changing things destroys the evidence and can break the business.
3. **Write exactly what you saw.** Name the device, the setting, and the state. Use plain words.
4. **Date and sign.** Note the date, the business, and who showed you.

5. **Keep it confidential.** A findings list is a sensitive document. Do not post it in a WhatsApp group or leave it on a cyber cafÃ© computer.

Evidence record template (used throughout the course):

Date	Area (room)	What I observed	How I know (who showed me / where I looked)
2026-10-05	Wi-Fi	Router still uses the default admin password	Owner opened the router page and showed me

Familiar analogy. Evidence gathering is like a **police officer taking notes at a scene** â€" they write what they *see*, in order, without moving the furniture. If they rearrange the room, the notes are useless.

Important limitation / misconception. "A real assessment uses scanning tools." Some professional assessments do, but only on systems the assessor is authorised to scan, and only by trained professionals. For a small business walk-through and for this course, **asking and observing is the correct and sufficient method**. You do not need any attack tool to do this course's assessment.

F.6 Rating risk â€" likelihood Ã— impact

Now the most important skill of the session: turning a finding into a risk level.

Two questions for every finding:

1. **Likelihood** â€" how *easy* or *likely* is it that this weakness gets used? (High, Medium, Low)
2. **Impact** â€" if it *is* used, how *bad* is the damage? (High, Medium, Low)

Risk = Likelihood Ã— Impact (in plain terms: *how easy* times *how bad*).

Then map to a simple level:

	Impact Low	Impact Medium	Impact High
Likelihood High	Medium	High	**High**
Likelihood Medium	Low	Medium	High
Likelihood Low	Low	Low	Medium

This is the **3Ã—3 grid**. Read it like a multiplication table for danger: the top-right corner (easy to happen **and** very damaging) is the worst â€" High. The bottom-left (unlikely **and** mild) is the least worrying â€" Low.

Now apply it to real findings:

- **Wi-Fi password written on a card taped to the counter, admin password still default.** Likelihood: **High** (anyone nearby, or anyone who photographs the card, can join). Impact: **High** (on the same network they may reach business devices and records). â†' **High risk.**
- **One staff member's phone is two years behind on updates.** Likelihood: **Medium** (needs a specific attack). Impact: **Medium** (phone holds some customer chats). â†' **Medium risk.**
- **Old staff account from a worker who left is still active.** Likelihood: **Medium** (only that person knows the password, but they left dissatisfied). Impact: **High** (could access business email and records). â†' **High risk.**
- **No backup at all.** Likelihood of *needing* a backup: **High** over a year (phones get stolen, files get deleted). Impact: **High** (business records lost forever). â†' **High risk.**
- **Wi-Fi uses WPA2 with a long password.** Likelihood: **Low**. Impact: **Medium** if it did fail. â†' **Low risk.** (This is a *good* finding; note it as "satisfactory".)

Why a simple scheme is good. Big companies use more complex scoring with numbers and percentages. For a small Nigerian business, a plain **Low / Medium / High** is understood by the owner and still drives the right decisions. Do not over-complicate. Accuracy matters more than fancy numbers.

Misconception to correct. "If nothing bad has happened yet, the risk is Low." Wrong. Risk depends on *how easy* and *how bad*, not on history. The back gate may never have been used â€" it is still High risk.

Important limitation. Risk rating is a **judgement**, not an exact science. Two careful people might rate the same finding Medium or High. That is acceptable, as long as you **show your reasoning** ("High likelihood because the password is on a public card; High impact because it exposes business records"). The reason column is what makes your rating trustworthy.

F.7 Prioritising findings

Once everything is rated, you decide what to fix **first**. Rating alone is not enough, because two High-risk items might need different treatment (one is free and instant, the other costs money).

Priority order â€" a simple rule:

1. **High risk + easy/cheap fix** â†' do it **immediately** (e.g., change the default admin password, switch on MFA, lock the back gate).
2. **High risk + hard/expensive fix** â†' **plan it** and start soon (e.g., buy an external drive for backups).
3. **Medium risk** â†' schedule within the improvement plan.
4. **Low risk / already good** â†' note it as satisfactory; revisit later.

This matches the "quick wins first" idea you will use fully in Session 8. For now, just understand the idea: **the risk level tells you what matters; the effort tells you the order.**

Familiar analogy. Imagine a leaking roof and a squeaky door in your house. The squeaky door (low risk, easy) you fix today; the leaking roof (high risk, needs money) you plan and pay for this month. You do both â€" but in a sensible order.

F.8 Summary of the session

- A **security assessment** is a permission-based, organised look at a business's security that ends in a written report.
- **Authorisation and scope** come first, always. Written permission only.
- We are **defensive only** â€" we never attack, and we never assess other people's systems.
- The **eight rooms** checklist: accounts/passwords, MFA, updates, antivirus/firewall, Wi-Fi, backups, staff awareness, data handling.
- **Gather evidence safely** by looking and asking; change nothing; write exactly what you saw.
- **Risk = likelihood Ã— impact**, mapped to Low / Medium / High on a 3Ã—3 grid.
- **Prioritise** by risk level, then by effort (quick wins first).

G. INSTRUCTOR DEMONSTRATION (15 minutes)

The instructor demonstrates how to *think through* one fictional business out loud, using the running example.

G.1 What the instructor prepares

- The whiteboard with the 3Ã—3 risk grid drawn.
- The running example written as a short profile (below), or read aloud.
- A blank findings table drawn large on the board.

The example profile (Adaeze Fashion, Port Harcourt):

> *Adaeze runs a small fashion shop on a busy street in Port Harcourt. She uses one Android phone for everything: bank app, WhatsApp business, and taking mobile-money payments by POS. Her assistant Chidi also uses the same phone when Adaeze travels to buy materials. The phone has no screen lock. Adaeze's email password is* `adaeze123`*, which she also uses for her Instagram and her bank app. MFA is not switched on. The shop's Wi-Fi password is* `12345678` *and is written on a paper on the counter. There is no backup of her customer list; it lives only in her WhatsApp. She has two staff and has never trained them about fake bank alerts. Windows laptop in the back office runs an old version of Windows that has not updated in months; Windows Defender is switched off because "it was slowing the computer."*

G.2 Demonstration â€" thinking aloud (about 8 minutes)

Say: "Watch how I move through the eight rooms and write each finding in the table. I am not touching anything â€" this is all on paper."

Walk the board, room by room:

1. **Accounts/passwords:** Finding â€" "Same weak password (`adaeze123`) used for email, Instagram and bank." Move to likelihood/impact.
    - *Ask the class:* "How likely is this to be used? How bad is it?" Guide them to **High Ã— High = High** (weak, reused, and it exposes money).
2. **MFA:** Finding â€" "MFA not switched on for bank or email." â†' High likelihood (weak password already), High impact â†' **High**.
3. **Device updates:** Finding â€" "Back-office Windows not updated for months; Defender off." â†' Medium likelihood, High impact (records + money) â†' **High**.
4. **Antivirus/firewall:** Folded into Room 3 finding above (Defender off).
5. **Wi-Fi:** Finding â€" "Weak Wi-Fi password `12345678` , written on the counter." â†' High likelihood, High impact (untrusted devices reach business devices) â†' **High**.
6. **Backups:** Finding â€" "Customer list only in WhatsApp; no backup." â†' High likelihood (phones get stolen), High impact (list lost forever) â†' **High**.
7. **Staff awareness:** Finding â€" "No training on fake alerts for two staff." â†' Medium likelihood, Medium impact â†' **Medium**.
8. **Data handling:** Finding â€" "Phone with bank app has no screen lock, shared with assistant." â†' High likelihood, High impact â†' **High**.

Then draw the prioritised list on the board:

1. Put a screen lock on the phone (High, free, instant).
2. Change the bank/email/Instagram passwords to unique strong ones + switch on MFA (High, free, same day).
3. Change the Wi-Fi password to a strong one and remove the card from the counter (High, free).
4. Switch Windows Defender back on and update the laptop (High, free).
5. Start a backup of the customer list to Google Drive (High, near-free).
6. Train the two staff (Medium, cheap, next week).

What to watch for / say: "Notice I found the *same* problem in more than one room? The weak password shows up in accounts, MFA and the bank app. That is normal â€" one weakness often creates others. Write each one where it belongs, and it will be obvious how they connect."

Questions to ask during the demo:

- "Which here is a quick win â€" High risk and free?" (Screen lock, MFA, Wi-Fi password.)
- "Which needs a small cost or planning?" (Training, and buying storage for backups if needed.)
- "Have I changed anything on Adaeze's phone?" (No â€" it is all on paper. That is the point.)

G.3 Demonstration â€" filling one row properly (about 7 minutes)

Say: "Let me show you how to write *one* row so well that the owner trusts it."

Write on the board:

Issue	Risk Level	Reason	Fix First?
Same weak password `adaeze123` used for email, Instagram and bank app	**High**	Likelihood High â€" the password is short, common, and reused; Impact High â€" a single guess or leak exposes email, socials and money at once	**Yes â€" today**

Point at the Reason column: "Notice I did not just write 'High'. I wrote *why* â€" the likelihood reason and the impact reason. A finding without a reason is just an opinion. A finding with a reason is a professional judgement."

Ask a learner to help write the next row (the Wi-Fi finding) on the board, guiding the wording. This warms them up for the guided exercise.

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: In pairs, assess a fictional business from a vignette card using the eight-room checklist, and produce a findings table with issue, risk level and reason.

Materials: One vignette card per pair (Appendix 7A); Worksheet 7.1 (blank checklist); Worksheet 7.2 (findings table); the risk grid on the board.

Procedure (instructor calls out each step; pairs work; instructor walks the room):

1. **(2 min)** Each pair reads their vignette card **twice** â€" once quickly, once slowly, pencil in hand. Underline every fact that relates to security.
2. **(2 min)** Copy the eight-room checklist. Tick each room you can say something about. If the vignette does not mention a room, write "not stated â€" ask owner."
3. **(2 min) Pause and predict:** Before writing any risk level, each pair must say out loud which **two** findings they think are the most dangerous. Write them at the top of the page.
4. **(6 min)** Fill the findings table: one row per issue. Columns: **Issue | Risk Level | Reason | Fix First?** Every Risk Level must be followed by a Reason that mentions likelihood and impact.
5. **(4 min)** Rate the risk using the 3Ã—3 grid. **Pause again:** For each High finding, say out loud "likelihood is high becauseâ€¦" and "impact is high becauseâ€¦".
6. **(2 min)** Prioritise: circle the two findings that should be fixed first. In the "Fix First?" column, write "Yes â€" now" for those, "Plan" for the High but expensive ones, "Later" for Low.

Expected result (worked example for vignette card 1 â€" see key below):

Issue	Risk Level	Reason	Fix First?
No screen lock on phone used for banking	High	L: High â€" anyone holding it is in; I: High â€" bank app + customer chats exposed	Yes â€" now
Default router admin password unchanged	High	L: High â€" default password is public knowledge; I: High â€" full network control	Yes â€" now
No backups of customer list	High	L: High â€" phones lost/stolen often; I: High â€" records lost forever	Plan
Staff never trained on fake alerts	Medium	L: Medium â€" scam texts are common; I: Medium â€" some payments could be lost	Later

Troubleshooting while walking the room:

- Pair writes "High" with no reason â†' ask: "How likely, and how bad? Say it in words first, then write it."
- Pair marks everything High â†' ask them to find the *good* finding (the one already satisfactory) and rate it Low. Not everything is High.
- Pair tries to "fix" the fictional business on the computer â†' stop them: "You are assessing, not changing. Paper only."
- Pair confuses MFA with a strong password â†' gently restate: MFA is a second lock; a strong password is a better first lock.

Completion checklist (learner ticks each):

- ☐ Read the vignette and underlined the facts
- ☐ Filled the eight-room checklist (or marked "not stated")
- ☐ At least four findings in the table
- ☐ Every finding has a Risk Level **and** a Reason
- ☐ Reason mentions likelihood and impact
- ☐ At least one Low / satisfactory finding noted
- ☐ Two findings marked for immediate fix

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task: Individually assess a **new** fictional business, *Blessing Bakes* (below), and produce a findings table plus a prioritised top-three fix list. No pair discussion this time.

Scenario (read this to the class):

> *Blessing runs a home cake business. She takes orders on WhatsApp Business on her personal phone and keeps all customer names and addresses in a single notebook. She uses one simple password, `cake2019`, for her email, her Facebook page and her quick-loan app. Her phone updates are set to automatic (good). Her Wi-Fi uses a strong password she changes every year. She has no antivirus app beyond what came with the phone. She has never backed up the notebook, and her two ice-cream delivery boys use the same phone to call customers when she is baking.*

Requirements:

1. Use all eight rooms; note which are good and which are weak.
2. Write a findings table with columns: **Issue | Risk Level | Reason | Priority**.
3. Give at least five findings, including at least one **satisfactory/Low** finding.
4. End with a **top-three fix list** in priority order, and one sentence on why the first is first.

Time allowance: 15 minutes.

Success criteria:

- Every finding has a Level and a Reason.
- At least one Low/satisfactory finding (updates are automatic; Wi-Fi is strong).
- Top-three list is ordered by risk, then by how easy/cheap the fix is.

Hints available if stuck:

- Hint 1: A reused password is always at least Medium, usually High, because one leak opens many doors.
- Hint 2: If a room is good, write "Satisfactory â€" Low. Reason: â€¦" so the owner knows it was checked.
- Hint 3: "Priority" = risk level + effort. Free + High = "Now".

Instructor answer key / model (do not show learners):

Issue	Risk Level	Reason	Priority
Same password `cake2019` used for email, Facebook and loan app	**High**	L: High â€" short, obvious, reused; I: High â€" one leak gives access to money and business pages	Now
Customer notebook has no backup	**High**	L: High â€" notebook can be lost, burnt or stolen; I: High â€" all customer records gone	Now (buy a cheap USB / use Drive)
Delivery boys share Blessing's phone with her bank/loan apps	**High**	L: High â€" the phone is handed around daily; I: High â€" banking exposed to others	Now
No security app beyond default	**Medium**	L: Medium â€" needs the user to click something bad; I: Medium â€" phone data at risk	Plan
Never trained on fake order / fake alert scams	**Medium**	L: Medium â€" scam messages common; I: Medium â€" could lose a delivery payment	Later

Issue	Risk Level	Reason	Priority
Phone updates set to automatic	**Satisfactory â€" Low**	L: Low; I: Medium â€" updates kept current, risk well managed	Keep as is
Wi-Fi password strong, changed yearly	**Satisfactory â€" Low**	L: Low â€" strong and changed; I: Medium if breached	Keep as is

Top-three fix list (model):

1. Change the shared password to unique strong passwords and switch on MFA for email/Facebook (High, free, today â€" first because it protects money fastest).
2. Set a screen lock/PIN on the phone and stop sharing it for bank apps (High, free, today).
3. Back up the customer notebook to Google Drive and a USB (High, cheap, this week).

Marking guidance (out of 10):

- Uses all eight rooms (2)
- Five or more findings (2)
- Correct risk levels with reasons (3)
- At least one satisfactory/Low finding (1)
- Clear, correctly ordered top-three list (2)

J. REAL-WORLD CASE STUDY

Situation. *Chidi* runs a phone-repair kiosk near a market in Port Harcourt. He repairs customers' phones and, to test them, he sometimes logs into customers' WhatsApp and bank apps "just to make sure the app opens." He keeps a notebook of every customer's name, phone number and sometimes their screen-lock PIN, "in case they come back and forget." He uses the same password for his own email and his POS terminal. One day he asks you, a CEA learner, to "check if his shop is safe."

Relevant facts.

- Chidi handles other people's sensitive accounts as part of his daily work.
- He stores customers' PINs in a notebook.
- He reuses one password across his own accounts.
- He has permission to repair the phones â€" but not to browse customers' private accounts.

Decision point. Before you even start assessing, what is wrong here, and what does scope and authorisation require you to say?

Possible approaches.

1. Just start assessing the shop's computers as asked, ignoring the phone-login habit â€" it is "not your business."
2. Point out the ethics problem: logging into customers' private apps is outside the permission customers gave (they gave the phone for repair, not their WhatsApp and bank). Then, with Chidi's permission, add "handling of customer accounts and data" to the scope and assess it too.
3. Refuse to help at all.

Recommended solution (for this stage). Approach 2. The professional response is to name the problem kindly and correctly. Customers authorised *repairing the phone*, not *reading their WhatsApp*. That is over-stepping scope even though the phone was handed over. The notebook of PINs is also a serious data-handling finding. With Chidi's permission, you assess and record: (a) customer account browsing â€" High risk (breaks trust and the law); (b) PIN notebook â€" High risk; (c) reused password â€" High risk; and recommend fixes: stop logging into customers' accounts, test apps with a test account, delete the PIN notebook, and use unique passwords.

Trade-offs.

- Approach 1 is easy but leaves a serious ethical and legal problem unspoken â€" and a real assessor must report what they find within scope.

- Approach 2 is the professional route: it respects the customer, protects Chidi (he could be sued or arrested), and still helps him.
- Approach 3 abandons a client who needs honest guidance. Marking the problem is more useful than walking away.

Professional connection. Junior IT support and consultants meet this exact situation constantly â€” a person with good intentions and bad habits. The skill is to **report facts neutrally** ("customer accounts were accessed during repairs") and **recommend a fix**, not to insult the owner. Naming a finding is not the same as accusing a person; it is the job.

K. COMMON MISTAKES AND TROUBLESHOOTING

K.1 "I rated everything High"

Symptoms: The findings table is a wall of High; prioritising becomes impossible. **Likely causes:** (a) The learner forgot that some items are already good. (b) They are confusing "important" with "dangerous." **How to investigate:** Go back through the eight rooms and ask, "Is this area already handled well?" Write those as Low/satisfactory. **Corrective steps:** Re-rate using the 3Ã—3 grid. Force yourself to give a likelihood and an impact reason; when you do, some items will fall to Medium or Low. **How to confirm resolved:** The table now contains a mix of High, Medium and Low. **Prevention:** Always hunt for at least one satisfactory finding; a good assessment reports strengths too.

K.2 "High" with no reason

Symptoms: Risk Level column filled, Reason column empty or vague ("it is bad"). **Likely cause:** The learner jumped to a feeling instead of a judgement. **Corrective steps:** For each finding, write two short phrases: "Likelihood is ___ because ___; Impact is ___ because ___." If you cannot, re-check your facts. **Prevention:** Rule of the course â€” **no reason, no rating.**

K.3 Assessing without permission

Symptoms: Learner wants to "just check" a school's or a friend's phone/website. **Likely cause:** Enthusiasm without understanding the ethics rule yet. **Corrective steps:** Stop immediately. Remind them: only your own systems, or systems with written permission. In this course, only the fictional paper businesses. **Prevention:** Repeat the authorisation checklist before every practical. The permission question is always first.

K.4 "Fixing" during the assessment

Symptoms: Learner changes a setting on the vignette's "business" or a real device while assessing. **Likely cause:** Eagerness to help. **Corrective steps:** Write it as a finding instead ("Recommended fix: change the password"). Restore anything changed immediately if it was a real device with permission. **Prevention:** Repeat the rule: assessors look and record; they do not change. Fixes happen in Session 8's improvement plan.

K.5 Confusing assessment with penetration testing

Symptoms: Learner asks, "Should I try to log in with a wrong password to test it?" **Likely cause:** Blending the two activities. **Corrective steps:** Clarify: trying to break in is penetration testing, which is not this course and not this activity. We record "passwords are weak" from what we observe/are told; we do not attack. **Prevention:** Keep the three-row comparison table (F.2) visible on the wall.

K.6 Scope creep

Symptoms: The assessment quietly grows to cover areas the owner did not approve. **Likely cause:** Curiosity. **Corrective steps:** Return to the written scope list; if something important is outside scope, **ask the owner in writing** to add it. **Prevention:** Re-read the scope at the start of every assessment; treat it as a fence.

Distinguish likely vs confirmed: In every case, a "likely cause" becomes "confirmed" only after you check â€” e.g., you confirmed a password is reused only when the owner or evidence shows it. Teach learners to confirm before writing a finding.

L. SESSION ASSIGNMENT

Assignment title: "Eight-Room Assessment of a Fictional Business"

Purpose: Practise using the eight-room checklist to produce a complete findings table with risk ratings and reasoning, for a business the learner invents.

Realistic scenario: Invent a small Nigerian business (a barbershop, a tailor, a provision store, a church ICT room â€" your choice). Write a short profile of how it currently works, then assess it with the eight-room checklist.

Detailed instructions:

1. Write a **one-paragraph profile** of your invented business: what it sells or does, what devices it uses, and how it handles accounts, passwords and customer data. Base it on realistic Nigerian practice. You may use good habits in some areas and weak habits in others.
2. Complete the **eight-room checklist** (Worksheet 7.1), filling each room with a short observation, or "not stated â€" ask owner."
3. Produce a **findings table** with at least six rows and columns: **Issue | Risk Level | Reason | Priority**.
4. Include at least **one satisfactory/Low finding** (a good habit) to show balance.
5. Write a **top-three fix list** in priority order.
6. Add a short **scope and authorisation statement** at the top: who owns the business (fictional), what is included, and what is excluded. State that it is a fictional business used for training only.

Required deliverables:

- Profile paragraph.
- Completed eight-room checklist.
- Findings table (6+ rows).
- Top-three fix list.
- Scope/authorisation statement. All on paper or in a document.

Submission format: Hand in on paper, or upload to the class folder as a document named `CEA-Sec-YourName-S7-Assignment`.

Deadline: Before Session 8.

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Realistic profile	2	A believable Nigerian small business with clear habits
Eight rooms covered	4	Every room addressed or marked "not stated"
Findings table quality	5	6+ rows; each issue is specific and observable
Risk rating correctness	4	Levels match likelihood Ã— impact; reasons given
Balance (a good finding included)	2	At least one satisfactory/Low finding
Prioritised fix list	2	Top three ordered sensibly with a reason
Scope/authorisation statement	1	Clearly states fictional, included/excluded, permission

Common mistakes to avoid: rating everything High; empty Reason column; assessing a real (non-fictional) business; forgetting the scope statement; changing/inventing facts that were not in your own profile.

Instructor reference solution (model for a fictional "Emeka Barbershop"):

> ***Profile:*** *Emeka's barbershop uses one Android phone for POS, bookings and the shop's social media. Two barbers share the phone. Password* `emeka2020` *is used for email and Instagram. MFA off. Wi-Fi password is strong. No backup of booking records. Staff were once shown a fake-alert message by Emeka.*
>
> ***Findings table:***

Issue	Risk Level	Reason	Priority
Shared password `emeka2020` for email + Instagram	High	L: High â€" reused and guessable; I: High â€" both accounts at once	Now

Issue	Risk Level	Reason	Priority
Phone shared by two barbers with banking/POS	High	L: High â€" handed over many times a day; I: High â€" money exposed	Now
No backup of booking records	High	L: High â€" phone loss common; I: High â€" records lost	Plan
MFA off on email	Medium	L: Medium â€" depends on password leak; I: High â€" full account	Plan
Wi-Fi password strong	Satisfactory â€" Low	L: Low â€" well set; I: Medium if breached	Keep
Staff once shown a fake alert	Satisfactory â€" Low	L: Low â€" some awareness present; still improve	Later

> ***Top-three fixes:*** *(1) unique strong passwords + MFA; (2) stop sharing the banking phone / add screen lock; (3) back up bookings to Drive.*

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key below.)

Q1. Short answer. In one sentence, what is a security assessment?

Q2. Multiple choice. What is the difference between a penetration test and hacking? a) There is no difference. b) A penetration test has written permission; hacking does not. c) Hacking is done by professionals; a pen test by criminals. d) A pen test always damages the system.

Q3. True or false, with reason. "An assessment should change weak settings as it finds them, so the business is fixed faster."

- True / False. Why?

Q4. List and explain. Name four of the eight rooms in the assessment checklist.

Q5. Risk rating. A shop's Wi-Fi uses the factory default password that anyone can look up online, and the Wi-Fi also connects to the computer that holds customer payments. Rate the likelihood and impact, then give the overall risk level, with a reason.

Q6. Prioritisation. You have two High-risk findings: (A) MFA is switched off (free to fix, 5 minutes), and (B) there is no off-site backup (needs a small purchase and planning). Which do you fix first, and why?

Q7. Ethics scenario. A friend says, "Just quickly test my school's website to see if it is safe." What do you say and do?

INSTRUCTOR ANSWER KEY (Q1â€"Q7)

A1. A security assessment is an organised, permission-based look at how a business uses its devices, accounts and habits, to find weaknesses, rate their risk, and recommend improvements. (Accept any answer with the ideas of *permission*, *finding weaknesses*, and *recommending fixes*.)

A2. (b) A penetration test has written permission; hacking does not.

A3. False. An assessment looks and records; it does not change settings. Changing things destroys evidence, may break the business, and goes beyond the assessor's role. Fixes belong in the improvement plan (Session 8), done with the owner's agreement.

A4. Any four of: accounts/passwords; MFA; device updates; antivirus/firewall; Wi-Fi/network; backups; staff awareness (phishing); data handling. Each should have a short correct description, e.g. "MFA â€" is a second lock switched on for important accounts?"

A5. Likelihood **High** (the default password is publicly known and easy to try); Impact **High** (the Wi-Fi reaches a computer holding customer payments). Overall **High risk**. Reason: easy to exploit **and** very damaging.

A6. Fix **A first**. Both are High risk, but A is free and completes in minutes ("quick win"), while B needs money and planning. The rule is: same risk level â†’ do the easier/cheaper fix first, and plan the harder one alongside it.

A7. Say no. You do not have written permission from the school, so you may not assess or test it â€” not even "quickly" or "for their own good." Explain that with the school's written permission and a defined scope, a qualified person could do it properly; but without permission it could be illegal and could get both of you in trouble. Offer to help your friend assess their **own** laptop or phone instead, since they own it.

N. REFLECTION AND RECAP

Plain-English summary. Today you learned that a security assessment is a permission-based health check-up for a business, not a break-in. You learned that **written permission and scope** come before anything else, and that we only assess our own systems or the fictional businesses in this course. You built an eight-room checklist, learned to gather evidence by looking and asking without changing anything, and learned to rate risk as **likelihood Ã— impact** on a simple 3Ã—3 grid. Finally, you practised prioritising findings and writing a findings table with clear reasons.

Five important takeaways:

1. A security assessment needs **written permission and a clear scope** â€” always.
2. Defensive assessment â‰ hacking â‰ penetration testing. Permission is the dividing line.
3. The **eight rooms**: accounts/passwords, MFA, updates, antivirus/firewall, Wi-Fi, backups, staff awareness, data handling.
4. **Risk = likelihood Ã— impact**, mapped to Low / Medium / High.
5. **Prioritise** by risk, then by effort â€” quick wins first.

Questions to help you recognise what you can now do:

- Can I explain the three activities (assessment, pen test, hacking) and what separates them?
- Can I list all eight rooms from memory?
- Can I rate a finding as Low/Medium/High and give a reason?
- Can I write a findings table that a business owner would understand?

Connection to the next session: A findings table tells a business *what is wrong*, but not *what to do about it or in what order over time*. In **Session 8** you turn your findings into a **prioritised improvement plan** â€” quick wins and longer projects, with clear cost-aware recommendations â€” and you learn what to do in the first hour of a real incident through a tabletop drill.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- Learner states the permission rule unprompted before starting the exercise.
- Learner's findings table shows a **mix** of risk levels, not all High.
- Every risk level is backed by a likelihood-and-impact reason.
- Learner identifies at least one **satisfactory** finding.
- Learner refuses, correctly, when given an out-of-scope/unauthorised temptation.
- Learner prioritises by risk **and** effort, not just by feeling.

Common misconceptions to watch for and correct:

- "Assessment = hacking." â†’ Re-show the three-row table; permission is the difference.
- "Nothing bad has happened, so risk is Low." â†’ Risk = likelihood Ã— impact, not history.
- "I should fix things as I find them." â†’ Assessors record; fixes happen later, with permission.
- "Everything is High, so everything is priority one." â†’ Hunt for good findings; use effort to order.
- "Scope is just what the owner loosely said." â†’ Scope must be written, with included and excluded items.

Suggested remedial exercises for learners who struggle:

1. **Sort-the-findings drill:** give ten finding cards and a 3Ã—3 grid; ask the learner to place each.
2. **Two-sentence drill:** for each finding, force the sentence "Likelihood is ___ because ___; impact is ___ because ___."

3. **Permission drill:** show five short scenarios (own laptop, friend's phone, a signed client, a school website, a church group) and ask "allowed or not, and why?"

Differentiation:

- **Level 1 (supported):** provide a pre-filled eight-room checklist with three rooms already done and a partly filled findings table; the learner completes the rest.
- **Level 2 (standard):** the exercise as written.
- **Level 3 (challenge):** add a **likelihood number (1â€“3) and impact number (1â€“3)**, multiply them, and derive the level arithmetically; also propose one free fix and one paid fix for each High finding.

Timing guidance: If the room is slow, shorten the case study (Section J) to a 3-minute mention and protect the full guided and independent exercise time â€” the findings table is the priority. If the room is fast, give vignette card 2 in Section I as a bonus.

APPENDIX 7A â€” VIGNETTE CARDS (cut into cards, one per pair)

Card 1 â€” Adaeze Fashion (Port Harcourt).

> *Adaeze runs a fashion shop. One Android phone does everything: bank app, WhatsApp Business, POS payments. Assistant Chidi shares the phone when Adaeze travels. No screen lock. Email password `adaeze123` reused for Instagram and bank. MFA off. Wi-Fi password `12345678`, written on a paper on the counter. Customer list only inside WhatsApp; no backup. Two staff, never trained on fake alerts. Back-office Windows laptop not updated in months; Defender switched off.*

Card 2 â€” Grace of God Provision Store (Aba Road).

> *Grace's provision store uses one desktop computer for stock and for the shop's small loan records. The computer has no password to log in. Windows updates are on (good). Free antivirus expired last year and was never renewed. Wi-Fi password is strong. Customer loan records are kept on the computer and also printed on paper kept in a drawer. No backup of the digital file. Grace herself was scammed once by a fake bank alert and now warns her one staff member. She uses a different strong password for her email and switched on MFA after the scam (good).*

Card 3 â€” Hope Church ICT Room (Port Harcourt).

> *The church ICT room has three laptops used for sound, records and printing. All three use the same simple password `church123`. There is one shared email account for the church with MFA off. The laptops auto-update (good). Antivirus is Windows Defender and is on (good). The Wi-Fi password is strong and changed twice a year. Membership records including phone numbers are kept on one laptop and on a USB that is passed around. No training for the three volunteers.*

Card 4 â€” Chinedu Electronics (Diobu).

> *Chinedu's electronics shop uses a laptop for invoices and a phone for POS. Laptop login password is strong and unique (good). Windows Defender on (good). Updates paused "because they take time" â€” last update four months ago. Wi-Fi router still uses the factory login `admin/admin`. A notebook holds suppliers' bank account details. MFA is on for the bank app (good). Three staff, none trained on scam invoices.*

END OF SESSION 7

Next: Session 8 â€” Improvement Plan and Incident Response.

SESSION 08 OF 9

Improvement Plan Incident

CONCEPT DIAGRAM — SESSION 08



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 8 â€" IMPROVEMENT PLAN AND INCIDENT RESPONSE

A. SESSION IDENTIFICATION

Item	Detail
Session number	8 of 9
Session title	Improvement Plan and Incident Response
Week / Module	Week 3 â€" Module 3: Assess and Improve
Recommended duration	105 minutes
Difficulty level	Beginner (turning findings into an action plan, plus first incident-response lesson)
Prerequisite knowledge	Session 7. Learners must already be able to produce a findings table with issue, risk level and reason. They must know the eight rooms and the permission/scope rule. If a learner cannot

Item	Detail
	explain "risk = likelihood Ã— impact," re-teach Section F.6 of Session 7 before this session.
Connection to previous work	In Session 7 you found the problems and rated them. A findings list alone does not help a business; it just worries the owner. This session gives you the two documents that actually help: a **prioritised improvement plan** (what to fix, in what order, at what cost) and an **incident response card** (what to do in the first hour when something goes wrong).
Preparation before class	Academy PCs on; projector ready; whiteboard; printed **incident response card template** (Appendix 8A); printed **tabletop drill scenario** (Section I); the four vignette cards from Session 7 re-used; the running example *Adaeze Fashion* findings list from Session 7 on the board; a blank "effort vs impact" 2Ã—2 grid drawn for the lecture.

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Convert** a findings table into a prioritised improvement plan that separates **quick wins** from **longer projects**.
2. **Write a clear recommendation** using the five questions: what, why, how, who, when.
3. **Give cost-aware advice** to a small Nigerian business, choosing free or cheap fixes before expensive ones.
4. **Describe the six basic incident-response steps** â€" Prepare, Identify, Contain, Eradicate, Recover, Learn â€" in simple words.
5. **Explain the first-hour actions** for a suspected breach or ransomware: disconnect from the network, do not pay blindly, preserve evidence, change passwords from a clean device, inform the right people, and restore from a clean backup.
6. **Produce a one-page incident response card** that a non-technical staff member could follow.
7. **Take part in a tabletop incident drill**, making sensible decisions in the correct order.

C. REQUIRED MATERIALS

Hardware

- One computer per learner (academy desktops), or paper if machines are limited.
- Instructor computer connected to a projector.

Software

- A word processor or Notepad for typing the plan and the card.
- No attack tools, no scanning tools, no live systems. All scenarios are fictional and paper-based.

Printed materials

- The **Adaeze Fashion findings table** from Session 7 (reprinted or on the board).
- Worksheet 8.1 â€" "Improvement Plan" (columns: Recommendation | Why | How | Who | When | Cost | Priority).
- Worksheet 8.2 â€" "Effort vs Impact grid" (2Ã—2 blank).
- Appendix 8A â€" "My Incident Response Card" (one-page template with the six first-hour actions, blank for the learner to fill and personalise).
- Section I â€" "Tabletop Drill Scenario" (read aloud by the instructor).
- Pen and paper for every learner.

Accounts

- None. No real incident, no real business, no live system.

Internet

- Not required. The whole session is fictional and offline.

Safety note for the instructor: The incident-response content is **defensive**. It tells a business how to *respond* to an attack on itself. It never teaches how to attack. Say this clearly: "You are learning fire-drill procedure, not how to start a fire."

D. OPENING ACTIVITY (6 minutes)

Instructor setup: On the projector or board, draw a house with smoke coming out of one window. Next to it, write two headings: *"Before the fire"* and *"When the fire starts."*

What the instructor says:

> *"Last week we learned to walk around a shop and write down what is wrong â€" the findings table. That is like noticing that a house has no smoke alarm and the fire escape is blocked. Good. But imagine the house is **already on fire right now**. Does it help to calmly write a report? No! Right now you need to know: where is the exit, where is the bucket, who calls the fire service, and do not run back inside for your phone. Today we learn both: first, how to turn last week's findings into a **fix plan** so the fire never starts. Then, how to react in the **first hour** if it does start anyway."*

Ask the class: "If your shop's POS phone is stolen right now, and your bank app is on it, what is the very first thing you do?"

Expected learner response: Learners will say things like "call the bank", "change the password", "block the SIM", "tell my husband", "pray", "find it with GPS." Accept all. Then steer:

> *"All useful. But notice we need an order â€" what first, what second. And we need it written down **before** it happens, because in a panic nobody remembers the order. That written page is called an **incident response card**, and by the end of today you will each have one."*

Why this opener works: It creates urgency and shows the difference between *planning ahead* and *reacting in the moment*, which is exactly the two halves of this session.

E. PREREQUISITE REVIEW (7 minutes)

Fast oral round-robin. Put the prompts on the board. These deliberately restate Session 7 so the improvement plan can build on it.

Question 1: "What is the risk formula from last week?"

- Expected answer: Risk = likelihood Ã— impact, mapped to Low/Medium/High.
- Common gap: learners remember "likelihood and impact" but not that they **multiply**. Restate: easy Ã— bad.

Question 2: "In a findings table, what three columns must always be present?"

- Expected answer: Issue, Risk Level, Reason. (Plus a priority/fix column.)
- Common gap: leaving out the Reason. Remind: no reason, no rating.

Question 3: "Give me one quick win and one bigger project from Adaeze Fashion's findings."

- Expected answer: Quick win â€" put a screen lock on the phone, switch on MFA, change the Wi-Fi password. Bigger project â€" set up proper backups, train staff.
- Common gap: naming a quick win as something costly. Clarify: a quick win is free or very cheap and done today.

Question 4: "What does the permission/scope rule say about who we assess?"

- Expected answer: only our own systems, or systems with written permission. Fictional businesses in this course.
- Common gap: none usually, but repeat it anyway.

Bridge to today (say this):

> *"You already have the diagnosis â€" the findings table. Today we write the **prescription**: what medicine, in what order, and what it costs. Then we learn the **emergency procedure** for the day the sickness comes anyway. A doctor does both."*

If more than a third of the class cannot answer Question 1, spend 8 extra minutes re-teaching the risk grid from Session 7 before continuing.

F. FULL LECTURE NOTES

F.1 From findings to plan â€" what an improvement plan is

Plain-English definition. An **improvement plan** is a written, prioritised list of the changes a business should make, with enough detail for the owner to act: what to do, why, how, who does it, when, and roughly what it costs.

Why it exists. A raw findings table overwhelms a busy shop owner. If you hand Adaeze a list of ten problems, she will feel frightened and do nothing. If you hand her a plan that says "*Today: put a screen lock on your phone, it is free and takes two minutes*" and "*This month: start a backup of your customer list*", she can actually start. A plan turns worry into action.

What it does.

- Puts the biggest dangers at the top.
- Splits work into **quick wins** (today) and **projects** (this month).
- Makes each action clear enough that **any staff member** can carry it out.
- Attaches a **cost** so a small business is not scared off.

Familiar analogy. A findings table is a list of symptoms from a check-up. An improvement plan is the **treatment plan** the doctor writes: "Take this tablet daily; come back in two weeks; reduce salt." Same visit, different document.

Real-life Nigerian scenario. A tailor in Mile 3 gets a findings table showing five problems. The IT person writes an improvement plan: "1. Change the phone PIN â€" free â€" today. 2. Switch on MFA for the bank app â€" free â€" today. 3. Buy a â‚¦4,000 USB and copy customer measurements weekly â€" this week. 4. Attend the free CEA phishing class â€" this month." The tailor does the free ones the same evening.

Misconception to correct. "An improvement plan should list every possible security upgrade." No. A plan that is too long gets ignored. A good plan focuses on the **few changes that reduce the most risk** and fits the business's real budget.

F.2 Quick wins versus longer projects

The simplest way to organise a plan is by **how much effort** each fix needs.

- **Quick wins:** free or very cheap, done in minutes or hours, no special skill. Examples: set a screen lock; switch on MFA; change a default password; change the Wi-Fi password; remove a password from a paper on the counter; switch Windows Defender back on; turn on automatic updates; log out of shared accounts.
- **Longer projects:** need money, planning, training, or a few days. Examples: buying and setting up a proper backup system; moving customer records off a shared notebook into a secure file; training all staff; replacing a very old computer that no longer receives updates; setting up separate guest Wi-Fi.

The rule: Do all the quick wins first. They cost nothing and remove a lot of risk. Then plan the projects.

Familiar analogy. Fixing a leaky tap (quick win) is different from re-plumbing the whole house (project). Do the tap today; plan the plumbing.

F.3 Effort versus impact â€" the 2Ã—2 grid

To decide what comes next when the quick wins are done, use a simple **effort vs impact** grid.

High impact	**DO NOW** (quick win with big benefit)	**PLAN** (big benefit, but needs time/money)
Low impact	**DO IF EASY** (nice to have)	**AVOID / DEFER** (not worth it now)

- **Do Now:** high impact, low effort â€" your best actions. Almost every fix on Adaeze's phone lives here.
- **Plan:** high impact, high effort â€" backups, training, new hardware. Schedule them.
- **Do If Easy:** low impact, low effort â€" tidy-ups; do them when convenient.

- **Avoid/Defer:** low impact, high effort â€" skip for now.

Say this to the class:

> *"When you are unsure what to advise, ask two questions: How much does this reduce risk? and How much effort or money does it cost? Everything you can fix for free that lowers a High risk goes straight to 'Do Now'."*

F.4 Writing a clear recommendation â€" what, why, how, who, when

A recommendation that says "improve security" is useless. A good recommendation answers **five questions**:

Question	Meaning	Example
What	The exact action	"Switch on MFA for the bank app"
Why	The risk it removes	"So that a stolen password alone cannot reach the money"
How	The steps, simply	"Open the bank app â†' Settings â†' Security â†' Two-factor â†' turn on and follow the prompt"
Who	The person responsible	"Adaeze (owner)"
When	A deadline	"Today before closing"

Example full recommendation (written as it would appear in the plan):

> ***Recommendation 1 â€" Switch on Multi-Factor Authentication (MFA) for the bank app.*** *Why: Currently a single reused password protects the business's money; one leak would be enough. How: Open the bank app, go to Security settings, turn on two-factor authentication, and follow the on-screen prompt. Who: Adaeze. When: Today. Cost: Free.*

Say this to the class: "If a recommendation does not tell you *who* and *when*, it will never get done. Always put a name and a date on it."

Misconception. "The owner will know what I mean." No â€" assume the owner is busy and does not know technical words. Write it as if for a bright person who is not technical.

F.5 Cost-aware advice for a small Nigerian business

Money is real. A plan that costs more than the business earns will be ignored, no matter how good it is. So give advice in this order:

1. **Free fixes first.** Screen locks, MFA, strong unique passwords, turning on updates and Windows Defender, changing default router passwords, logging out of shared accounts, deleting old staff accounts. These remove a huge share of the risk for **â‚¦0**.
2. **Cheap fixes second.** A USB drive (a few thousand naira) for off-site backup; a phone case with a lock; a small fee for more Google Drive storage (or free tier); printing the incident response card.
3. **Sensible investments later.** Proper backup drive or cloud plan; replacing a very old computer that no longer gets security updates; paying for staff security training (like a CEA short course); a business-grade router with guest Wi-Fi.

Real-life Nigerian scenario. A provision store earns maybe â‚¦30,000 profit a month. Telling the owner to buy a â‚¦100,000 server is useless. Telling her "Switch on MFA today (free), and buy a â‚¦3,500 USB this week so a copy of your records lives away from the phone" is advice she can actually take. That is professional.

Say this to the class: "The best advice is not the fanciest. It is the advice the owner can actually afford and will actually do."

Important limitation. Free fixes reduce most *common* risks, but they cannot fix everything. A business with very valuable data may need to spend money â€" and it is honest to say so, and to explain the trade-off.

F.6 What an incident response is

Plain-English definition. An **incident** is any event that harms, or could harm, the security of the business â€" a stolen phone, a hacked WhatsApp, a ransomware message locking files, a suspected fake bank transfer, a lost USB with customer records. **Incident response** is what you *do* about it, in a sensible order.

Why it exists. In a real incident, the difference between a small problem and a disaster is usually **how fast and how calmly** people act. A phone stolen today with a screen lock and MFA is annoying; the same phone with an open bank app and no lock is a catastrophe. Response is about limiting the damage.

Familiar analogy. It is the **fire drill**. The building has extinguishers and a printed exit plan, and everyone has practised. When real smoke appears, nobody stands frozen. Incident response is the fire drill for computers.

What it is not. Incident response does not mean "hunt down the criminal" or "hack back." Hacking back is illegal and dangerous. Our job is to **protect the business and reduce the damage**, then learn.

F.7 The six basic incident steps â€" explained simply

This is a widely used framework. Learn the six words in order: **Prepare, Identify, Contain, Eradicate, Recover, Learn.** (A common way to remember: *PICERL* â€" but the meaning matters more than the letters.)

1. Prepare. Before anything happens, get ready. Have the incident response card printed and posted; have backups running; know who to call (the IT person, the bank, and for a real crime, the police); keep a clean phone or email available; decide who will speak for the business. *Without Prepare, the other five steps are done in panic.*

2. Identify. Notice and confirm that something is wrong. What exactly happened? Which device or account? When? How do you know? Keep calm and gather the basic facts: "The laptop shows a message that all files are encrypted." Do not guess wildly; write down what you actually see.

3. Contain. Stop the damage spreading. The classic first move: **disconnect the affected device from the network** (unplug the cable or switch off Wi-Fi) so the problem cannot spread to other devices. Isolate, do not delete. Do not switch off and wipe â€" that can destroy useful evidence.

4. Eradicate. Remove the cause. This might mean cleaning the device, removing the harmful program, or â€" if the device cannot be trusted â€" setting it aside and rebuilding it. For a small business this is often done by the IT person. In our fictional drills, we describe it, we do not hunt or attack.

5. Recover. Bring the business back safely. **Restore from a clean backup** (one made *before* the incident), reset passwords, confirm the device is clean, and return to normal work carefully. Test before trusting.

6. Learn. After it is over, sit down and ask: how did this happen? What did we do well? What was slow? What should we change so it does not happen again? Update the improvement plan. A lesson not written down is a lesson lost.

Say this to the class: "Six words: Prepare, Identify, Contain, Eradicate, Recover, Learn. If you remember only one, remember **Contain** â€" disconnect from the network â€" because that is the move that stops a small fire becoming a big one."

F.8 The first hour of a suspected breach or ransomware

When something goes wrong, the first hour matters most. Here is the defensive first-hour checklist. Teach it as a simple, calm sequence.

If files are locked with a ransom message (ransomware) or you suspect a break-in:

1. **Disconnect from the network â€" immediately.** Unplug the network cable, or turn off Wi-Fi and mobile data. This stops the harmful program from reaching other devices or the backup. Keep the device **on** if you are unsure â€" switching off may wipe evidence held in memory, and the IT person may need it.
2. **Do NOT pay or negotiate blindly.** Paying does not guarantee your files come back, and it may fund criminals and mark you as a willing payer. Do not click links or reply in the ransom message. Report it to the right people first.
3. **Preserve the evidence.** Do not delete the ransom note or the strange files. Take a photo of the screen with your phone (not the affected device). Write down the time you noticed and what you saw. The evidence may be needed by your IT person or the police.
4. **Change your important passwords â€" from a clean device.** Use a *different, unaffected* phone or computer to change the passwords for email and banking. Start with email, because email is often used to reset everything else. Turn on MFA at the same time if it is off.

5. **Tell the right people.** Inform the owner/manager immediately, inform the IT support person, and if money or customer data is involved, inform the bank and â€" for a real crime â€" report to the police or the relevant authority. Do not hide it out of shame; hiding it makes it worse.
6. **Restore from a clean backup.** Once the IT person confirms the device is clean, restore from a backup that was made **before** the incident. This is why the backup must be off the device and tested.

Say this to the class: "The first hour is about three things: **stop the spread** (disconnect), **keep the evidence** (do not wipe it), and **protect the accounts** (change passwords from a clean device). Everything else can follow."

Misconceptions to correct:

- "Switch the laptop off and on again." For ransomware this can be the wrong move â€" it may destroy evidence and does not remove the problem.
- "Just pay the small amount they ask." Dangerous and no guarantee; do not do it blindly.
- "Don't tell anyone, it's embarrassing." Silence makes it worse. Tell the right people early.
- "Delete the virus message to clean up." No â€" preserve it as evidence.

Important limitation. This card is for a small business's first response. Larger or more serious incidents, and any crime, need professional help and reporting. Our role is to react correctly for the first hour and to know when to call for help.

F.9 Summary of the session

- An **improvement plan** turns findings into action: what, why, how, who, when, cost, priority.
- **Quick wins first**, then projects; use the **effort vs impact** grid.
- Give **cost-aware** advice â€" free fixes first.
- An **incident** is an event that harms security; **incident response** limits the damage.
- Six steps: **Prepare, Identify, Contain, Eradicate, Recover, Learn.**
- First hour: **disconnect, don't pay blindly, preserve evidence, change passwords from a clean device, tell the right people, restore from a clean backup.**
- Put it on a **one-page card** so staff can follow it under pressure.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

The instructor demonstrates turning the Adaeze Fashion findings into a plan, then walks through the first hour of a fictional ransomware incident.

G.1 What the instructor prepares

- The Adaeze Fashion findings table on the board (from Session 7).
- The effort vs impact 2Ã—2 grid drawn.
- Appendix 8A incident response card (blank) projected.
- A volunteer role: the instructor plays "Adaeze" and asks the class what to do.

G.2 Demonstration â€" building the improvement plan (about 8 minutes)

Say: "Watch me turn these findings into actions. I am not writing fancy words; I am writing what Adaeze can actually do."

Show the findings, then build the plan live:

#	Recommendation (What)	Why	How	Who	When	Cost	Priority
1	Put a screen lock/PIN on the phone	Stops anyone who picks it up from opening the bank app	Settings â†' Security â†' Screen lock	Adaeze	Today	â‚¦0	Now
2	Switch on MFA for bank and email	A stolen password alone can no	App â†' Security â†' Two-factor â†' turn on	Adaeze	Today	â‚¦0	Now

#	Recommendation (What)	Why	How	Who	When	Cost	Priority
		longer reach the money					
3	Change weak reused passwords to unique strong ones	Stops one leak opening every account	Use different long passwords; write them in a password manager (demo: Bitwarden)	Adaeze	Today	â‚¦0	Now
4	Change Wi-Fi password and remove card from counter	Stops strangers joining the network	Router page â†’ Wireless â†’ new long password	Adaeze/IT	Today	â‚¦0	Now
5	Switch Windows Defender back on and update laptop	Closes known weaknesses	Windows Security â†’ turn on; Windows Update â†’ check	Adaeze/IT	This week	â‚¦0	Now
6	Back up customer list to Google Drive + USB	Records survive theft/loss	Save list as a file; upload to Drive; copy to USB kept at home	Adaeze	This week	~â‚¦3,500 USB	Plan
7	Train the two staff on fake alerts	Reduces scam risk	Use CEA short awareness session / printed tips	Owner	This month	Low	Plan

Point out: "Rows 1â€“5 cost nothing and are all 'Now'. Only the USB costs a little. See how a scary findings list becomes a calm to-do list?"

Questions to ask during the demo:

- "Which of these is a quick win?" (Rows 1â€“5.)
- "Which needs money or planning?" (Backup USB, training.)
- "In row 3, what did I answer for 'why'?" (Stops one leak opening every account.)

G.3 Demonstration â€“ the first hour of ransomware (about 7 minutes)

Say: "Now the fire starts. Adaeze calls me: 'My laptop says all my files are locked and wants money in Bitcoin! What do I do?' Let us walk the first hour together."

Walk the sequence out loud, asking the class after each step:

1. **Disconnect:** "First â€“ unplug the laptop from the network and switch off Wi-Fi." Ask: "Why first?" (Stops it spreading to the backup and other devices.)
2. **Do not pay:** "I will not pay or reply. Why?" (No guarantee; funds crime; may mark us as payers.)
3. **Preserve evidence:** "I take a photo of the screen with my own phone and write the time. Why not just delete it?" (Evidence needed for IT/police.)
4. **Change passwords from a clean device:** "Adaeze uses her *other* phone to change her email and bank passwords and check MFA." Ask: "Why a clean device?" (So the compromised laptop cannot capture the new passwords.)
5. **Tell the right people:** "She tells me, tells the bank if money is involved, and reports to the police. She does not hide it."
6. **Restore from a clean backup:** "If the customer list was backed up to Drive last week, we restore the copy made *before* the attack."

As the instructor, fill the projected card as you go, so learners see the finished one-page card. Then say: "This card is the whole lesson in one page. In the drill, you will make your own."

H. GUIDED PRACTICAL EXERCISE (18 minutes)

Objective: With the instructor guiding, learners turn the Session 7 findings (their own vignette card) into a prioritised improvement plan, and start their incident response card.

Materials: Worksheet 8.1 (Improvement Plan), the Session 7 findings table, the effort vs impact grid, Appendix 8A (blank incident card).

Procedure (instructor calls out each step; learners follow; instructor walks the room):

1. **(2 min)** Take out your Session 7 findings table. Circle every finding rated **High**.
2. **(3 min) Pause and predict:** For each High finding, decide quickly whether it is a **quick win** or a **longer project**. Write Q or P beside it. Then compare with your neighbour.
3. **(6 min)** Fill Worksheet 8.1, one row per finding. Columns: **Recommendation (what) | Why | How | Who | When | Cost | Priority.** Every row must have a name in "Who" and a date in "When".
4. **(2 min) Pause again:** Sort your rows so all the **quick wins** are at the top. Say out loud which row you would do *first* and why.
5. **(3 min)** Fill the first four lines of your **incident response card** (Appendix 8A): Disconnect, Do not pay, Preserve evidence, Change passwords from a clean device. Keep each line short â€" one action per line.
6. **(2 min)** Read your card to your neighbour as if they were a staff member who is panicking. Ask them: "Could you follow this under stress?" Fix any line that is too long or too technical.

Expected result (worked example for Adaeze Fashion):

Improvement plan (top rows):

Recommendation	Why	How	Who	When	Cost	Priority
Put screen lock on phone	Stops anyone opening the bank app	Settings â†' Security â†' Screen lock	Adaeze	Today	â‚¦0	Now
Switch on MFA	Stolen password alone cannot work	App â†' Security â†' Two-factor	Adaeze	Today	â‚¦0	Now
Change weak reused passwords	Stops one leak opening all accounts	Use unique long passwords / password manager	Adaeze	Today	â‚¦0	Now

Incident card (first four lines):

- Disconnect the device from the network (unplug / Wi-Fi off).
- Do not pay or reply to any ransom message.
- Preserve evidence: photo of the screen, note the time.
- Change passwords (email, bank) from a clean phone.

Troubleshooting while walking the room:

- Learner writes a row with no "Who" or "When" â†' ask: "If nobody's name is here, who will do it? If there's no date, when?"
- Learner lists only expensive projects â†' prompt: "What is the free version of this fix?"
- Learner's card lines are paragraphs â†' ask them to cut each line to one short action.
- Learner suggests paying the ransom â†' correct gently using Section F.8.

Completion checklist (learner ticks each):

- ☐ Every High finding has a plan row
- ☐ Each row has what, why, how, who, when, cost, priority
- ☐ Quick wins sorted to the top
- ☐ At least one free fix and one costing fix identified
- ☐ Incident card has at least the first four actions
- ☐ Card read aloud and understood by a partner

I. INDEPENDENT CLASS EXERCISE (15 minutes)

Task (two parts):

1. Build a **prioritised improvement plan** for the *Blessing Bakes* findings you wrote in Session 7 (or a new short fictional set provided below).
2. Run a **mini tabletop drill** in pairs on the scenario below, and write the order of actions.

Blessing Bakes â€" short findings (use these if you did not keep last week's):

- Same password `cake2019` for email, Facebook and a loan app.
- Customer notebook has no backup.
- Delivery boys share Blessing's banking phone.
- No training on fake-order scams.

Tabletop drill scenario (read aloud):

> *It is a busy Saturday. Blessing's delivery boy picks up her phone and sees a strange message: "Your photos and files are encrypted. Pay â‚¦50,000 in gift cards within 24 hours or everything is deleted." He panics and calls Blessing. She is at the market buying flour. What should happen in the next hour?*

Requirements:

1. Write the improvement plan for the four findings (Recommendation | Why | How | Who | When | Cost | Priority).
2. For the drill: write the **first six actions** in order, and next to each, in brackets, which PICERL step it is (Prepare/Identify/Contain/Eradicate/Recover/Learn).
3. Write one sentence on why **disconnect** comes before **change passwords**.

Time allowance: 15 minutes.

Success criteria:

- Plan covers all four findings, quick wins first, with names and dates.
- Drill actions are in a safe order; Disconnect (Contain) is early.
- The explanation correctly says: disconnect first so the problem cannot spread or capture the new passwords.

Hints available if stuck:

- Hint 1: For the plan, the reused password is your number-one quick win (free, protects money).
- Hint 2: For the drill, think of our three first-hour words: stop the spread, keep the evidence, protect the accounts.
- Hint 3: Changing passwords while still connected to the infected phone defeats the purpose.

Instructor answer key / model (do not show learners):

Improvement plan:

Recommendation	Why	How	Who	When	Cost	Priority
Change `cake2019` to unique strong passwords + MFA	Stops one leak accessing money and pages	Use different long passwords; turn on two-factor	Blessing	Today	â‚¦0	Now
Stop sharing banking phone; add screen lock	Delivery boys should not reach the bank app	Screen lock/PIN; use a separate basic phone for deliveries	Blessing	Today	â‚¦0	Now
Back up customer notebook	Records survive loss/theft	Type/copy names to Drive + a USB kept at home	Blessing	This week	~â‚¦3,500	Plan

Recommendation	Why	How	Who	When	Cost	Priority
Train on fake-order/fake-alert scams	Fewer successful scams	Use CEA awareness tips / short session	Owner + staff	This month	Low	Plan

Drill â€" first six actions in order:

1. **Disconnect** the phone from mobile data/Wi-Fi and stop using it for banking. *(Contain)*
2. **Do not pay** or reply to the message; do not click anything in it. *(Contain)*
3. **Preserve evidence:** photograph the message with another phone; note the time. *(Identify/preserve)*
4. **Tell the right people:** inform Blessing (owner), her IT helper, and the bank if banking/POS is involved; report to police if it is a real crime. *(Identify/Prepare)*
5. **Change passwords from a clean device:** use another phone to change email and bank passwords and enable MFA. *(Contain/Recover)*
6. **Restore from a clean backup** (or, if none, start one immediately and plan for the future). *(Recover)*
7. *(Then)* **Learn:** meet afterwards and add the missing backup to the improvement plan. *(Learn)*

Disconnect-before-passwords explanation: You disconnect first so the harmful program cannot spread to other devices/backups, and so it cannot capture the new passwords as you type them. Changing passwords while still connected to a compromised device is unsafe.

Marking guidance (out of 10):

- Plan covers all findings (2)
- Quick wins prioritised, names/dates given (2)
- Costs are realistic and cost-aware (1)
- Drill actions in safe order (3)
- PICERL steps correctly labelled (1)
- Correct explanation of disconnect-first (1)

J. REAL-WORLD CASE STUDY

Situation. *Ngozi* runs a small POS and mobile-money business in a busy Port Harcourt junction. On a Monday morning her phone shows a message that her files are encrypted and she must pay â‚¦80,000 in gift cards within 24 hours. The phone holds her transaction records and her bank app. She is panicking and about to pay.

Relevant facts.

- Ngozi does not have a backup of the transaction records.
- MFA is not switched on for her email or bank app.
- She has a second, older phone that is not connected to the same accounts.
- She does not have an IT support person; she usually asks a nearby cyber cafÃ©.

Decision point. In the first hour, what should Ngozi do, in what order, and what should she *not* do?

Possible approaches.

1. Pay the â‚¦80,000 quickly to get the files back and carry on.
2. Delete everything, reset the phone, and start fresh â€" "clean it out."
3. Follow the first-hour sequence: do not pay; disconnect the phone from mobile data/Wi-Fi; preserve evidence (photo of the message, note the time); use the clean older phone to change email and bank passwords and switch on MFA; tell the bank and report to the police; then, with help, clean/rebuild the phone and start proper backups going forward.

Recommended solution (for this stage). Approach 3. Paying (1) is no guarantee and may fund crime and mark her as a payer; deleting and resetting (2) can destroy evidence and still leaves her accounts unprotected. The calm, correct route is to contain, preserve, protect accounts, inform the right people, then recover and put a backup in place.

Trade-offs.

- Approach 1 feels fastest but gives up the most (money, no guarantee, and encouragement to attackers).
- Approach 2 feels clean but loses evidence and does not close the door the attacker used.
- Approach 3 takes longer and feels harder in the moment, but protects money, keeps evidence, and prevents a repeat â€" which is exactly the professional response. The honest downside: with no prior backup, some transaction records may still be lost â€" which is precisely why the *plan* should have included a backup before the incident.

Professional connection. This is the daily reality of small-business IT support. The professional value is not in "beating" the attacker; it is in helping the owner make calm, correct decisions under pressure. That skill â€" knowing the order, keeping evidence, protecting accounts first â€" is a hallmark of defensive security work.

K. COMMON MISTAKES AND TROUBLESHOOTING

K.1 The plan lists problems, not actions

Symptoms: Rows read "Wi-Fi is weak" instead of "Change the Wi-Fi password." **Likely cause:** Copying the findings table instead of translating it into actions. **Corrective steps:** Rewrite every row starting with a **verb** ("Changeâ€¦", "Switch onâ€¦", "Back upâ€¦"). **How to confirm resolved:** Every row starts with a clear action. **Prevention:** For each finding ask, "What is the *doing* word?"

K.2 Recommendations with no "who" or "when"

Symptoms: Rows with blanks in Who and When; nothing gets done. **Likely cause:** Assuming the owner will figure it out. **Corrective steps:** Add a person's name and a date to every row. **Prevention:** Rule of the course â€" **no name and date, not a recommendation.**

K.3 Advice is too expensive

Symptoms: The plan is full of paid tools and new hardware for a tiny shop. **Likely cause:** Forgetting the budget of a small Nigerian business. **Corrective steps:** Re-order so free fixes come first; mark anything costing money as a "project"; keep it affordable. **Prevention:** Always ask, "Can this be done for â‚¦0 first?"

K.4 Confusing containment with cleaning

Symptoms: In the drill, learner wants to "delete the virus" immediately. **Likely cause:** Thinking cleaning comes first. **Corrective steps:** Explain the order: **contain** (disconnect) so it stops spreading, **then** preserve evidence, **then** clean/eradicate, **then** recover. **Prevention:** Keep the six steps on the wall. Contain before clean.

K.5 Suggesting to pay the ransom

Symptoms: Learner says "just pay so we get files back." **Likely cause:** Panic logic. **Corrective steps:** Explain: no guarantee; may fund crime; may mark the business as a payer. Do not pay blindly; seek advice and report. **Prevention:** Repeat the first-hour card line: "Do not pay or reply."

K.6 Wiping the device and destroying evidence

Symptoms: Learner resets the phone/computer straight away. **Likely cause:** Wanting a clean slate. **Corrective steps:** Preserve evidence first (photos, notes), get advice, and only then rebuild. Do not switch off or wipe a device that may hold evidence unless advised. **Prevention:** The fire-drill comparison: you do not bulldoze the house before the fire officer inspects it.

K.7 Changing passwords while still on the infected device

Symptoms: Learner changes the bank password on the compromised phone. **Likely cause:** Not thinking about capture. **Corrective steps:** Always change passwords from a **clean, unaffected** device. **Prevention:** Add this explicitly to every incident card.

Distinguish likely vs confirmed: Confirm before acting â€" e.g., confirm a device really is disconnected, and confirm a backup really predates the incident before restoring from it.

L. SESSION ASSIGNMENT

Assignment title: "Improvement Plan and Incident Response Card for a Fictional Business"

Purpose: Practise writing a cost-aware, prioritised improvement plan from findings, plus a realistic one-page incident response card.

Realistic scenario: Use the fictional business you created for the Session 7 assignment (or reuse one of the vignette cards). Produce both a plan and a card.

Detailed instructions:

1. Take your Session 7 findings table. For each finding, write one row in your improvement plan with columns: **Recommendation | Why | How | Who | When | Cost | Priority**.
2. Sort the rows so **quick wins come first**.
3. Make sure at least **two rows are free (â‚¦0)** and clearly mark which are "quick wins" and which are "projects."
4. Create a **one-page incident response card** with the six first-hour actions in order (disconnect, do not pay, preserve evidence, change passwords from a clean device, tell the right people, restore from a clean backup). Keep each line to one short, plain instruction that a non-technical staff member could follow.
5. Add a **short "Prepare" note** at the top of your card listing three things the business should do *before* any incident (e.g., start backups, print this card, keep a clean phone).

Required deliverables:

- Improvement plan (one row per finding, with all seven columns).
- One-page incident response card.
- "Prepare" note (three items). All on paper or in a document.

Submission format: Hand in on paper, or upload as a document named `CEA-Sec-YourName-S8-Assignment`.

Deadline: Before Session 9 (capstone day).

Marking rubric (20 marks):

Criterion	Marks	Description of a strong answer
Every finding turned into an action	3	Actions start with a verb and match the findings
What/why/how/who/when/cost/priority complete	4	All columns filled; names and dates present
Quick wins prioritised first	3	Free/low-effort fixes at the top
Cost-aware advice	3	Realistic for a small Nigerian business; free first
Incident card correct and usable	4	Six actions in safe order; short, plain lines
Prepare note	2	Three sensible preparation actions
Clarity / no jargon	1	A non-technical owner could follow it

Common mistakes to avoid: listing problems instead of actions; missing who/when; over-expensive advice; wrong incident order (cleaning before containing); suggesting to pay the ransom; changing passwords on the infected device.

Instructor reference solution (model for Adaeze Fashion):

Improvement plan (top rows):

Recommendation	*Why*	*How*	*Who*	*When*	*Cost*	*Priority*
Put a screen lock on the phone	*Stops anyone opening the bank app*	*Settings â†' Security â†' Screen lock*	*Adaeze*	*Today*	*â‚¦0*	*Now*
Switch on MFA for bank + email	*A stolen password alone can't reach the money*	*App â†' Security â†' Two-factor*	*Adaeze*	*Today*	*â‚¦0*	*Now*

Recommendation	Why	How	Who	When	Cost	Priority
Replace weak reused passwords	*Stops one leak opening all accounts*	*Unique long passwords / password manager*	*Adaeze*	*Today*	*â‚¦0*	*Now*
Back up customer list off the phone	*Records survive theft/loss*	*Save list â†' Google Drive + USB at home*	*Adaeze*	*This week*	*~â‚¦3,500*	*Plan*
Train staff on fake alerts	*Fewer successful scams*	*CEA awareness session / printed tips*	*Owner*	*This month*	*Low*	*Plan*

Prepare note: *(1) Start weekly backups to Drive + USB. (2) Print and post this card. (3) Keep one clean, unshared phone/email for emergencies.*

Incident card: *(1) Disconnect from network. (2) Do not pay or reply. (3) Preserve evidence (photo + time). (4) Change email/bank passwords from a clean phone. (5) Tell owner, IT, bank, police. (6) Restore from a clean backup.*

M. KNOWLEDGE CHECK

(Learner version â€" answers only in the Instructor Key below.)

Q1. Short answer. What is the difference between a findings table and an improvement plan?

Q2. Multiple choice. In an improvement plan, what does "quick win" mean? a) A cheap fix that also removes a high risk. b) A fix that takes months. c) Any expensive purchase. d) A fix nobody needs to do.

Q3. List and explain. Name the five questions a clear recommendation should answer.

Q4. Ordering. Put the six incident-response steps in the correct order: Recover, Prepare, Learn, Contain, Identify, Eradicate.

Q5. Short answer. Why should affected devices be **disconnected from the network** as an early step?

Q6. True or false, with reason. "If ransomware locks your files, the fastest solution is to pay and get them back."

- True / False. Why?

Q7. Scenario. A staff member's laptop suddenly shows a ransom note. Write the **first four** actions you would take, in order.

INSTRUCTOR ANSWER KEY (Q1â€"Q7)

A1. A findings table describes **what is wrong** (issue, risk level, reason). An improvement plan describes **what to do about it** (action, why, how, who, when, cost, priority). The findings table is the diagnosis; the plan is the treatment.

A2. (a) A cheap (usually free) fix that also removes a high risk.

A3. What (the action), **Why** (the risk it removes), **How** (the simple steps), **Who** (the person responsible), **When** (the deadline). (Cost is a helpful sixth.)

A4. Prepare â†' Identify â†' Contain â†' Eradicate â†' Recover â†' Learn.

A5. To stop the problem spreading to other devices, backups, or the network, and to prevent it capturing new passwords typed during the response (e.g., for ransomware, also stops encryption spreading to shared/backup drives).

A6. False. Paying does not guarantee the files return, it may fund criminals, and it may mark the business as a willing payer. The correct first response is: disconnect, do not pay blindly, preserve evidence, protect accounts, tell the right people, and restore from a clean backup (with reporting where appropriate).

A7. Any reasonable order starting with containment:

1. Disconnect the laptop from the network (unplug/disable Wi-Fi/mobile data). *(Contain)*
2. Do not pay or reply to the ransom; do not click anything in it.
3. Preserve evidence: photograph the screen with another device and note the time; do not delete or wipe.

4. Tell the right people (owner, IT support; bank/police if money or crime is involved). *(Then continue: change passwords from a clean device, then restore from a clean backup.)*

N. REFLECTION AND RECAP

Plain-English summary. Today you learned to turn a findings table into an **improvement plan** â€" a prioritised, cost-aware to-do list that a small business can actually follow. You used **quick wins versus projects** and the **effort vs impact** grid, and learned to write recommendations answering **what, why, how, who, when**. Then you learned that an **incident** is any event that harms security, and you learned the six response steps â€" **Prepare, Identify, Contain, Eradicate, Recover, Learn** â€" plus the first-hour actions for a suspected breach or ransomware. Finally, you built a one-page **incident response card** that a non-technical staff member could follow under stress.

Five important takeaways:

1. Findings tell you **what is wrong**; the plan tells you **what to do**, in order.
2. **Quick wins first** â€" free fixes that remove High risks; then plan the projects.
3. A clear recommendation answers **what, why, how, who, when** (and cost).
4. Incident steps: **Prepare, Identify, Contain, Eradicate, Recover, Learn.**
5. First hour: **disconnect, don't pay, preserve evidence, change passwords from a clean device, tell the right people, restore from a clean backup.**

Questions to help you recognise what you can now do:

- Can I turn each finding into an action with a name and a date?
- Can I explain the difference between containing and cleaning an incident?
- Can I list the six steps in order from memory?
- Would a panicking staff member be able to follow my incident card?

Connection to the next session: You now have all the pieces: a findings table, an improvement plan, and an incident response card. In **Session 9** you build the **capstone** â€" a complete defensive security assessment report for the fictional *Adaeze Fashion*, including an executive summary, scope and authorisation, method, findings table, prioritised improvement plan, incident card, and conclusion â€" then you **present it** and answer viva questions. This is your certificate project.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- Learner's plan rows start with **verbs** and include who and when.
- Learner puts **free/quick wins at the top** and marks projects separately.
- Learner's incident card is **short, ordered and plain** â€" usable under stress.
- Learner explains **contain-before-clean** correctly.
- Learner refuses to pay the ransom and says why.
- Learner changes passwords from a **clean device**, not the affected one.

Common misconceptions to watch for and correct:

- "The plan is the findings table with a new title." â†' Plan = actions, with who/when/cost.
- "Buy the best tools." â†' Free fixes first; fit the budget.
- "Clean the virus immediately." â†' Contain and preserve evidence first.
- "Pay the ransom." â†' No; no guarantee, funds crime. Do not pay blindly.
- "Change passwords on the infected phone." â†' Use a clean device.
- "Don't tell anyone." â†' Tell the right people early.

Suggested remedial exercises for learners who struggle:

1. **Verb drill:** give five problem statements and ask the learner to rewrite each as an action starting with a verb.
2. **Order-the-cards drill:** hand out the six PICERL cards shuffled, the learner arranges them.

3. **First-hour drill:** read three short scenarios; the learner writes the first three actions each time.
4. **Card-writing drill:** ask the learner to explain their incident card to a partner acting as a panicking staff member.

Differentiation:

- **Level 1 (supported):** provide a partly filled improvement plan (two rows done) and an incident card with the first two lines completed; the learner finishes.
- **Level 2 (standard):** the exercise as written.
- **Level 3 (challenge):** add a **cost column in naira** with a total budget line, and split the plan into "Week 3 (this week)" and "Month 1" schedules; add a short "who to call" list to the incident card (IT, bank, police, internet provider).

Timing guidance: The incident-response portion (Sections F.6â€"F.8 and the drill) is the emotional heart and must not be skipped. If time is short, compress the improvement-plan lecture and protect the tabletop drill. If the room is fast, run a second, different tabletop scenario (e.g., a stolen phone with an open banking app).

APPENDIX 8A â€" MY INCIDENT RESPONSE CARD (template)

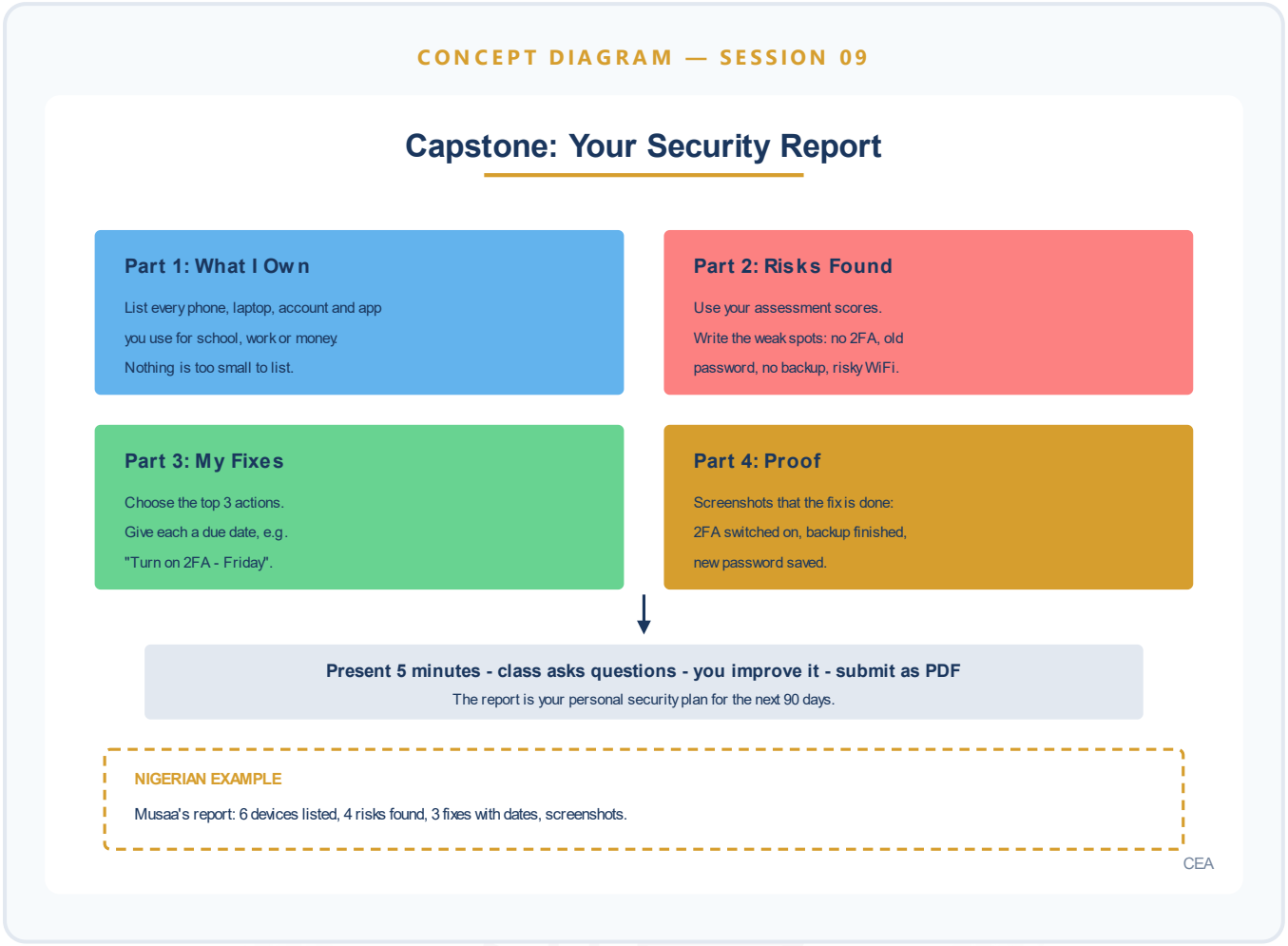
> ***Incident Response Card â€" [Business name]***
>
> ***Prepare (before any incident):***
>
> 1. _____
> 2. _____
> 3. _____
>
> ***If something goes wrong â€" first hour:***
>
> 1. *Disconnect the device from the network. (unplug / Wi-Fi off / mobile data off)*
> 2. *Do not pay or reply to any ransom message.*
> 3. *Preserve evidence: photograph the screen with another phone; write the time.*
> 4. *Change your email and bank passwords â€" from a clean, unaffected device.*
> 5. *Tell the right people: owner/manager, IT support, bank, and (for a crime) the police.*
> 6. *Restore from a clean backup made before the incident.*
>
> ***Who to call:*** *IT: _____ Bank: _____ Police: _____ Internet provider: _____*

END OF SESSION 8

Next: Session 9 â€" Capstone: Security Assessment Report and Presentation.

SESSION 09 OF 9

Capstone Report



CYBER ELIAS ACADEMY â€" CYBERSECURITY

SESSION 9 â€" CAPSTONE: SECURITY ASSESSMENT REPORT AND PRESENTATION

A. SESSION IDENTIFICATION

Item	Detail
Session number	9 of 9 (final session)
Session title	Capstone: Security Assessment Report and Presentation
Week / Module	Week 3 â€" Module 3: Assess and Improve (capstone build and present)
Recommended duration	105 minutes (build, finalise, present, viva)
Difficulty level	Beginner (final integration of all skills)

Item	Detail
Prerequisite knowledge	Sessions 1â€"8. Learners must have produced a findings table (S7) and an improvement plan plus incident response card (S8). They must be able to explain the permission/scope rule, the eight rooms, risk = likelihood Ã— impact, and the six incident steps.
Connection to previous work	Everything in this course has been building toward this single deliverable: a complete **defensive security assessment report and prioritised improvement plan** for an authorised, fictional business. The capstone is the certificate project; presenting it also completes LO10.
Preparation before class	Academy PCs on; projector ready for presentations; a timer visible; printed **Capstone Rubric** (Section L) for each presenter; printed **Viva Question List** (Section M) for the instructor; the *Adaeze Fashion* running example complete report skeleton on the board; a class folder `CEA-Sec-Name` for submissions; refreshments arrangement for the brief closing (optional).

B. LEARNING OUTCOMES

By the end of this session, the learner will be able to:

1. **Assemble** a complete defensive security assessment report for a fictional, authorised business, containing all required sections.
2. **Justify** the scope and authorisation statement, and demonstrate the ethics of assessing only permitted systems.
3. **Present** their findings table, risk ratings, and prioritised improvement plan clearly to a non-technical audience.
4. **Defend their decisions** in a short viva, answering questions about risk ratings and recommendations.
5. **Demonstrate** one hardened, defensive action live (e.g., showing MFA switched on, or a backup completed) on their own academy account/device.
6. **Explain honestly** what this qualification does and does not make them: a safer user and a junior IT-support beginner with defensive awareness â€" **not** a hacker or penetration tester.

C. REQUIRED MATERIALS

Hardware

- One computer per learner for finalising and presenting.
- Instructor computer connected to a projector or large screen for presentations.
- A visible timer (projector clock or phone).

Software

- A word processor for the report and slides/notes for the presentation.
- No attack tools, no scanning tools, no live systems. All targets are fictional and paper-based.

Printed materials

- The **Capstone Rubric** (Section L) â€" one per presenter and one for the instructor.
- The **Viva Question List** (Section M) â€" instructor copy.
- The learner's own Session 7 findings table and Session 8 improvement plan and incident card.
- Any vignette card / own invented business profile.

Accounts

- Learners' **own** academy email account (for the live demonstration of MFA/backup only). No client accounts, no real business data.

Internet

- Optional, only for the live demonstration of turning on MFA on the learner's own email, or uploading a dummy file to their own Drive. If the internet is down, the learner describes the action and shows the settings on Windows instead.

Safety and ethics note for the instructor: Repeat at the start and at the demo: all targets are fictional; the only live system touched is the learner's **own** academy account, with their consent; nothing is done to any other person's system.

D. OPENING ACTIVITY (6 minutes)

Instructor setup: On the projector, show a finished-looking one-page report cover:

> ***DEFENSIVE SECURITY ASSESSMENT Prepared for:*** *Adaeze Fashion, Port Harcourt* ***Prepared by:*** *[Your name], Cyber Elias Academy* ***Date:*** *October 2026* ***Authorised assessment of a fictional business â€" training use only.***

What the instructor says:

> *"For eight weeks we have been building one skill at a time: spotting scams, strong passwords and MFA, safe browsing, phishing, hardening devices, Wi-Fi and backups, then assessing a business, then writing a plan and an incident card. Today all of it comes together into* ***one document*** *that a real business would pay for â€" and then you stand up and present it.*
>
> *This is your certificate project. It is not about being clever or fast. It is about being* ***careful, honest, and clear****. A business owner reading your report should feel calmer, not more confused. That is the standard."*

Ask the class: "Which single document would you want a new business to have ready *before* anything bad happens?"

Expected learner response: Learners will suggest the improvement plan, the incident response card, backups, MFA. Accept all, then connect:

> *"Right â€" and your capstone report bundles all of these together: what is wrong (findings), what to do (plan), and what to do if it happens anyway (incident card). Plus the executive summary that a busy owner reads first. Today you finish it and present it."*

Why this opener works: It frames the capstone as a real, saleable professional document and sets a clear quality standard ("the owner should feel calmer"), which reduces anxiety about presenting.

E. PREREQUISITE REVIEW (7 minutes)

Run as a fast oral round-robin. These prompts restate the exact ingredients the learner must put into the report.

Question 1: "What must come before any assessment, and what is it called?"

- Expected answer: written permission and a defined scope (scope and authorisation).
- Common gap: saying "the owner's trust." Clarify: trust is good but it must be **written** and scoped.

Question 2: "Name four of the eight rooms again."

- Expected answer: any four of accounts/passwords, MFA, updates, antivirus/firewall, Wi-Fi, backups, staff awareness, data handling.
- Common gap: forgetting backups or data handling. Prompt them.

Question 3: "How do you rate risk, and what are the three levels?"

- Expected answer: likelihood Ã— impact â†' Low/Medium/High. Reason required.
- Common gap: leaving out the reason. Repeat: no reason, no rating.

Question 4: "In an incident, what is the very first action and why?"

- Expected answer: disconnect from the network, to stop it spreading.
- Common gap: "call the owner" â€" acceptable but containment comes first.

Question 5: "What is the difference between a findings table and an improvement plan?"

- Expected answer: findings = what is wrong; plan = what to do, in order, with who/when/cost.

Bridge to today (say this):

> *"You already have every ingredient. Today you simply put them into one neat report, add the executive summary at the front and the conclusion at the end, and take the stage. The viva is not a trap â€" it is a conversation to check that the report is truly yours and that you understand it."*

If a learner has **not** completed the Session 7 and 8 assignments, use the first 15 minutes of the practical to help them finish the findings table and plan using the Adaeze Fashion running example (Appendix 9A), so they can still build a report.

F. FULL LECTURE NOTES

F.1 What the capstone is (restated)

Plain-English definition. The **capstone** is a complete **defensive security assessment report and prioritised improvement plan** for an **authorised, fictional** business â€" for example, *Adaeze Fashion, Port Harcourt*. It gathers everything you learned into one professional document, which you then **present** and defend in a short **viva** (a spoken question-and-answer).

Why it exists. Employers and clients do not pay for isolated skills; they pay for **a clear deliverable**. A report proves you can take a messy real-world situation and produce something useful and trustworthy. It also proves you understand the ethics: the report itself states its **scope and authorisation**, showing you know you may only assess permitted systems.

What it contains. Six core parts plus a plan and a card:

1. Executive summary
2. Scope and authorisation
3. Method
4. Findings table with risk ratings
5. Prioritised improvement plan
6. Incident response card
7. Conclusion

Familiar analogy. The capstone is like a **final-year project** or a **building inspection report**. The inspector visits, measures, writes a clear report with photos and a list of repairs in priority order, and signs it. The owner can act on it. That is exactly what you produce.

Important limitation / misconception. "The capstone means I can now work as a hacker or penetration tester." **No.** This course is **defensive only**. The capstone proves you can assess and advise â€" a safer user and a junior IT-support beginner with defensive awareness. It does **not** make you a penetration tester, and it does **not** authorise you to test anyone's system. See Section O and the course wrap-up.

F.2 Milestone checkpoints â€" what should be done before S9

Good reports are not written in one sitting. Here are the checkpoints a successful learner should have already reached. The instructor should confirm these at the start.

Checkpoint	Due	What "done" looks like
M1 â€" Business chosen and described	End of S7	A one-paragraph profile of the fictional business (or a vignette card chosen)
M2 â€" Scope and authorisation drafted	End of S7	A written statement: fictional business, what is included, what is excluded, permission for training
M3 â€" Findings table complete	End of S7 assignment	6+ findings, each with risk level and reason

Checkpoint	Due	What "done" looks like
M4 â€" Improvement plan complete	End of S8 assignment	Every finding turned into an action with who/when/cost, quick wins first
M5 â€" Incident response card complete	Middle of S8	One-page card with the six first-hour actions + a Prepare note
M6 â€" Report assembled	Start of S9 (today)	All sections present in order, in one document
M7 â€" Presentation prepared	Within S9 build time	Short spoken walkthrough + one live demonstration ready
M8 â€" Submitted to class folder	End of S9	Report file in `CEA-Sec-Name`

Say this to the class: "If you did your S7 and S8 assignments, you are already 80% done. Today is assembly, polish, and the stage."

F.3 The required report structure

Write the report in this order. Each part has a clear job.

1. Title page.

- Title: *Defensive Security Assessment Report*.
- Prepared for: the fictional business name.
- Prepared by: your name, Cyber Elias Academy.
- Date.
- A clear line: *"Fictional business â€" authorised training assessment only."*

2. Executive summary (about half a page).

- The single most important part for a busy owner.
- Plain English, no jargon. States: what was assessed, the overall state of security, the **top three risks**, and the **top three recommended actions**. An owner should be able to read only this page and still know what to do first.
- Example sentence: *"Overall, the business's security is weak in three areas. The most urgent issue is that one weak password protects the bank, email and social media at once. We recommend switching on MFA today (free) as the first step."*

3. Scope and authorisation.

- State the business (fictional), the person authorising (the owner), what is **included**, what is **excluded**, the date, and that it is for **training only**. This proves you follow the ethics rule.

4. Method.

- How you assessed: "The eight-room checklist; observation and interview; no system was changed; no other system was tested." Keep it short and honest. Do not claim screenshots or scans you did not do.

5. Findings table.

- Columns: **Issue | Risk Level | Reason | Priority**. Every row has a reason mentioning likelihood and impact.

6. Prioritised improvement plan.

- Columns: **Recommendation | Why | How | Who | When | Cost | Priority**. Quick wins first; free fixes before paid.

7. Incident response card.

- The one-page card: Prepare note + the six first-hour actions.

8. Conclusion.

- A short, honest closing: what the biggest risks are, what should happen next, and a note that with the recommended free fixes started today, the business's risk is meaningfully reduced. Thank the owner and offer the next review date.

Say this to the class: "Notice the report has a *front* an owner reads (executive summary), a *middle* that is the evidence, and a *back* that is the action. Neat, ordered, professional."

Misconception. "More pages = better." No. A clear, well-ordered report of a few pages beats a long, confusing one. Clarity is the mark of competence.

F.4 The live demonstration (what it adds)

The capstone includes one **live demonstration** of a defensive action on your **own** academy account or device. This proves you can *do*, not just describe.

Choose **one**:

- Show MFA switched on for your own academy email (walk through the settings).
- Show a backup completed: upload a dummy file to your own Google Drive and show the copy exists.
- Show Windows Defender and the firewall switched on, and updates set to automatic.
- Show your own file saved into a password manager (if the demo is available).

Rules for the demo:

- Only your **own** academy account/device. Never anyone else's.
- Explain *why* the action reduces risk (one sentence).
- Expected result: the setting visibly shows it is on, or the backup copy visibly exists.
- What to watch: if internet fails, describe the action and show the setting on Windows instead. Do **not** claim a screenshot you do not have.

F.5 Summary of the session

- The capstone is a complete defensive assessment **report** for a fictional, authorised business.
- Structure: executive summary, scope/authorisation, method, findings, plan, incident card, conclusion.
- Meet the milestones (M1â€“M8); most of the work is already done from S7 and S8.
- Present clearly to a non-technical owner; defend your reasoning in the viva.
- Demonstrate one hardened action live on **your own** system.
- Be honest about what the certificate means â€” a safer user / junior IT-support beginner, not a hacker.

G. INSTRUCTOR DEMONSTRATION (15 minutes)

The instructor demonstrates how to assemble a *complete* report for Adaeze Fashion and how to present it, so learners see the finished standard.

G.1 What the instructor prepares

- The complete Adaeze Fashion report (Appendix 9A) partly on screen, partly on the board.
- A stopwatch.
- The rubric projected so learners can see what is being marked.

G.2 Demonstration â€” assembling the report (about 8 minutes)

Say: "Watch me put the pieces in order. I already wrote the findings and the plan in Sessions 7 and 8 â€” now I just arrange them and write the front and back."

Show each section on the projector in order, narrating the *job* of each:

1. **Title page** â€” "states who, what, when, and that it is fictional."
2. **Executive summary** â€” read the sample aloud (from Appendix 9A). Point out that it names the **top three risks** and **top three actions** only â€” no jargon.
3. **Scope and authorisation** â€” read the sample; point at "fictional â€” training only."
4. **Method** â€” "eight rooms, observation and interview, nothing changed."
5. **Findings table** â€” "the evidence; every row has a reason."
6. **Improvement plan** â€” "quick wins first; free before paid."

7. **Incident card** â€" "one page a staff member can follow."
8. **Conclusion** â€" "what to do next, and thank the owner."

Say: "See? The capstone is not a new mountain. It is the work you already did, arranged beautifully and given a good cover."

G.3 Demonstration â€" presenting (about 7 minutes)

Say: "Now the stage. Let me present Adaeze Fashion's report in three minutes, and notice what I do."

Present in this order (model the timing):

1. **Greeting and one-line summary** (15 seconds): "Good morning. I assessed Adaeze Fashion's security and here are the three most important things."
2. **The top three findings with a plain reason each** (60 seconds).
3. **The top three actions, quick wins first** (45 seconds).
4. **The incident card in one sentence** (15 seconds).
5. **Live demonstration of one defensive action** (30 seconds).
6. **Close** (15 seconds): "With the free fixes started today, the risk drops a lot. Thank you."

Point out the habits that earn marks:

- Speak to the owner, not to the screen.
- Always give a **reason**, never just "High."
- Say "fictional business" at least once.
- Keep to time.
- Be calm and honest about limits ("I did not test any system; I observed with permission.")

Questions to ask the class:

- "What did I say instead of 'it's High'?" (Likelihood and impact reason.)
- "What did I demonstrate, and on whose account?" (One action, my own.)

H. GUIDED PRACTICAL EXERCISE (18 minutes) â€" Capstone build

Objective: With the instructor guiding, each learner assembles their capstone report from their S7 and S8 work and prepares a short presentation.

Materials: Learner's S7 findings table, S8 improvement plan, S8 incident card, the report structure (F.3), the rubric (L), a word processor.

Procedure (instructor calls out each step; learners follow; instructor walks the room):

1. **(2 min)** Create the file `CEA-Sec-YourName-Capstone` in the class folder. Add the title page (who, what, when, "fictional â€" training only").
2. **(3 min) Pause and plan:** On paper, write your **top three** risks and your **top three** actions. These will become your executive summary.
3. **(4 min)** Write the **executive summary** (half a page, no jargon). Check: does it name the top three risks and top three actions?
4. **(2 min)** Paste your **scope and authorisation** statement and your **method** paragraph (from Session 7/8).
5. **(3 min)** Paste your **findings table** and **improvement plan**, and **incident card**. Make sure the plan has each finding turned into an action, quick wins first.
6. **(2 min)** Write the **conclusion** (three or four sentences).
7. **(2 min) Pause and rehearse:** read your executive summary aloud to your neighbour in under one minute. Ask them: "Would a busy shop owner understand this?"

Expected result: A complete report containing the title page, executive summary, scope/authorisation, method, findings table, improvement plan, incident card, and conclusion â€" in order. A short spoken summary ready.

Troubleshooting while walking the room:

- Executive summary full of jargon â†' rewrite: "weak password", "backup", not "credential hygiene" or "risk surface."

- Missing scope/authorisation â†' add it now; it is a marked item.
- Plan rows missing who/when â†' fix before submitting.
- Learner wants to assess a real shop â†' stop and redirect to the fictional example.
- Learner's demo would touch someone else's account â†' redirect to their **own** academy account.

Completion checklist (learner ticks each):

- ☐ Title page with "fictional â€" training only"
- ☐ Executive summary names top 3 risks and top 3 actions
- ☐ Scope and authorisation present
- ☐ Method present
- ☐ Findings table with reasons
- ☐ Improvement plan with quick wins first, who/when/cost
- ☐ Incident card included
- ☐ Conclusion present
- ☐ Report saved in `CEA-Sec-YourName`

I. INDEPENDENT CLASS EXERCISE (15 minutes) â€" Present and viva

Task: Each learner **presents** their capstone report (3 minutes) and answers **viva questions** (2 minutes). The instructor and class use the rubric.

Objective: Demonstrate clear presentation and defend the reasoning behind findings, risk ratings and recommendations.

Materials: Projector; timer; rubric (L); viva list (M).

Procedure:

1. **(1 min)** Instructor explains the format: 3 minutes present + 2 minutes viva, per learner. While one presents, others listen and note one strength and one question.
2. **(2 min)** First presenter sets up; instructor starts the timer.
3. **(12 min)** Each learner presents their report and demonstration, then answers 2â€"3 viva questions from Section M. The instructor scores live using the rubric.

Presentation expectations (restate to the class):

- Greeting and one-line summary.
- Top three findings, each with a reason.
- Top three actions, quick wins first.
- One sentence on the incident card.
- One live defensive demonstration on your own account.
- Honest close and thanks.

Viva expectations: Answer in plain English; if you do not know, say so honestly and explain your reasoning â€" this is acceptable and even expected of a beginner.

Instructor answer key / model viva answers: see Section M (the full viva key). The instructor listens for the **ideas**, not exact words.

Success criteria (per learner):

- Report is complete and in order.
- Presentation clear, in time, with reasons given.
- Viva answers show understanding, not memorisation.
- Live demonstration is on the learner's own system and reduces risk.

Hints available if stuck (during presentation):

- Hint 1: If you forget a finding, read it from your table â€" that is allowed.
- Hint 2: If a viva question is hard, restate the question and answer the part you know.
- Hint 3: Always name your top risk and its reason â€" that is the heart.

Note to instructor: This is the graded practical of the course (simulation 15 + capstone 30 + viva 5 in the assessable mark distribution). Pace strictly so every learner presents.

J. REAL-WORLD CASE STUDY

Situation. *Adaeze Fashion* is a fictional but realistic Port Harcourt fashion business (the course's running example). Adaeze runs the shop on one Android phone used for banking, POS and WhatsApp Business; she shares it with her assistant; she reuses one weak password; MFA is off; the Wi-Fi password is on a card at the counter; there is no backup of her customer list; her two staff have never been trained on scams; and the back-office Windows laptop has Defender off and is months behind on updates.

Relevant facts.

- The most dangerous single issue is the reused weak password: one leak would expose her bank, email and social media together.
- Several High-risk issues are **free** to fix today (screen lock, MFA, password change, Wi-Fi password, Defender on).
- The backup and the staff training are small projects.
- No incident has happened yet â€" but the risk is real.

Decision point. If the business can only act on **one thing today**, what should it be, and why â€" and what comes second and third?

Possible approaches.

1. Buy an expensive security suite and hope it solves everything.
2. Do the free quick wins first, then plan the projects.
3. Wait until there is a real problem.

Recommended solution. Approach 2. Today: switch on MFA and change the reused password (free, protects money), put a screen lock on the phone (free), change the Wi-Fi password and remove the card (free), switch Defender on and update the laptop (free). This week: start a backup to Google Drive + a USB. This month: train the two staff. This mirrors the prioritised plan and the capstone report exactly.

Trade-offs.

- Approach 1 spends money before addressing the free, highest-impact risks â€" poor value.
- Approach 2 removes most of the immediate danger at little or no cost, then invests sensibly.
- Approach 3 leaves the business exposed for no benefit; risk depends on likelihood and impact, not on whether anything has happened yet.

Professional connection. This is precisely the judgement a junior IT-support person or consultant must exercise: protect the money and the accounts first, spend nothing where free fixes suffice, and set a realistic plan for the rest. The capstone report is the professional expression of this judgement.

K. COMMON MISTAKES AND TROUBLESHOOTING

These are the **most common failure points in the capstone** and how to fix each.

K.1 Missing scope and authorisation statement

Symptoms: The report jumps straight into findings. **Why it fails:** It fails the **scope/ethics** criterion and shows the learner did not follow the course's central rule. **Corrective steps:** Add a short section stating: fictional business, owner authorising, included, excluded, date, "training only." **How to confirm resolved:** The reports opens with a clear, written permission statement. **Prevention:** Write scope *first*, before any findings.

K.2 Jargon-filled executive summary

Symptoms: The summary uses words like "threat surface," "credential hygiene," "attack vector." **Why it fails:** The owner cannot act on it; it fails the clarity criterion. **Corrective steps:** Rewrite in plain words: "weak password," "backup," "not trained." Aim for a busy owner to understand it in one reading. **Prevention:** Write the summary as if speaking to Adaeze herself.

K.3 Risk ratings with no reasons

Symptoms: A column of "High/High/High." **Why it fails:** Fails the risk-rating criterion; looks like guessing. **Corrective steps:** Add a likelihood-and-impact reason to every row. Re-check for at least one satisfactory/Low finding. **Prevention:** Rule of the course â€” no reason, no rating.

K.4 Improvement plan lists problems, not actions

Symptoms: Rows read "Wi-Fi weak" instead of "Change the Wi-Fi password." **Why it fails:** The plan cannot be acted on. **Corrective steps:** Rewrite each row starting with a verb; ensure who/when/cost are filled. **Prevention:** For each finding ask, "What is the doing word?"

K.5 Assessing or demonstrating on a real/third-party system

Symptoms: Learner wants to "check" a real shop's Wi-Fi or someone else's phone during the demo. **Why it fails: Serious ethics breach**; must never happen. **Corrective steps:** Stop immediately; redirect to the fictional report and the learner's own academy account. **Prevention:** Repeat the permission rule before the demo; the only live system is your own.

K.6 Overrunning time in the presentation

Symptoms: Presenter runs past 3 minutes; later learners get squeezed. **Corrective steps:** Instructor signals time; presenter jumps to top actions and close. **Prevention:** Rehearse; lead with the top three.

K.7 Claiming screenshots/scans not done

Symptoms: Report says "screenshots attached" or "port scan performed" when none was. **Why it fails:** Dishonest; a professional report must be accurate. **Corrective steps:** Remove the claim; describe only what was actually observed/recorded. **Prevention:** Write only what you did. Honesty is marked.

K.8 Not demonstrating a live action

Symptoms: No demo during the presentation. **Corrective steps:** Show one setting (MFA, backup, Defender) on your own account and explain why it reduces risk. **Prevention:** Prepare the demo before the session.

Distinguish likely vs confirmed: In your report, say what you **observed** and how you know it (who showed you / where you looked). Do not present a guess as a confirmed fact.

L. SESSION ASSIGNMENT â€” THE CAPSTONE (and full rubric)

Assignment title: "Capstone â€” Defensive Security Assessment Report and Presentation for Adaeze Fashion (or your chosen fictional business)."

Purpose: Integrate every skill in the course into one professional deliverable and present it.

Realistic scenario: You are a junior IT-support helper engaged to assess a fictional, authorised small business. You produce a report the owner can act on, and you present it to the owner (played by the class/instructor).

Detailed instructions: see Section F.3 (required report structure) and the milestones in F.2. The report must contain, in order: title page; executive summary; scope and authorisation; method; findings table; prioritised improvement plan; incident response card; conclusion. Then present it (3 minutes) and answer viva questions (2 minutes), including one live defensive demonstration on your **own** account.

Required deliverables:

- Capstone report (all sections in order), file `CEA-Sec-YourName` in the class folder.
- Presentation (spoken; slides optional).
- One live defensive demonstration on your own academy account.
- Viva answers.

Submission format: Report file in the class folder `CEA-Sec-Name`; presentation live in class; demo live.

Deadline: End of Session 9.

CAPSTONE RUBRIC (30 marks + 5-mark viva/demo = 35)

#	Criterion	Marks	Performance descriptions
1	**Scope & authorisation / ethics**	4	**4 (Excellent):** Clear written statement; fictional target named; included/excluded items; "training only"; demonstrates full understanding of permission. **3 (Good):** Statement present and mostly complete. **2 (Fair):** Statement present but vague (no exclusions, or no fictional note). **1 (Weak):** Mentioned in passing only. **0:** Absent, or shows intent to assess a real/unauthorised system.
2	**Assessment thoroughness**	4	**4:** All eight rooms addressed (or "not stated" noted); findings are specific and observable. **3:** Sixâ€"seven rooms covered. **2:** Fourâ€"five rooms. **1:** Oneâ€"three rooms. **0:** No structured coverage.
3	**Risk-rating accuracy**	5	**5:** Every finding rated with likelihood Ã— impact and a clear reason; mix of levels; at least one satisfactory/Low finding. **4:** Ratings mostly correct with reasons; minor slip. **3:** Ratings present but reasons thin or one clearly wrong. **2:** Several ratings unjustified or all High. **1:** Ratings mostly wrong or missing. **0:** No ratings.
4	**Improvement plan quality & prioritisation**	5	**5:** Every finding turned into an action with what/why/how/who/when/cost; quick wins first; cost-aware for a small Nigerian business. **4:** Plan complete; prioritisation mostly good. **3:** Plan present; some rows lack who/when or cost-awareness. **2:** Plan lists problems not actions, or missing priorities. **1:** Very thin plan. **0:** No plan.
5	**Incident response**	4	**4:** One-page card with a Prepare note and the six first-hour actions in safe order; short, plain, usable. **3:** Card mostly complete and in order. **2:** Card present but out of order or too long. **1:** Fragmented incident notes. **0:** No incident content.
6	**Report clarity & professionalism**	4	**4:** Neat, ordered, plain English; executive summary names top 3 risks and top 3 actions; no jargon; no false claims. **3:** Clear and mostly ordered. **2:** Understandable but disorganised or jargony. **1:** Hard to follow. **0:** Missing key sections / misleading.
7	**Presentation**	4	**4:** Within time; clear; top findings with reasons; top actions; speaks to the owner; honest close. **3:** Clear but slightly over time or thin on reasons. **2:** Read haltingly; little reasoning. **1:** Largely unclear. **0:** Did not present.
	Subtotal (capstone)	**30**	
8	**Viva & live demonstration**	5	**5:** Answers show genuine understanding; live action on **own** account with a clear "why"; handles a hard question honestly. **4:** Good understanding; demo done. **3:** Basic understanding; demo attempted. **2:** Weak answers or demo touches wrong system. **1:** Little understanding. **0:** No viva/no demo.
	TOTAL	**35**	

Common mistakes to avoid: missing scope/authorisation; all-High findings with no reasons; plan listing problems instead of actions; incident card in the wrong order; jargon; assessing or demoing on a real/third-party system; claiming screenshots/scans not done; overrunning time.

Instructor reference solution: the complete Adaeze Fashion report in Appendix 9A below.

M. KNOWLEDGE CHECK â€" VIVA QUESTION LIST WITH MODEL ANSWERS

(Instructor copy. Ask 2â€"3 per learner. Mark on understanding, not exact words. Accept any answer that shows the right idea.)

Q1. What is a defensive security assessment, and how is it different from hacking?

- **Model answer:** A security assessment is a permission-based, organised look at a business's devices, accounts and habits to find weaknesses, rate risk and recommend fixes. Hacking is breaking in **without permission**. The difference is written permission: an assessment has it, hacking does not; a penetration test also has permission but this course does not do that.

Q2. Why does your report begin with scope and authorisation?

- **Model answer:** Because you may only assess your own systems or systems you have written permission to assess. Scope says exactly what is included and excluded. Stating it proves the assessment is ethical and legal. It is a fictional business used for training only.

Q3. How did you rate risk, and why is one of your findings High?

- **Model answer:** Risk = likelihood Ã— impact, mapped to Low/Medium/High. (Then a specific example): "The reused weak password is High because the likelihood is High (short, reused, guessable) and the impact is High (one leak reaches the bank, email and social media)."

Q4. Why did you put the free fixes first in your improvement plan?

- **Model answer:** Because they remove the most serious risks at no cost and can be done today, which a small business can actually afford and act on. Expensive items are planned later.

Q5. What are the six incident response steps, and what is the first thing to do in a suspected breach?

- **Model answer:** Prepare, Identify, Contain, Eradicate, Recover, Learn. First action: disconnect the affected device from the network to stop it spreading.

Q6. Why should passwords be changed from a clean device during an incident?

- **Model answer:** So the compromised device cannot capture the new passwords as you type them.

Q7. Why should the business not pay a ransomware demand?

- **Model answer:** Paying does not guarantee the files return, it may fund criminals, and it can mark the business as a willing payer. It is better to contain, preserve evidence, protect accounts, inform the right people, and restore from a clean backup.

Q8. What does your certificate actually qualify you to do?

- **Model answer (key honesty question):** It shows I am a **safer user** and a **junior IT-support beginner with defensive awareness** â€" I can protect accounts and devices, assess a small business's security with permission, and write a plan. It does **not** make me a hacker or a penetration tester, and it does not authorise me to test anyone's system.

Q9. Which finding in your report did you rank highest, and would the owner agree? Why?

- **Model answer:** (Any reasoned answer.) Typically the reused weak password, because it exposes money and multiple accounts at once; the owner would likely agree because it directly touches her money, which she cares about most.

Q10. What would you do differently if this were a real paying client?

- **Model answer:** Get a **signed** authorisation and a written scope; agree start/end times; keep the client's information confidential; and, as a beginner, bring in a more experienced professional for anything beyond a basic assessment.

N. REFLECTION AND RECAP

Plain-English summary. Today you completed the course's central deliverable: a full **defensive security assessment report** for a fictional, authorised business, with an executive summary, scope and authorisation, method, findings table, prioritised improvement plan, incident response card, and conclusion. You presented it clearly, demonstrated one defensive action on your own system, and defended your reasoning in a viva. You also reflected honestly on what this qualification means.

Five important takeaways:

1. A professional deliverable is **clear, honest and ordered** â€" the owner should feel calmer, not confused.
2. **Scope and authorisation** come first; we assess only permitted, fictional systems.
3. **Risk = likelihood Ã— impact**; the plan turns findings into **cost-aware actions, quick wins first.**
4. In an incident: **Prepare, Identify, Contain, Eradicate, Recover, Learn**; first hour â€" **disconnect, don't pay, preserve evidence, change passwords from a clean device, tell the right people, restore from a clean backup.**
5. This makes you a **safer user and a junior IT-support beginner with defensive awareness** â€" not a hacker or penetration tester.

Self-check / reflection questions (write short answers in your workbook):

1. Which part of your report are you most proud of, and why?
2. Which part was hardest, and how did you solve it?
3. If a real business owner read only your executive summary, would they know what to do first?
4. Which viva question made you think most, and what did you learn from it?
5. What is **one** defensive habit from this course you will adopt in your own life this week?
6. How would you explain to a friend, in one sentence, the difference between an assessment and hacking?

Connection to the whole course: S1â€"S6 built the defensive skills; S7 turned them into an assessment; S8 turned findings into a plan and an incident response; S9 brought it all together into a report you can show an employer or use to protect your own family, shop, church or school.

O. INSTRUCTOR EVALUATION NOTES

Observable signs of genuine competence:

- Report has all sections in order, with a clear scope/authorisation statement.
- Executive summary is plain and actionable (top 3 risks, top 3 actions).
- Every risk rating has a likelihood-and-impact reason; at least one satisfactory finding.
- Plan rows are actions with who/when/cost; quick wins first.
- Incident card is short, ordered and usable.
- Presentation is calm, in time, and speaks to the owner.
- Viva answers show understanding; the learner answers the "what does this qualify me for" question honestly.
- The live demo is on the learner's **own** account and the learner explains *why*.

Common misconceptions to watch for and correct:

- "The capstone makes me a hacker/pen tester." â†' Correct firmly and kindly: defensive only; safer user / junior IT-support beginner.
- "I can test my friend's shop as practice." â†' No; only own systems or written permission; use the fictional example.
- "Longer report is better." â†' Clarity beats length.
- "All findings are High." â†' Re-check with likelihood Ã— impact.
- "The demo can use any account." â†' Only your own academy account.

Suggested remediation for common failures:

- **Missing scope:** provide a fill-in scope template and require it before grading the rest.
- **Jargon summary:** give the "say it to Adaeze" exercise â€" rewrite three jargon sentences into plain English.
- **No reasons:** use the two-sentence drill ("Likelihood is ___ because ___; impact is ___ because ___").
- **Wrong incident order:** the shuffle-the-six-cards drill.
- **Demos on wrong system:** re-brief the permission rule and re-run the demo on the learner's own account.

Differentiation:

- **Level 1 (supported):** provide the Adaeze Fashion report skeleton with headings and one filled section; the learner completes the rest using the running example.
- **Level 2 (standard):** the capstone as written.
- **Level 3 (challenge):** add a **second business** for comparison, a **one-page slide set**, a **naira budget total** in the plan, and a "who to call" list on the incident card; optionally present to a small guest panel.

Timing guidance: Protect the **presentation and viva** above all â€" every learner must present. If the build runs long, trim the report polish (not the content) and keep presentations strict to 3 minutes. Keep a visible timer. Reserve the final 5 minutes for the course-completion note.

APPENDIX 9A â€" COMPLETE ADAEZE FASHION CAPSTONE REPORT (instructor model)

> ***DEFENSIVE SECURITY ASSESSMENT REPORT Prepared for:*** *Adaeze Fashion, Port Harcourt* ***Prepared by:*** *[Learner name], Cyber Elias Academy* ***Date:*** *October 2026* ***Fictional business â€" authorised training assessment only.***
>
> ---
>
> ***1. Executive Summary*** *Adaeze Fashion is a small fashion shop that uses one Android phone for banking, POS payments and WhatsApp Business. Overall, security is weak in three main areas. The* ***three biggest risks*** *are: (1) one weak, reused password protects the bank, email and social media at once; (2) the banking phone has no screen lock and is shared with an assistant; and (3) there is no backup of the customer list. The* ***three actions to take first*** *are: switch on Multi-Factor Authentication and change the reused password (free, today); put a screen lock on the phone and stop sharing it for*

banking (free, today); and start a weekly backup of the customer list to Google Drive and a USB (cheap, this week). The remaining items â€" changing the Wi-Fi password, switching Windows Defender back on, and training the two staff â€" are also recommended and are low or no cost.

2. Scope and Authorisation *This assessment covers the fictional business Adaeze Fashion only, with the owner's consent for training.* ***Included:*** *the business phone, the back-office Windows laptop, the shop Wi-Fi, and the business's account and backup habits.* ***Excluded:*** *all other systems; no other person's device or account; no live testing of any system.* ***Nothing was changed during the assessment.*** *Date of assessment: October 2026. This is a fictional business used for training only.*

3. Method *The assessment used the Cyber Elias Academy eight-room checklist: accounts/passwords, MFA, device updates, antivirus/firewall, Wi-Fi/network, backups, staff awareness, and data handling. Evidence was gathered by* ***observation and interview only****. No system was scanned, changed or tested.*

4. Findings

Issue	Risk Level	Reason	Priority
Same weak password `adaeze123` for email, Instagram and bank app	High	L: High â€" short, common, reused; I: High â€" one leak exposes money and multiple accounts	Now
Banking phone has no screen lock and is shared with assistant	High	L: High â€" anyone holding it is in; I: High â€" bank app and customer chats exposed	Now
No backup of customer list (only in WhatsApp)	High	L: High â€" phone loss/theft common; I: High â€" records lost forever	Plan
Wi-Fi password `12345678`, on a card at the counter	High	L: High â€" weak and visible; I: High â€" strangers reach business devices	Now
Back-office Windows not updated; Defender off	High	L: Medium â€" needs a specific attack; I: High â€" records and payments at risk	Now
Staff never trained on fake alerts	Medium	L: Medium â€" scam messages common; I: Medium â€" some payments lost	Later
MFA switched on for bank	Satisfactory â€" Low	L: Low; I: Medium â€" good practice already in place	Keep

5. Prioritised Improvement Plan

Recommendation	Why	How	Who	When	Cost	Priority
Put a screen lock on the phone	Stops anyone opening the bank app	Settings â†' Security â†' Screen lock	Adaeze	Today	â‚¦0	Now
Switch on MFA for bank + email	A stolen password alone cannot work	App â†' Security â†' Two-factor	Adaeze	Today	â‚¦0	Now
Replace weak reused passwords	Stops one leak opening all accounts	Unique long passwords /	Adaeze	Today	â‚¦0	Now

Recommendation	Why	How	Who	When	Cost	Priority
		password manager				
Change Wi-Fi password; remove counter card	Stops strangers joining the network	Router page â†' Wireless â†' new long password	Adaeze/IT	Today	â‚¦0	Now
Switch Defender on and update laptop	Closes known weaknesses	Windows Security â†' turn on; Windows Update	Adaeze/IT	This week	â‚¦0	Now
Back up customer list off the phone	Records survive theft/loss	Save list â†' Google Drive + USB at home	Adaeze	This week	~â‚¦3,500	Plan
Train the two staff on fake alerts	Fewer successful scams	CEA awareness tips / short session	Owner	This month	Low	Plan

6. Incident Response Card *Prepare: start weekly backups; print and post this card; keep one clean, unshared phone/email. If something goes wrong: (1) Disconnect the device from the network. (2) Do not pay or reply. (3) Preserve evidence (photo + time). (4) Change email/bank passwords from a clean phone. (5) Tell the owner, IT, bank and (for a crime) the police. (6) Restore from a clean backup.*

7. Conclusion *The biggest risks at Adaeze Fashion come from a weak reused password, a shared unlocked phone, and the absence of a backup. Most of the most urgent fixes are free and can be done today; the rest are low cost and can be planned within the month. With the recommended actions started immediately, the business's exposure to the most likely and most damaging problems is greatly reduced. A follow-up review is recommended in one month. Thank you for the trust placed in this assessment.*

COURSE-COMPLETION NOTE

Congratulations â€" you have completed the Cyber Elias Academy Cybersecurity course.

Be clear and honest about what you have achieved. Over nine sessions you learned to recognise common scams and threats, create strong unique passwords and switch on MFA, browse and download safely, spot phishing and social-engineering attempts, harden Windows devices (updates, Defender, firewall), secure Wi-Fi, make backups, and â€" most importantly â€" assess a small business's security **with permission**, rate risk, write a prioritised and cost-aware improvement plan, and prepare an incident response card.

This makes you a **safer user** and a **junior IT-support beginner with defensive awareness**. You can help your family, your shop, your church or your school protect their accounts and devices, and you can produce a clear assessment report.

It does **not** make you a hacker, and it does **not** make you a penetration tester. You are **not** authorised to test anyone else's system. Defensive security is about protecting, not attacking. If you ever want to pursue penetration testing, that is a separate, advanced path requiring formal training, proper certifications and, always, **written permission**.

Next steps on your journey:

1. Practise the free fixes in your own life this week: MFA on your email and bank app, unique passwords, a backup of what matters, and a screen lock.
2. Keep your own incident response card somewhere you can find it in a hurry.
3. Consider deepening your skills: a short course in Windows/IT support, networking basics, or an entry-level security awareness pathway â€" build on these foundations honestly, one step at a time.

4. Remember the two rules for the rest of your career: **protect, never attack**, and **never assess a system without written permission**.

From Zero to Expert, Together â€" well done. Keep learning, keep protecting.

END OF SESSION 9

End of the Cybersecurity course (Cyber Elias Academy, 2026).